**Arjun Technologies Pvt. Ltd.**
Bengaluru, Karnataka — 560 001
CIN: U72200KA2008PTC044521 | www.arjuntech.in

# INFORMATION TECHNOLOGY SECURITY POLICY AND PROCEDURES MANUAL

Segment 1 of 3 — Governance · Classification · Access Control

| | | | |
|---|---|---|---|
| **Version** | 3.5 | **Effective Date** | 01 January 2024 |
| **Review Date** | 31 December 2024 | **Classification** | Internal Use Only |
| **Policy Sponsor** | Mr. Rajesh Arjun | **Document Owner** | Mr. Ashwin Kumar |
| **Approved By** | Mr. Vikram Nair | **Legal Review By** | Mr. Sandeep Iyer |
| **Standard Alignment** | ISO/IEC 27001:2022 | **HR Acknowledgement** | Ms. Priya Menon |
| **Document Ref.** | IT-SEC-POL-001-v3.5 | **Segment** | 1 of 3  (Pages 1–60) |

*This document is the property of Arjun Technologies Pvt. Ltd. and is classified as Internal Use Only. It sets out the mandatory information security policy and procedural requirements applicable to all employees, contractors, consultants, and third parties who access, process, store, or transmit information assets owned by or entrusted to the organisation. Compliance is a condition of employment and engagement. Direct queries to Mr. Ashwin Kumar at itsecurity@arjuntech.in.*

## Revision History

The following table records the complete version history of the Arjun Technologies Pvt. Ltd. Information Technology Security Policy and Procedures Manual since its initial publication in January 2010. Every revision has been approved by the Chief Technology Officer, and where revisions involve changes to legal compliance provisions, by the General Counsel. All employees, contractors, and third-party users accessing company systems are responsible for ensuring they are reading the current version of this document at all times. The current version is published on the IT Security intranet page, on the HRMS portal under Policies and Documents, and is additionally distributed by email to all employees when a new version takes effect. Earlier versions are retained in the document archive maintained by the IT Security team and are available for reference on written request.

| Version | Date | Summary of Changes | Author |
|---|---|---|---|
| 1.0 | Jan 2010 | Initial IT security policy — password standards, acceptable use, basic access controls, email security. | S. Deepak |
| 1.1 | Jun 2010 | Added full-disk encryption mandate for laptops following a device theft incident. | A. Kumar |
| 1.2 | Feb 2011 | Acceptable use updated to address cloud storage; Dropbox and Google Drive personal use prohibited. | IT Dept |
| 1.3 | Oct 2012 | Added mobile device policy; BYOD first introduced as a controlled provision with MDM requirement. | M. Rajan |
| 1.4 | May 2013 | Updated access control to reflect Active Directory migration; removed legacy LDAP references. | IT Ops |
| 2.0 | Mar 2015 | Major revision — network segmentation, BYOD, MDM, incident response procedure, vendor security. | V. Nair |
| 2.1 | Sep 2015 | Added third-party vendor security assessment requirements following client audit findings. | A. Kumar |
| 2.2 | Mar 2016 | Password length increased to 12 characters; MFA mandated for all remote access via VPN. | IT Security |
| 2.3 | Nov 2016 | Data retention schedules and secure disposal procedures added; email security updated. | IT Security |
| 2.4 | Jun 2017 | Secure software development lifecycle requirements added for engineering teams. | V. Nair |
| 2.5 | Jan 2018 | Security awareness training programme formalised; phishing simulation requirements added. | IT Security |
| 2.6 | Aug 2019 | Penetration testing requirements updated; vulnerability management SLAs introduced. | A. Kumar |
| 3.0 | Aug 2020 | Complete overhaul — ISO/IEC 27001:2013 alignment; cloud security section added; ISMS integration documented. | S. Menon |
| 3.1 | Feb 2021 | Remote work security controls updated for full-time remote working during COVID-19 period. | IT Security |
| 3.2 | Nov 2021 | Zero Trust architecture principles adopted; VPN split-tunnelling prohibited; updated hybrid work provisions. | V. Nair |
| 3.3 | Jun 2023 | MFA requirements revised; AI tool usage guidelines first published; password manager mandate extended. | A. Kumar |
| 3.4 | Sep 2023 | ISO/IEC 27001:2022 alignment completed; DPDP Act 2023 provisions integrated throughout. | IT Security |
| 3.5 | Jan 2024 | Generative AI security guidelines expanded; supply chain security updated; audit schedule revised. | A. Kumar |

## Table of Contents

This policy manual is published in three segments. Segment 1 covers the governance framework, information classification and handling requirements, and the access control policy. Segment 2 covers network security, endpoint security, cloud security, and the incident response procedure. Segment 3 covers third-party and vendor security, security awareness and training, the business continuity and disaster recovery framework, compliance and audit requirements, and the complete set of appendices including the risk register framework, security metrics dashboard definitions, and the acceptable use policy in full. All segments are available on the IT Security intranet page and on the HRMS portal.

---

**— SEGMENT 1 (This Document — Pages 1–60) —**


**1 Purpose, Scope, and Governance Framework**

1.1 Purpose of This Policy

1.2 Scope of Application

1.3 Governance Framework and Responsibilities

1.4 Legal and Regulatory Framework

1.5 Information Security Management System (ISMS)

1.6 Policy Compliance, Exceptions, and Violations

**2 Information Classification and Handling**

2.1 Classification Framework — Principles and Obligations

2.2 Classification Level Definitions and Examples

2.3 Handling Requirements by Classification Level

2.4 Labelling Standards

2.5 Reclassification and Declassification

2.6 Data Retention and Secure Disposal

2.7 Cross-Border Transfer of Classified Information

**3 Access Control Policy**

3.1 Access Control Principles

3.2 User Account Lifecycle Management

3.3 Privileged Access Management

3.4 Password and Authentication Standards

3.5 Multi-Factor Authentication Requirements

3.6 Remote Access and VPN Policy

3.7 Physical Access Controls

3.8 Access Review and Recertification

— SEGMENT 2 (Pages 61–120) —

**4 Network and Infrastructure Security**

**5 Endpoint Security**

**6 Cloud Security**

**7 Security Incident Response**

— SEGMENT 3 (Pages 121–180) —

**8 Third-Party and Vendor Security**

**9 Security Awareness and Training**

**10 Business Continuity and Disaster Recovery**

**11 Compliance, Audit, and Policy Management**

**Appendices A–I Supporting materials, forms, and registers**

# 1. Purpose, Scope, and Governance Framework

## 1.1 Purpose of This Policy

This Information Technology Security Policy and Procedures Manual establishes the comprehensive framework within which Arjun Technologies Pvt. Ltd. manages, protects, and controls all information assets — whether those assets are owned by the company directly, belong to clients and have been entrusted to the company for processing, or relate to employees and other individuals whose personal data the company holds as a consequence of its business operations. The policy defines the mandatory minimum security standards that every individual who interacts with the company's information systems must meet, the technical and organisational controls that must be in place across the organisation's full technology estate, and the processes that must be followed when those controls are established, maintained, audited, or when they fail. This policy is the authoritative source of security requirements for all employees, contractors, and third-party users of company systems. Where other policies or procedures conflict with this document, this policy takes precedence unless a higher-authority exception has been formally approved in writing by the Chief Technology Officer.

Information security is a foundational business requirement for Arjun Technologies, not an administrative compliance exercise or an IT department concern to be addressed at the margins of operational planning. The company operates across five cities and serves clients in financial services, healthcare, manufacturing, retail, and the public sector — all of which are industries where the integrity, confidentiality, and availability of information systems are critical to the safety and wellbeing of end users and to the legal obligations of the client organisations themselves. Clients in these sectors share sensitive data with Arjun Technologies — patient records, financial transaction data, personal identification information, proprietary algorithms, and regulated business information — because they have made a judgement that the company has both the technical competence and the organisational culture to protect that information. A single significant security failure — a ransomware encryption event, an uncontrolled data exfiltration, an accidental email disclosure of client personal data, or a misconfigured cloud storage bucket exposed to the internet — has the potential to destroy years of earned client trust in a matter of hours, to trigger regulatory investigation and significant financial penalties, and to expose individual employees to personal legal liability. The purpose of this policy is to prevent such failures through the design and disciplined maintenance of controls that are proportionate to the risks they address.

This policy has been developed in alignment with ISO/IEC 27001:2022, the current edition of the international standard for information security management systems. It also incorporates the specific requirements of the Digital Personal Data Protection Act, 2023, the Information Technology Act, 2000 and its amendments, the IT (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011, applicable provisions of

the Companies Act, 2013, and the security requirements embedded in the company's contracts with major clients across regulated industries. Where a specific client contract imposes security requirements that are more stringent than those set out in this policy — which is frequently the case for clients in banking, insurance, healthcare, and government — those client-specific requirements apply to all systems, personnel, and processes engaged in delivering services to that client, and the more stringent standard governs without exception. Where the EU General Data Protection Regulation applies to the processing of EU resident personal data in connection with specific client engagements, the requirements of that regulation are addressed in detail in the Data Privacy Policy, which must be read alongside this document.

This version of the policy — Version 3.5, effective 01 January 2024 — represents the most comprehensive revision in the policy's history. It incorporates learnings from the company's ISO/IEC 27001:2022 recertification audit completed in September 2023, from a major penetration test conducted by an independent third party in October 2023, from the evolving threat landscape including the significant increase in ransomware and social engineering attacks targeting Indian IT services companies, and from the enactment of the DPDP Act 2023, which for the first time creates a comprehensive Indian statutory framework for personal data protection with penalties that can reach ■250 crore for a single violation. The policy is reviewed formally at least once per year by the IT Security Steering Committee and may be updated at any time when a material change in the threat environment, a significant new legal or regulatory obligation, or an internal security incident reveals a gap in the existing provisions. All employees and contractors are notified of updates through the IT Security intranet page and by direct communication.

The structure of this manual reflects a deliberate decision to present security requirements in the context of the risks they address, rather than as a list of technical controls without context. The company has found over many years of operating a security programme that employees comply more consistently with requirements they understand and consider reasonable than with requirements that appear arbitrary or disconnected from any apparent purpose. The rationale sections embedded within each major provision of this policy are therefore not editorial embellishment — they are a deliberate investment in the informed, understanding-based compliance that produces materially better security outcomes than enforcement-based compliance alone. Employees who understand why a control exists are more likely to apply its spirit correctly in situations that the written rule does not explicitly address, and are more likely to raise a concern when they observe something that seems to conflict with the control's purpose even if it does not technically violate the rule's letter.

### 1.2 Scope of Application

This policy applies in its entirety to the following categories of individual: all permanent and fixed-term employees of Arjun Technologies Pvt. Ltd. at all locations, at all levels of seniority,

and in all departments; all contractors, consultants, freelancers, and independent third-party workers who are provided with access to company systems, data, premises, or networks in connection with their engagement; all third-party vendors, managed service providers, technology partners, and business partners whose services involve any interaction with company information systems or company data; all interns, graduate trainees, and apprentices who are provided with access to company systems during their programme; and all members of the Board of Directors and the Executive Leadership Team in their capacity as users of company systems and custodians of company information.

The policy applies to all information assets of Arjun Technologies, without limitation as to format, medium, or location. An information asset is any item that has value to the organisation, and includes: electronic data stored on servers, workstations, laptops, mobile devices, external storage media, and cloud services; software applications, source code, configuration files, and development environments; physical documents, printed materials, handwritten notes, and physical storage media containing company information; verbal information communicated in meetings, telephone calls, or video conferences that relates to the company's confidential business; and the infrastructure and systems through which all of the above is created, stored, processed, or transmitted. The fact that a specific item of information is not listed in the above does not mean it falls outside the scope of this policy — any information whose compromise could harm the company, its clients, its employees, or other stakeholders is in scope.

The policy applies regardless of the physical location from which information is accessed or processed. The company's hybrid working model means that employees access company systems from their homes, from client offices, from hotels and conference venues, from airports, and from any other location where they have connectivity. The security obligations that apply at the corporate office apply equally in all of these locations. The nature of modern cyber threats — which are agnostic to geography and which frequently target the weakest point in an organisation's security posture, which is often the remote worker on a home network or a hotel Wi-Fi — means that it would be unreasonable and dangerous to apply different security standards to different working locations. Employees must internalise their security obligations as personal professional standards rather than as situational rules that apply only when they are at their desk in the office.

Systems and information owned by clients to which company employees have been granted access for the purpose of delivering contracted services present a specific scope consideration. These systems are not company assets, and the company has no administrative authority over them. However, the company's contractual obligations to the client typically require the company to protect client systems and data at least as stringently as it would protect its own, and in regulated sectors the obligations are typically more stringent. Employees working with client systems must comply with both this policy and with any applicable client security requirements. Where the two sets of requirements differ, the more stringent standard applies. The company's

IT Security Business Partners are available to advise on the interpretation of client security requirements and on how to satisfy both sets of obligations simultaneously when they appear to conflict.

The scope of this policy extends to the personal devices of employees who participate in the company's Bring Your Own Device programme. Employees who access company email, calendar, or other company data on a personal device under the approved BYOD arrangement have agreed, as a condition of that arrangement, to install the company's Mobile Device Management profile on their device. The MDM profile manages only the company-related applications and data on the device — it does not access personal photos, personal applications, personal messages, or any other non-company content. However, the company's security requirements for the company data stored on or accessible through that personal device apply in full, including the requirement to lock the device with a PIN or biometric, to use the approved VPN when accessing company data remotely, and to report the device to IT Security immediately if it is lost, stolen, or compromised. The scope of this policy does not extend to the personal activities of employees conducted on personal devices that have no connection to company data or systems.

### 1.3 Governance Framework and Responsibilities

Effective information security governance at Arjun Technologies requires that accountability for security decisions and security outcomes is clearly assigned at every level of the organisation, from the Board of Directors to the individual employee. The governance framework described in this section defines those accountability lines and ensures that security decisions are made at the appropriate level, with appropriate expertise, and with appropriate visibility to the stakeholders who need to understand and act on them. The framework also ensures that the security programme has the organisational authority to require compliance, to allocate resources, and to escalate non-compliance without obstruction — because a security programme that depends on voluntary cooperation and is unable to enforce its requirements in cases of resistance is a programme that will ultimately fail.

At the Board level, the Board of Directors holds ultimate accountability for information security risk as an element of the company's overall risk management framework. The Board receives a security programme performance report from the CTO at each quarterly Board meeting, including key security metrics, a summary of material incidents since the last report, the current status of the risk register, and any material changes to the threat landscape or regulatory environment that affect the company's security posture. The Board is responsible for approving the overall information security budget as part of the annual budget process, for ensuring that the security programme receives adequate organisational priority and resources, and for holding the CEO accountable for the cultural and operational conditions that enable effective security management.

At the Executive level, the Chief Executive Officer is responsible for establishing and maintaining a culture of security-consciousness throughout the organisation. This cultural responsibility is distinct from the technical management of the security programme, which rests with the CTO. The CEO's role is to ensure that security is consistently treated as a business priority rather than a technical inconvenience — that managers throughout the organisation model secure behaviour, that adequate time and resources are allocated to security obligations including mandatory training, that security concerns raised by the IT Security team receive prompt and serious attention from the business, and that employees across all functions understand that security compliance is as much a part of their professional obligation as the quality of the work they produce for clients.

At the technology leadership level, the Chief Technology Officer is responsible for the information security strategy, programme design, and architectural direction of the company's security posture. The CTO chairs the IT Security Steering Committee, approves all material changes to security policy and controls, and is the final authority on security investment decisions and risk acceptance decisions. The CTO receives a weekly security dashboard from the Information Security Manager and escalates material concerns to the CEO and, where warranted, to the Board. The current CTO is Mr. Vikram Nair, whose direct contact information is available on the HRMS portal.

At the operational security level, the Information Security Manager (Mr. Ashwin Kumar) is responsible for the day-to-day management, operation, and continuous improvement of the information security programme. The ISM's responsibilities include: developing and maintaining this policy and all subsidiary security standards and procedures; conducting the annual information security risk assessment; managing the incident detection and response capability; overseeing the security awareness and training programme; managing relationships with third-party security service providers including the penetration testing firm and the SIEM managed service provider; reporting to the IT Security Steering Committee on programme performance; and advising business units on the security implications of new technology investments and new client engagements. The ISM has the authority to require immediate remediation of critical vulnerabilities, to suspend user access pending investigation of a security incident, and to escalate security non-compliance directly to the relevant SVP and to HR without requiring approval from any intermediate manager.

| Role / Body | Security Accountability | Reporting Frequency | Escalation Path |
|---|---|---|---|
| Board of Directors | Ultimate accountability for information security. Approves security budget and risk appetite. | Quarterly (Board pack) | External audit findings; regulatory matters. |
| Chief Executive Officer | Organisational culture of security. CEO-level visibility of material incidents. | As required | Board of Directors. |
| Chief Technology Officer | Security strategy, architecture, and programme direction. Chairs IT Security Steering Committee. | Weekly (ISM dashboard) | CEO for material incidents. |
| IT Security Steering Committee | Quarterly programme review. Risk register review. Major investment approvals. | Quarterly | CTO escalation. |
| Information Security Manager | Operational security management. Incident response. Risk assessments. | Weekly to CTO; Quarterly to Steering Committee | CTO for material incidents. |

| Role / Body | Security Accountability | Reporting Frequency | Escalation Path |
|---|---|---|---|
| IT Security Business Partners | BU-level security guidance. New technology assessment. Client security requirement interpretation. | As required | CISO |
| IT Operations Team | Security control implementation. Patch management. SIEM operation. Security infrastructure. | Daily operational | IT Manager, CISO |
| All Employees and Contractors | Full policy compliance. Incident reporting. Mandatory training completion. | Ongoing | Line manager, ISM, HR |

### 1.4 Legal and Regulatory Framework

The information security obligations of Arjun Technologies arise from a combination of applicable Indian law, international contractual standards, and the company's own commitments to clients in its service agreements. The following discussion summarises the primary instruments that shape the requirements in this policy. Employees are not expected to be legal specialists in these instruments, but they should understand that the controls described in this policy are not arbitrary preferences of the IT Security team — they are mandatory requirements whose breach can expose the company to enforcement action, financial penalties, and reputational damage that would be materially harmful to the company and to every individual who works for it.

The Information Technology Act, 2000, as amended by the Information Technology (Amendment) Act, 2008, is the primary Indian legislation governing electronic transactions and cybercrimes. Section 43A of the Act imposes civil liability on a body corporate that is negligent in implementing and maintaining reasonable security practices and procedures in relation to sensitive personal data, where such negligence results in wrongful loss or gain to any person. Section 66 and related provisions create criminal liability for unauthorised access to computer systems, data theft, computer-related fraud, and the publishing of obscene material in electronic form. Section 72A creates liability for the unlawful disclosure of personal information obtained in the course of providing services. The IT (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011 — issued under Section 43A — specifically require companies that handle sensitive personal data to implement either ISO 27001 or an equivalent information security standard, to maintain a documented information security policy that is published on their website, to obtain explicit consent before collecting sensitive personal data, and to use sensitive personal data only for the purpose for which it was collected. Arjun Technologies's information security programme, of which this policy is a central component, is designed to satisfy and exceed these requirements.

The Digital Personal Data Protection Act, 2023 — enacted in August 2023 with phased implementation beginning in 2024 — is India's most significant data protection legislation to date and introduces a fundamentally new legal framework for personal data processing in India. Under the DPDP Act, Arjun Technologies operates as a Data Fiduciary for the personal data of its employees and, in many client engagements, for the personal data of clients' end users. As a Data Fiduciary, the company is required to implement appropriate technical and organisational security measures to prevent personal data breaches; to maintain the accuracy and

completeness of personal data; to retain personal data only for as long as necessary for the specified purpose; to notify the Data Protection Board of India and affected data principals of a personal data breach that is likely to cause harm, within the timelines prescribed by the Board in its regulations; and to ensure that data processors engaged by the company — including all technology subcontractors and cloud service providers — provide contractually binding commitments to maintain equivalent levels of protection for the personal data they process on the company's behalf. The maximum financial penalty under the DPDP Act for a breach of these obligations can reach ■250 crore for a single violation, making robust compliance a matter of financial as well as ethical necessity.

The ISO/IEC 27001:2022 standard, while not itself a legal instrument, is the internationally recognised benchmark for information security management systems and is a contractual requirement in many of the company's client agreements, particularly with clients in financial services and with multinational corporations that are themselves subject to international data protection regulations. Arjun Technologies holds ISO/IEC 27001:2022 certification covering all five office locations, assessed annually by an independent NABCB-accredited certification body. The certification audit involves a comprehensive review of the company's risk management processes, control implementation, documentation, and incident management practices. Maintaining this certification in good standing is therefore both a contractual obligation and a practical demonstration of the company's security posture to prospective clients. Any material non-compliance with this policy that is identified during a surveillance audit has the potential to result in a finding that could place the certification at risk.

| Legal Instrument | Jurisdiction | Core Security Obligation | Maximum Penalty / Consequence |
|---|---|---|---|
| Information Technology Act, 2000 | India | Reasonable security practices for sensitive personal data; prohibition on unauthorised access | Civil liability for negligence; criminal prosecution for... |
| IT (SPDI) Rules, 2011 | India | ISO 27001 or equivalent security standard; documented security policy; cooperation with CERT-In | Civil liability; regulatory investigation for non-... |
| DPDP Act, 2023 | India | Data Fiduciary security obligations; breach notification to DPB; data principal rights fulfilment | Up to ■250 crore per violation; mandatory remedial... |
| Companies Act, 2013 | India | Board-level accountability for internal controls including IT; CSR and investigation reporting | Director liability; SEBI investigation; reputational... |
| ISO/IEC 27001:2022 | International | Risk-based ISMS; continuous improvement; statement of applicability; annual external audit | Loss of certification; loss of client contracts; los... |
| PCI DSS v4.0 | Global (fintech clients) | Strict cardholder data environment controls; segmentation; quarterly scanning | Loss of PCI certification; client termination; card... |
| GDPR | EU/EEA (client employees) | Personal data protection for EU residents; DPA agreements with processors; breach notification | Fines up to €20M or 4% of global turnover; data... |
| Client Security Contracts | Varies by client | Client-specific requirements typically exceeding statutory minimums; right to audit clauses; penetration... | Contract termination; indemnity claims; reputational... |

### 1.5 Information Security Management System

Arjun Technologies maintains a formal Information Security Management System in accordance with the requirements of ISO/IEC 27001:2022. The ISMS is the systematic framework within which the company identifies the information assets that require protection, assesses the threats and vulnerabilities that affect those assets, determines the likelihood and potential business impact of security incidents involving those assets, selects and implements the controls that most effectively reduce risk to an acceptable level, monitors the operation of those controls over

time, measures their effectiveness against defined performance indicators, and responds to changes in the risk environment by adapting controls and updating the risk treatment plan. The ISMS is not a static framework — it is a continuous management process that reflects the reality that the threat landscape, the company's technology estate, and the regulatory environment are all in constant evolution.

The ISMS at Arjun Technologies operates on the Plan-Do-Check-Act management cycle. In the Plan phase, the company conducts a comprehensive information security risk assessment annually — typically in October, prior to the annual management review — identifying all information assets within the defined scope, the threats and vulnerabilities relevant to each asset, the existing controls and their effectiveness, the residual risk after controls are applied, and the risk treatment decisions for each residual risk above the company's defined risk acceptance threshold. The risk assessment is conducted by the ISM with input from IT Operations, the business units, and Legal, and is reviewed and approved by the IT Security Steering Committee. The output of the risk assessment includes the Risk Register, the Risk Treatment Plan, and the updated Statement of Applicability — the document that records which of ISO 27001's Annex A controls are applicable to the company and whether each has been fully implemented, partially implemented, or explicitly excluded with documented justification.

In the Do phase, the company implements and operates the controls identified in the Plan phase, integrating them into its operational processes in a way that balances security effectiveness with operational efficiency. Security controls are not imposed on the business as external constraints — they are designed in collaboration with the business units they affect, to ensure that they achieve their security objective without creating unnecessary obstacles to the legitimate work of the people who must comply with them. The Do phase also includes the delivery of security awareness training to all employees, the onboarding of new employees into the security requirements that apply from their first day, and the management of security within the supply chain through vendor assessment and contractual security obligations.

In the Check phase, the company monitors and measures the performance of the ISMS through several mechanisms operating at different frequencies. On a continuous basis, the SIEM platform aggregates and analyses security events from across the technology estate, triggering alerts for anomalous patterns that may indicate a security incident in progress. On a monthly basis, the ISM reviews a set of defined security KPIs — including patch compliance rates, training completion rates, vulnerability remediation SLA compliance, and incident response time metrics — and reports these to the CTO in the weekly security dashboard. On a quarterly basis, the IT Security Steering Committee reviews the KPI trend data, the current risk register, and the status of any major remediation projects. On an annual basis, an independent internal audit team reviews the ISMS against the ISO 27001 requirements and produces a formal audit report with findings and recommendations. Additionally, an independent external penetration testing firm conducts both external and internal penetration tests annually, and the results feed directly

into the risk assessment and control improvement programme.

In the Act phase, the company responds to findings from the Check phase by implementing corrective actions for identified non-conformities, updating the risk register to reflect new threats or changed vulnerabilities, revising controls where evidence suggests they are not operating effectively, and updating this policy where new requirements or gaps have been identified. The Act phase also includes the management review — an annual formal review by the IT Security Steering Committee and senior management of the ISMS's performance, adequacy, and suitability, which produces documented decisions about changes to the ISMS scope, security objectives, and resource allocation for the coming year. The management review is a mandatory requirement of ISO 27001 and is an input to the annual recertification audit.

### 1.6 Policy Compliance, Exceptions, and Violations

Compliance with this policy is mandatory for all individuals within its scope. There are no optional provisions in this document — every requirement stated here must be met unless a formal exception has been approved through the process described in this section. The IT Security team does not have the authority to grant informal exceptions, and line managers do not have the authority to waive security requirements for members of their teams on the basis of operational convenience, deadline pressure, or personal judgement about the likelihood of a security incident. Exceptions to security requirements create vulnerabilities that can be exploited by external attackers or that can lead to accidental data loss, and the company must maintain consistent visibility of all exceptions in order to manage its overall security posture effectively.

Where an employee, contractor, or business unit identifies a situation in which strict compliance with a specific requirement in this policy is genuinely operationally impractical — for example, where a specific client system cannot support the required version of TLS for technical reasons that are outside the company's control, or where a specific operational tool requires local administrator rights that would normally be prohibited — the exception request process must be followed. The process requires the requester to submit a written exception request to the ISM describing the specific provision from which an exception is sought, the specific technical or operational reason that compliance is not currently achievable, the compensating controls that will be applied during the period of the exception to reduce the risk created by non-compliance, the proposed duration of the exception, and the remediation plan that will achieve full compliance. The ISM reviews the request and either approves it with documented conditions, escalates it to the CTO for approval if the risk is material, or declines it with a written explanation. All approved exceptions are logged in the Exception Register maintained by the IT Security team and are reviewed at each quarterly Steering Committee meeting.

Violations of this policy — whether intentional or inadvertent — are taken seriously. The severity of the response to a violation reflects the nature of the provision violated, the potential harm

caused or risked by the violation, the employee's awareness of the requirement, and whether the violation was a one-time oversight or part of a pattern. Minor violations — such as failing to lock a workstation before a brief absence, or sending an internal-use document to a personal email address through genuine inadvertence — are typically addressed through a manager-led coaching conversation and mandatory remedial training, with a formal notation on the employee's security compliance record. Moderate violations — such as repeatedly bypassing required security controls, installing unauthorised software on a company device despite prior warnings, or failing to report a known security incident promptly — are escalated to HR and treated as conduct matters under the company's disciplinary procedure, which may result in a formal written warning. Serious violations — such as deliberately circumventing security controls to exfiltrate company data, sharing system credentials with an unauthorised third party, or attempting to cover up a security incident — are treated as gross misconduct and may result in immediate suspension, a formal investigation, and termination of employment. Where a violation constitutes a criminal offence under Indian law, the matter will be referred to law enforcement.

## 2. Information Classification and Handling

### 2.1 Classification Framework — Principles and Obligations

All information created, received, processed, stored, or transmitted by or on behalf of Arjun Technologies — in any format, on any medium, and in any location — must be assigned a classification level that reflects its sensitivity and the potential consequences of its unauthorised disclosure, modification, or destruction. The classification level determines the minimum security controls that must be applied to that information throughout its entire lifecycle, from the moment of creation or receipt until the moment of authorised disposal or destruction. Classification is the foundational mechanism through which the company's security controls are proportionately calibrated to the value and sensitivity of the information they protect — ensuring that the most sensitive information receives the strongest protection while avoiding the operational overhead of applying the highest controls to all information regardless of its sensitivity.

Every employee and contractor who creates or handles information on behalf of Arjun Technologies shares the responsibility for ensuring that the information they work with is correctly classified and handled in accordance with the requirements for its classification level. This is not an exclusively IT or Records Management function — it is a professional obligation of every individual who touches information in the course of their work. A software engineer who creates a technical design document must consider whether it should be classified as Confidential or Restricted based on the sensitivity of the system it describes. A finance analyst who prepares a budget forecast must classify that document at the Confidential level. An HR professional who maintains employee records must classify those records at the Confidential or Restricted level depending on the nature of the information they contain. The business unit that creates or owns information is responsible for its correct classification, and the IT Security team provides the framework, guidance, and enforcement oversight.

The classification framework uses four levels arranged in ascending order of sensitivity and stringency of required controls: Public, Internal Use Only, Confidential, and Restricted. These four levels cover the full spectrum of information sensitivity from completely open public information at one end to the company's most sensitive data at the other. The four-level structure has been deliberately chosen to avoid both the complexity of a more granular system — which creates classification fatigue and leads to inconsistent application — and the bluntness of a simpler two-level system, which cannot adequately calibrate the different risk profiles of the large middle range of information that is sensitive but not at the highest level of sensitivity.

The principle of classification upwards applies whenever the correct classification level for a piece of information is genuinely uncertain. In cases of doubt, the employee must apply the higher classification level until clarification is obtained from the IT Security team or the Legal and Compliance team. This principle reflects a deliberate risk management philosophy: the cost of applying controls that prove to be more stringent than necessary — some additional operational

friction, some additional access management overhead — is materially lower than the cost of failing to protect information that proves to be more sensitive than the employee initially assessed. The principle of classification upwards is particularly important when handling information received from third parties, clients, or government entities, where the sensitivity of the information may not be immediately apparent from its content.

Information classification is dynamic, not permanent. The appropriate classification level for a piece of information may change over time as its sensitivity changes — a product development plan that is Restricted while the product is in development may appropriately be reclassified to Confidential after public announcement, and subsequently to Public after full disclosure in a press release. Employees who own or manage information are responsible for reviewing its classification periodically and initiating a reclassification when the information's sensitivity has materially changed. The reclassification process requires documentation of the reason for the change, approval by the information owner's line manager, and notification to the IT Security team for records purposes. Where reclassification involves downgrading from Restricted to a lower level, ISM approval is additionally required.

The information classification framework must be distinguished from the personal data classifications established by the DPDP Act 2023 and the IT (SPDI) Rules 2011. Personal data — information relating to an identified or identifiable natural person — has its own regulatory handling requirements that apply in addition to the company's classification controls. Sensitive personal data or information, as defined by the SPDI Rules, includes passwords, financial information, health and medical records, sexual orientation, and biometric data, and requires enhanced controls beyond the standard Confidential level. Where personal data falls within the company's Confidential or Restricted classification levels, both sets of requirements apply simultaneously. The Data Privacy Policy provides the complete framework for handling personal data and must be read alongside this policy.

### 2.2 Classification Level Definitions and Examples

The four classification levels used by Arjun Technologies are defined as follows, with examples of the types of information typically assigned to each level. These examples are illustrative rather than exhaustive — the classification of specific information items must always be assessed based on the definition of the level rather than by mechanical reference to the example lists. The examples are intended to support the development of sound classification judgement, not to substitute for it.

| Classification Level | Sensitivity Definition | Common Examples — Internal | Common Examples — Client / Third Party | Default Handling Posture |
|---|---|---|---|---|
| Public | Information that has been formally approved for unrestricted release to the general public | Approved press releases, published annual reports, job postings, marketing collateral, publicly available product documentation | Approved press releases, published annual reports, job postings, marketing collateral, publicly available product documentation | No restrictions on sharing; standard brand and accuracy review before publication |
| Internal Use Only | Information intended for internal use. Not approved for public release. Unauthorised disclosure would cause minor inconvenience but no significant harm | Internal newsletters, general policy documents, non-sensitive meeting notes, organisational charts, internal directories | Standard project correspondence, non-sensitive contract terms, general business communications | Share within the organisation and with authorised third parties; do not post publicly |
| Confidential | Sensitive information whose unauthorised disclosure could cause significant harm to the company, its clients, employees, or partners | Source code and technical designs, client project deliverables, financial forecasts, HR records, employee personal data | Client data, signed contracts, proprietary methodologies, pricing models, audit findings | Share only on a need-to-know basis; encrypt in transit and at rest; mark clearly |

| Classification Level | Sensitivity Definition | Common Examples — Internal | Common Examples — Client / Third Party | Default Handling Posture |
|---|---|---|---|---|
| Restricted | The most sensitive information the company holds. Unauthorised disclosure could cause severe harm to the company, its clients, or individuals. Access is strictly limited to named individuals on a need-to-know basis. | Cryptographic private keys and certificates used to sign software releases; Board-level strategic plans before announcement; Merger and acquisition documents; Unencrypted backup media containing production data; Source code for proprietary algorithms | Client encryption keys held in escrow; Unreleased financial results; Litigation strategy documents; Personal data of employees subject to GDPR Article 9 special category data; Trade secrets disclosed by partners under NDA | Encrypted at rest and in transit; Physical access restricted to named individuals; Access logged and reviewed quarterly; Never stored on personal devices; Never transmitted by unencrypted email; Destruction by cryptographic erasure or physical shredding |

### 2.3 Handling Requirements by Classification Level

The following handling requirements apply to information of each classification level across the full information lifecycle. These requirements represent the minimum mandatory controls. Business units and project teams are permitted and encouraged to apply more stringent controls than the minimum where the risk profile of specific information warrants it — for example, applying Restricted-level controls to a particularly sensitive Confidential document where the potential harm from unauthorised disclosure is disproportionate to its base classification. Less stringent controls than those specified below are never acceptable without a formally approved exception.

| Lifecycle Stage | Internal Use Only | Confidential | Restricted |
|---|---|---|---|
| Storage — Electronic | Company-managed file systems or approved cloud platforms. No special controls beyond standard access management. | Company-managed cloud platforms with access restricted to named individuals or groups. Encryption at rest required. Access reviewed annually. | Encrypted storage only. Never on personal devices or unmanaged systems. Access restricted to named individuals. Access logged and reviewed quarterly. |
| Storage — Physical | Store in desk or cabinet when not in use. Standard office security. | Store in locked drawer or cabinet when not in use. Key or combination access only. | Locked safe or secure room. Access restricted to named individuals. Access log maintained. |
| Transmission — Internal | Standard company email and collaboration tools. No special controls. | Company email or approved file sharing platform. Do not forward to personal email accounts. | Encrypted transfer only. Verify recipient's identity before sending. Do not transmit via unencrypted channels. |
| Transmission — External | Company email with manager approval. Do not send to personal email accounts. | Encrypted email or approved file sharing platform. Verify recipient's identity before sending. Do not transmit via unencrypted channels. | Encrypted transfer only. Verified recipient only. Confirm receipt. Consider whether the data should be transmitted at all. |
| Printing | Collect immediately from printer. Do not leave unattended. | Collect immediately from printer. Do not leave unattended. Store locked when not in use. | Manager approval required before printing. Print to locked collection only. Do not leave unattended. Shred when no longer needed. |
| Disposal — Electronic | Standard deletion acceptable. | Secure deletion using approved tool. Physical destruction of storage media. | Physical destruction of storage media. Witnessed and logged. Certificate of destruction retained. |
| Sharing with Third Parties | Manager approval. Confirm the third party has a legitimate business need. | Formal approval required. NDA in place. Data Processing Agreement in place where personal data is involved. | Board or Legal approval required. NDA in place. Data Processing Agreement in place. Security assessment of the third party completed. |

### 2.4 Labelling Standards

Information classified at the Internal Use Only, Confidential, or Restricted level must be labelled with its classification to ensure that everyone who encounters it understands immediately the controls that apply to it. Labelling is a preventive control — a document that is clearly marked 'Confidential' on every page is significantly less likely to be casually forwarded externally, left on a printer, or stored without appropriate controls than a document whose sensitivity is not immediately obvious. The absence of a label on a sensitive document is not a substitute for a low classification — an unlabelled document must be treated at the Confidential level by default until its appropriate classification is determined.

For electronic documents produced as standalone files — Word documents, PDF reports, PowerPoint presentations, Excel spreadsheets, and similar — the classification label must appear in both the page header and the page footer of every page of the document. The label must be clearly legible and must use the exact classification level terminology defined in Section 2.2: 'Internal Use Only', 'Confidential', or 'Restricted — Authorised Personnel Only'. For documents stored in company systems with metadata support, the classification level must additionally be set as a document metadata tag. For email communications whose content is

Confidential or Restricted, the classification level must be stated in the first line of the email body and in the subject line where the subject line does not itself reveal sensitive information.

For physical documents and printed materials, the classification label must be stamped or clearly printed on the cover page and on every subsequent page at both the top and bottom. For multi-part physical records that are maintained together — such as a client contract with appendices — the classification level of the entire document set is determined by the most sensitive component. The entire set must be labelled and stored at the level of the most sensitive component. For legacy documents created before the current labelling policy took effect, the document owner should review and apply appropriate labels when the document is next accessed or distributed. The absence of a label on a legacy document does not change the obligation to classify and protect it appropriately.

### 2.5 Reclassification and Declassification

The sensitivity of information can change over time in both directions — sometimes increasing as additional detail accumulates, more often decreasing as information ages, becomes public, or becomes less operationally relevant. The reclassification process must be followed whenever an information owner determines that the current classification level no longer accurately reflects the sensitivity of the information. Reclassification without following the proper process is not permitted — an employee who decides unilaterally that a Confidential document should now be treated as Internal Use Only, without going through the reclassification process, is exposing that information to inadequate controls based on a subjective judgement that has not been validated by the appropriate governance authority.

Upward reclassification — moving information to a higher classification level — requires documentation of the reason for the change and approval by the information owner's line manager. The ISM must be notified within five working days so that the classification records can be updated and any access controls or handling procedures can be adjusted to reflect the new level. All parties who currently hold or have access to the information must be notified of the reclassification and must adjust their handling accordingly. Where upward reclassification of a document affects third parties who have been provided with copies under the lower classification level, the information owner must contact those third parties to inform them of the revised classification and confirm that they will apply the more stringent handling requirements.

Downward reclassification — moving information to a lower classification level — is more operationally significant and requires a higher level of approval. Moving information from Confidential to Internal Use Only requires line manager approval plus HRBP notification where the information involves employee data. Moving information from Restricted to any lower level requires ISM approval plus CTO notification. The justification for downward reclassification must be documented and retained for audit purposes. Downward reclassification does not

retrospectively change the handling obligations that applied to copies of the document that were made while the higher classification was in force — prior copies must continue to be handled at the higher level or destroyed.

### 2.6 Data Retention and Secure Disposal

Information must not be retained for longer than is necessary for the purpose for which it was collected or created. Retaining information beyond its necessary period creates unnecessary risk — the more information a company holds, the larger the potential impact of a security breach. Retention of personal data beyond the period necessary for its original purpose is also a specific violation of the DPDP Act 2023, which requires that personal data be erased after the purpose for which it was collected has been fulfilled. The company's Data Retention Schedule, maintained by Legal and updated annually, defines the required retention periods for all major categories of company information.

| Information Category | Retention Period | Disposal Method | Notes |
|---|---|---|---|
| Employee personal data | Duration of employment + 7 years | Secure electronic deletion | Includes payroll, appraisal records, health information, disc |
| Client contracts and correspondence | Duration of contract + 10 years | Secure electronic deletion | Legal hold takes precedence over retention schedule where |
| Financial records and accounts | 7 years from end of financial year | Secure electronic deletion | Required under Companies Act and Income Tax Act. |
| System and application logs | 12 months online; 12 months archived | Automated deletion from active and archive systems | Security event logs: 24 months online to support incident in |
| Security incident records | 5 years from incident closure | Secure electronic deletion | Extended where incident involves ongoing litigation. |
| CCTV footage | 30 calendar days | Automatic overwrite | Extended where footage is relevant to an ongoing security |
| Email communications | 3 years; auto-archived after 1 year | Automated deletion from live and archive | Legal hold applied through compliance system where requi |
| Source code and version history | Indefinite while product is active; archived on product retirement | Secure deletion | Repository retained for compliance and audit purposes |
| Background verification reports | Duration of employment + 3 years | Secure deletion | Third-party agency retention managed under their own poli |
| Security training records | Duration of employment + 5 years | Secure deletion | Required for compliance evidence and certification audits. |
| Penetration test reports | 5 years from report date | Secure deletion | Restricted classification. Current report to ISM; prior reports |
| Vendor security assessments | Duration of vendor relationship + 2 years | Secure deletion | Relevant to ongoing risk management and contract manag |

Secure disposal of electronic information means rendering it irrecoverable through a method appropriate to the classification level of the information being disposed of. For Internal Use Only and Confidential information stored on hard disk drives, a minimum of three-pass overwrite using an approved data sanitisation tool is required. For Restricted information stored on hard disk drives, physical destruction of the drive by degaussing followed by shredding is required, carried out by the IT Security team or an approved specialist third-party destruction service with a certificate of destruction issued. For solid-state drives at all classification levels above Public, physical destruction is required because overwrite-based sanitisation is not reliably effective on SSD storage media due to wear levelling and overprovisioning behaviour. For cloud-hosted data, the company's contracts with cloud service providers require certified data deletion that meets the NIST 800-88 standard, and confirmation of deletion must be obtained in writing before

the cloud account or storage resource is closed.

### 2.7 Cross-Border Transfer of Classified Information

The transfer of company information across international borders is subject to both the classification-based controls described in this section and the legal requirements applicable to the specific type of information being transferred. Cross-border transfer of Internal Use Only information may be accomplished through standard company channels including company email and approved cloud services, provided the destination jurisdiction does not impose specific import controls on the type of information involved. Cross-border transfer of Confidential information requires prior confirmation that the receiving party is subject to equivalent or stronger privacy and security obligations — typically verified through the existence of a signed NDA, a Data Processing Agreement, or both.

Cross-border transfer of personal data — including Confidential employee data, client employee data, or any personal data subject to the DPDP Act or GDPR — is subject to the specific requirements of those statutes, which may require that transfers are made only to jurisdictions with an adequate level of data protection as determined by the relevant regulatory authority, or that appropriate safeguards are in place for transfers to other jurisdictions. Under the DPDP Act 2023, the central government will notify countries to which personal data may be transferred; until that notification is issued, any proposed cross-border personal data transfer requires prior Legal and Compliance team review. Under the GDPR, transfers of EU resident personal data outside the EU/EEA require either an adequacy decision from the European Commission or appropriate safeguards such as Standard Contractual Clauses. All proposed cross-border transfers of personal data must be reviewed and approved by the Legal and Compliance team before the transfer occurs.

Restricted information must not be transferred across international borders except with explicit prior approval from both the ISM and the General Counsel. The approval request must specify the nature of the Restricted information, the destination jurisdiction, the identity of the receiving party, the purpose of the transfer, the proposed transmission method and encryption, and the legal or contractual basis that justifies the transfer. Where a transfer involves Restricted information belonging to or relating to a client, the client's consent must also be obtained before the transfer proceeds. The ISM maintains a log of all approved cross-border Restricted information transfers for audit and ISMS purposes.

## 3. Access Control Policy

### 3.1 Access Control Principles

The access control policy of Arjun Technologies is built on three foundational principles that must be applied consistently and without exception to every access provisioning decision across the entire technology estate. These principles are the Principle of Least Privilege, the Principle of Need-to-Know, and the Principle of Segregation of Duties. Together they define the philosophical framework within which all access control decisions are made. An access provisioning decision that violates any of these principles requires a formal exception approved by the ISM — it cannot be justified by operational convenience, management instruction, or precedent from how access has previously been provisioned.

The Principle of Least Privilege requires that every user, system, application, and automated process is granted only the minimum level of access — in terms of both the systems it can reach and the operations it can perform within those systems — that is necessary for it to perform its authorised and current function. 'Current' is an important qualifier: access should not be provisioned in anticipation of future need or on the basis that additional access might be useful at some point. Access is granted for a specific, current, documented purpose. When that purpose ends — because a project completes, an employee changes roles, or a temporary access need expires — the access must be removed promptly. The most dangerous accounts in any organisation are often not those of current employees but those of former employees whose access was not promptly revoked, accounts provisioned for a project that continued to exist after the project ended, and service accounts that accumulated excessive permissions over time without review. The Principle of Least Privilege is the primary control against all of these risk patterns.

The Principle of Need-to-Know requires that access to information — not only to systems, but to specific data and content within those systems — is granted only where there is a clear, current, and documented business justification. Holding a legitimate role within the organisation does not automatically confer the right to access all information relevant to that role. A software engineer working on a specific client's platform needs access to the code repositories, documentation, and development environments relevant to that client's work — not to the code repositories of other clients. A finance analyst preparing management accounts for the company needs access to the financial data relevant to those accounts — not to employee payroll records or to client commercial terms. The Principle of Need-to-Know requires that access requests articulate the specific business justification, and that access granting managers and the IT Security team evaluate that justification before provisioning access rather than treating all requests from employees in the same general function as equally justified.

The Principle of Segregation of Duties requires that no single individual has unconstrained, end-to-end control over a critical process or system without an independent check or approval

step. This principle is most directly relevant to financial systems — where a single individual should not be able to both initiate and approve a payment, or to both create a vendor and approve payments to that vendor — but it applies to IT systems as well. No single administrator should have sole, unchecked access to production databases containing sensitive data. No single developer should have the ability to both write code and deploy it to production without a review and approval step. The Principle of Segregation of Duties prevents both intentional fraud and accidental damage by ensuring that no individual can act unilaterally in a way that causes significant harm without detection.

In addition to these three foundational principles, the access control policy is also guided by the following operational standards. Access must be based on an authenticated and authorised identity — shared accounts are prohibited except in the specific, tightly controlled circumstances described in Section 3.3 for emergency service accounts. Access credentials must be treated as personal to the individual to whom they are assigned — sharing credentials with colleagues, contractors, or any other party is prohibited regardless of the urgency of the business need being used to justify it. All access to Confidential and Restricted systems must be logged in a manner that allows every access event to be attributed to a specific individual identity and a specific time. Access logs must be protected against modification and must be retained for the periods specified in the Data Retention Schedule.

### 3.2 User Account Lifecycle Management

User accounts — the digital identities that allow individuals to authenticate to company systems and access company resources — must be managed rigorously throughout their lifecycle, from the moment of provisioning to the moment of final deactivation and deletion. Poorly managed account lifecycles are one of the most common root causes of security incidents in organisations of all sizes. Accounts provisioned with excessive permissions, accounts left active after the person who held them has left the organisation, and accounts whose passwords have not been changed for years are all routine findings in post-incident forensic investigations. The account lifecycle management requirements in this section are designed to prevent these well-understood failure patterns through systematic process rather than individual vigilance.

Account provisioning must be initiated by a formal access request submitted by the employee's line manager through the IT Service Desk ticket system. The request must specify: the identity of the individual for whom access is being requested; the systems, applications, and specific permission levels to which access is being requested; the business justification for each element of access requested; and the intended duration of the access, distinguishing between standing access (indefinite, subject to periodic review) and temporary access (with a specific expiry date). The IT Operations team will provision the access upon receipt of an approved request. Access provisioning without a formal approved request — for example, a line manager verbally directing an IT administrator to grant access — is not permitted, regardless of urgency. In genuine

emergencies where access is required immediately, the emergency access procedure described in Section 3.3 provides a controlled pathway.

Account modification must follow the same request and approval process as initial provisioning. When an employee changes roles — through a promotion, a lateral move, a project assignment, or a structural reorganisation — their access must be reviewed and updated to reflect their new responsibilities within five working days of the change taking effect. HR is responsible for notifying the IT Operations team of all role changes through the HRMS system. Line managers are responsible for reviewing the access of their team members whenever a role change occurs and for raising modification requests to add necessary new access and to remove access that is no longer justified. The IT Operations team is responsible for implementing approved modifications promptly and for flagging cases where the modification request appears inconsistent with the Principle of Least Privilege.

Account deactivation is one of the most critical elements of the account lifecycle and one of the most frequently mismanaged. HR must notify the IT Operations team within 24 hours of confirming an employee's last working date — regardless of the reason for separation. IT Operations must deactivate the departing employee's accounts no later than the end of business on the last working date. 'Deactivation' means disabling the account immediately, not deleting it — the account and its access logs must be retained for the period specified in the Data Retention Schedule to support any future investigations. Email access must be redirected to the former employee's manager for a period not exceeding 30 days to ensure business continuity for any outstanding client or operational communications. For employees on garden leave, access deactivation must occur at the start of the garden leave period, not at the end. The IT Security team audits the alignment between HR separation records and active account states on a monthly basis. Any account that remains active for more than five business days after the confirmed last working date of the account holder is treated as a critical finding.

| Account Lifecycle Event | Action Required | Responsible Party | Timeline | Verification |
|---|---|---|---|---|
| New employee joining | Create accounts for all required systems. Issue credentials securely. | IT Operations | Before start date | Signed confirmation of receipt |
| New contractor / vendor access | Create time-limited accounts. Set automatic expiry date. | IT Operations | Before engagement commences | Access log review at expiry. |
| Employee role change | Review and update access. Remove access no longer justified. | IT Operations | Within 5 working days of change | Manager confirmation in HRMS. |
| Employee on leave > 30 days | Suspend account access (not delete). Preserve data. | IT Operations on HR notification | Before leave commences | HR notification triggers action. |
| Employee resignation | Deactivate all accounts on last working day. | IT Operations on HR notification | End of business, last working day | HR leavers list — mon |
| Contractor engagement ends | Deactivate all accounts on final day of engagement. | IT Operations | End of business, final day | Manager sign-off. Contract database — m |
| Password compromise suspected | Force immediate password reset. Review access logs for unauthorised use. | IT Security | Within 1 hour of detection | Incident report. |
| Account dormant > 90 days | Flag for review. Deactivate if no business justification provided. | IT Operations | Monthly automated scan | Line manager review and decision within 5 day |

### 3.3 Privileged Access Management

Privileged accounts — accounts that have elevated permissions over and above those of standard users, typically including the ability to install software, modify system configurations, access security audit logs, manage other user accounts, or access production databases and sensitive data directly — present a disproportionately high security risk and must be managed with commensurately higher controls than standard user accounts. The compromise of a privileged account by an external attacker, or the misuse of a privileged account by an internal employee, can result in a security incident of a severity that no standard user account compromise could achieve. Privileged accounts are accordingly subject to additional controls beyond those that apply to all user accounts.

All privileged accounts must be registered in the company's Privileged Access Management system, which provides centralised management, monitoring, and auditing of privileged account usage. The PAM system requires users to check out privileged credentials for specific, time-limited sessions, automatically rotates passwords after each use, records and stores video of all privileged sessions for subsequent review, and alerts the ISM in real time when privileged accounts are used outside of pre-approved maintenance windows. The use of privileged access outside the PAM system — for example, using a privileged account's credentials directly rather than through the PAM check-out process — is prohibited and will be treated as a serious security policy violation.

The principle that privileged accounts must be distinct from everyday user accounts applies to all employees who hold privileged access, including senior IT administrators and members of the IT Security team. An IT administrator must have two separate accounts: a standard user account used for all everyday activities including email, web browsing, document management, and collaboration, and a separate privileged account used exclusively for administrative tasks. Logging into a workstation, accessing email, or browsing the internet using a privileged account is prohibited. This separation reduces the attack surface for privilege escalation attacks — an attacker who compromises the administrator's standard account through a phishing email does not automatically inherit privileged access to production systems.

Emergency service accounts — shared privileged accounts that exist for use in genuine operational emergencies where normal privileged access is unavailable — are the only permitted exception to the prohibition on shared accounts. Emergency accounts must be registered in the PAM system, their credentials must be stored in the company's approved password manager and changed after every use, every use must be documented with the name of the individual who used the account, the time, the reason, and the specific actions taken, and the account usage must be reviewed by the ISM within one business day of each use. The number of emergency service accounts should be minimised to the absolute operational minimum, and their existence must be reviewed annually to confirm that they are still operationally necessary.

### 3.4 Password and Authentication Standards

Passwords are the most widely deployed authentication factor in enterprise computing and, simultaneously, the most consistently exploited weakness in enterprise security. Attackers routinely gain access to company systems not by exploiting sophisticated technical vulnerabilities but by obtaining valid credentials through phishing, credential stuffing attacks that reuse credentials leaked in third-party data breaches, or social engineering. The password standards in this section are designed to make passwords significantly harder to obtain through these methods while remaining usable enough that employees can comply with them without resorting to the insecure workarounds — writing passwords on sticky notes, reusing passwords across systems, choosing simple and predictable passwords — that result from standards that are too onerous to follow.

The following password standards apply to all accounts on company systems — both individual user accounts and service accounts. Minimum password length is twelve characters. This requirement is based on the mathematical reality that a twelve-character password from a reasonable character set provides approximately 72 bits of entropy, which makes brute-force cracking computationally impractical with current technology. Passphrases — sequences of four or more unrelated words, such as 'correct horse battery staple' — are explicitly encouraged as an alternative to complex but shorter passwords, because research has consistently shown that passphrases of this type are both more secure and easier to remember than complex eight-character passwords. Passphrases must still meet the twelve-character minimum. All passwords must contain characters from at least three of the following four categories: uppercase letters, lowercase letters, numbers, and special characters.

| Password Requirement | Standard | Enforcement Mechanism | Notes |
|---|---|---|---|
| Minimum length | 12 characters | System-enforced at creation and change | Passphrases of 4+ random words are exp |
| Character complexity | Characters from ≥3 of 4 categories: uppercase, lowercase, numbers, special characters | System-enforced at creation and change | Applies to all standard user accounts |
| Password age — standard accounts | Maximum 90 days before mandatory change | System-enforced; user notified 14 days, 7 days, 1 day before expir | Applies to all standard user accounts |
| Password age — privileged accounts | Maximum 30 days; automatic rotation after each PAM session | PAM system automatic rotation | Privileged account passwords must never |
| Password history | Cannot reuse any of the last 12 passwords | System-enforced at change | Prevents cycling through a small set of kn |
| Prohibited content | No dictionary words, personal names, dates of birth, employee ID numbers, or company name | Password strength checker at creation and change | Applies to all account types |
| Storage | Company-approved password manager only | Policy control; periodic compliance audit | Approved managers: 1Password Enterpris |
| Sharing | Prohibited absolutely, including with IT staff and managers | Policy and disciplinary control | IT staff will never ask for a user's passwor |
| Default credentials | Must be changed on first login for all new accounts and devices | System-enforced at first login | Applies to all systems, not only IT infrastru |
| Service account passwords | Must meet all above standards. Rotation managed through PAM system | PAM system automated rotation | Service account passwords must not be e |

### 3.5 Multi-Factor Authentication Requirements

Multi-Factor Authentication requires a user to provide two or more of the following authentication factors in order to access a system: something they know (a password or PIN), something they have (a hardware security key, an authenticator app on a trusted device, or an SMS code sent

to a registered phone number), and something they are (a biometric factor such as a fingerprint or facial recognition). The combination of factors makes it dramatically harder for an attacker to gain access even if they have obtained the user's password — which, given the frequency and scale of third-party data breaches that expose credential databases, must be assumed to be a realistic possibility for any employee's account. MFA is one of the single most effective security controls available, and the company has mandated it broadly and is progressively extending its coverage.

SMS-based one-time passwords are the least secure form of MFA and are specifically deprecated for high-value accounts because of the well-documented SIM-swapping attack technique, through which an attacker can redirect SMS messages to a phone number they control by fraudulently transferring the victim's phone number to a SIM card in their possession. For privileged accounts, production system access, and all access to Restricted data systems, SMS OTP is explicitly prohibited as an MFA factor — only hardware security keys (FIDO2 U2F) or TOTP-based authenticator applications are acceptable. For standard user accounts, SMS OTP is permitted as a fallback only where an authenticator app is not available due to a device issue, and the fallback use must be reported to the IT Service Desk to ensure the authenticator app is reinstated.

| Access Context | MFA Required? | Acceptable MFA Factors | Prohibited Factors | Notes |
|---|---|---|---|---|
| VPN (remote access to corporate network) | Mandatory | TOTP authenticator app; FIDO2 hardware key | SMS OTP | VPN access without MFA is technically blo |
| Corporate email and O365 / Google Workspace | Mandatory | TOTP authenticator app; FIDO2 hardware key; push notification | SMS OTP for new enrolments | MFA enforced by conditional access policy |
| Cloud service consoles (AWS, Azure, GCP) | Mandatory | TOTP authenticator app; FIDO2 hardware key | SMS OTP; email OTP | Root and super-admin accounts: hardware |
| Privileged accounts in PAM system | Mandatory — stronger | FIDO2 hardware key; TOTP authenticator app | SMS OTP; email OTP; push notification | PAM checks for registered MFA device at c |
| Source code repositories (GitHub Enterprise) | Mandatory | TOTP authenticator app; FIDO2 hardware key | SMS OTP | Required for all write access to any reposit |
| HRMS and HR data systems | Mandatory | TOTP authenticator app; FIDO2 hardware key; push notification | SMS OTP; email OTP | MFA enforced by conditional access policy enforced centrall |
| Internal intranet (on-network access) | Strongly recommended | Authenticator app; push notification | None if single-factor in use | Phased MFA rollout to complete by Q3 202 |
| Non-sensitive internal tools (on-network) | Recommended, not yet mandatory | Any supported factor | None | Include in MFA rollout programme. |
| BYOD device accessing company email via MDM | Mandatory | Device PIN/biometric + app-level authenticator | Email access without MDM enrolment | MDM enrolment is a prerequisite for BYOD |

### 3.6 Remote Access and VPN Policy

Remote access to all company systems, applications, and data must be established exclusively through the company's approved Virtual Private Network solution. The VPN creates an encrypted tunnel between the employee's device and the company's network infrastructure, ensuring that all data transmitted between the device and company systems is protected against interception, modification, or eavesdropping even when the device is connected to an untrusted network such as home broadband, hotel Wi-Fi, or public internet access. Any access to company systems that bypasses the VPN — for example, accessing company web applications directly through a browser without first establishing a VPN connection — is prohibited, because it exposes company data to the security risks of the intermediate network through which the

connection travels.

The company operates a full-tunnel VPN configuration, meaning that when the VPN is active, all network traffic from the employee's device — not only traffic to company systems, but also general internet browsing, streaming, and any other network activity — is routed through the company's network and subject to the company's security monitoring and filtering. Split-tunnel VPN configurations, which route only company-bound traffic through the VPN while allowing other internet traffic to bypass it, are explicitly prohibited. While split tunnelling reduces VPN server load and improves some aspects of performance, it creates a security risk because internet traffic that bypasses the VPN can carry malware or data exfiltration activity that is invisible to the company's security monitoring infrastructure.

The VPN client application is managed and deployed by the IT Operations team and must not be disabled, modified, uninstalled, or replaced by any alternative software without IT approval. The VPN client incorporates endpoint compliance checking — before establishing a VPN connection, it verifies that the connecting device has an up-to-date operating system, active endpoint protection software, and full-disk encryption enabled. Devices that do not meet these compliance criteria are denied VPN access and directed to remediate the compliance issue before reconnecting. This compliance gating ensures that the VPN does not become a pathway through which a compromised or non-compliant device introduces threats into the company network.

Employees travelling to countries with known internet censorship, surveillance, or man-in-the-middle capabilities must contact the IT Security team before travelling to receive a security briefing specific to their destination. Several countries actively intercept and decrypt TLS-encrypted internet traffic at the national level, and in some jurisdictions the use of VPN software may itself be legally restricted. The IT Security team maintains a travel security advisory for countries of particular concern and will provide specific guidance on connection strategies, the handling of sensitive data, and the use of travel loaner devices for high-risk destinations. Employees must not assume that their normal remote working practices are safe in all international travel contexts.

### 3.7 Physical Access Controls

Physical access to company premises is an information security control, not merely a facilities management function. An attacker who gains physical access to company office space can interact directly with unattended workstations, remove hardware from the premises, install hardware keyloggers or rogue network devices, retrieve improperly disposed of documents from waste bins, and overhear sensitive conversations. Physical access controls are therefore an integral part of the ISMS, subject to the same rigour of design, implementation, monitoring, and audit as technical controls.

All Arjun Technologies office premises operate a card-based physical access control system. Each employee and authorised contractor is issued a personalised access card that provides entry to the areas of the building for which they are authorised. Access rights on each card are provisioned through the physical access control system by the Administration team based on a formal access request approved by the employee's line manager and processed through HR. Access rights are limited to the areas of the building in which the employee has a legitimate and current business need to be present — the Principle of Least Privilege applies to physical access in exactly the same way as it applies to logical access to IT systems.

All visitors to company premises — including clients, candidates, vendors, contractors, and the personal guests of employees — must be registered in the visitor management system at reception, must produce a government-issued photo ID for verification, must receive a visitor badge that is visually distinct from employee badges and that must be worn visibly at all times while on premises, and must be accompanied by an authorised employee at all times in secure areas. Visitors must not be left unattended in office areas where they have visual or physical access to workstations, printed documents, server rooms, or network infrastructure. The employee who registered the visitor is personally responsible for the visitor's conduct and for ensuring that the visitor adheres to all physical security requirements during their visit. Visitor badges must be returned at reception at the end of each visit.

| Physical Zone | Access Level | Who Is Authorised | Controls Applied | Visitor Access |
|---|---|---|---|---|
| Reception and public waiting areas | Open | All employees; all visitors | Reception desk check-in; visitor badge issuance | Permitted with employee escort. |
| General office floors | Standard | All employees of the relevant office, authorised contractors | Access card required; CCTV monitored | Permitted with continuous employee escort |
| IT infrastructure room (server room, network cabinets) | Restricted | IT Operations team members only | Separate access card authorisation; CCTV; entry logged | Prohibited except for authorised IT work |
| Finance and HR department storage | Restricted | Finance team; HR team; management as assigned | Separate access card authorisation; CCTV; entry logged. | Not permitted. |
| Executive and Board meeting rooms | Standard during business hours; Restricted outside hours | All employees during business hours; Board and invited guests | Standard access card; Board and invited guests provided temporary visitor badges at reception | Permitted during business hours when hosted by an employee |
| Roof, plant rooms, utility areas | Restricted | Facilities management only | Separate access card; CCTV | Not permitted. |

### 3.8 Access Review and Recertification

Access rights do not remain valid indefinitely. The business context in which access was originally granted — the employee's role, the project they are working on, the systems they need for their current responsibilities — changes continuously, and access rights that were appropriate at the time of provisioning can become excessive or entirely unjustified over time without any deliberate decision having been made. The access review and recertification process is the systematic mechanism through which the company periodically verifies that all current access rights across all systems remain justified, and revokes any that do not.

The access review is conducted on the following schedule: standard user access to all production systems is reviewed quarterly, with each employee's line manager certifying that each system access is still required for the employee's current role; privileged access to all

systems is reviewed monthly by the IT Security team and the ISM, with any privileged account whose usage cannot be justified by a documented current business requirement being deactivated immediately; access to Restricted data systems is reviewed on a continuous basis through the PAM session management system and reviewed formally monthly by the ISM; service account access is reviewed quarterly by the IT Operations team with ISM sign-off; and external and contractor access is reviewed at each renewal of the relevant engagement.

The recertification process requires access owners — the line managers responsible for certifying their team members' access — to review a report generated from the access management system showing every system access held by each of their direct reports, and to confirm in writing for each access item whether it is still required ('recertify'), no longer required ('revoke'), or requires modification to a different permission level. The recertification report must be completed within ten working days of being issued. Access for which no recertification decision is recorded within ten working days is automatically suspended pending the access owner's decision. Recertification completion rates are reported as a KPI to the IT Security Steering Committee.

The access review process regularly identifies several categories of access anomaly that require remediation. Orphaned access — access that was provisioned for a specific project or purpose that has since concluded, but that was never revoked when the project ended — is the most common finding. Excessive access — access at a higher permission level than the employee's current role requires — is the second most common. Dormant access — access to systems that an employee has not used for more than 90 days — is automatically flagged by the monitoring system for review, since dormant accounts represent a risk of undetected compromise. Segregation of duties violations — access configurations in which a single employee has the ability to perform two steps in a critical process that should be performed by separate individuals — are identified through automated SOD conflict detection and reviewed by the ISM and CFO.

## 4. Network and Infrastructure Security

### 4.1 Network Architecture and Segmentation Principles

The network architecture of Arjun Technologies is designed according to the principle of defence in depth — the deployment of multiple independent layers of security controls such that the failure or bypass of any single layer does not result in unrestricted access to the company's most sensitive systems and data. Network segmentation is the primary architectural mechanism through which this principle is implemented. By dividing the company's total network environment into logically isolated zones, each with its own access controls and traffic filtering rules, the company ensures that an attacker who breaches the perimeter of one zone cannot automatically move laterally to reach other zones without encountering and bypassing additional independent controls.

The company's network is divided into six defined security zones, each representing a different trust level and requiring different access and traffic control standards. The Corporate Zone is the standard office network used by employee workstations for everyday business activities — email, collaboration tools, internet access, and connection to internal business applications. The Server Zone is a more strictly controlled internal network hosting the company's application servers, internal databases, and infrastructure services. The Demilitarised Zone (DMZ) hosts systems that require access from the public internet — web gateways, API endpoints, load balancers, and email filtering infrastructure — and is positioned between the public internet and the internal network with firewall controls on both boundaries. The Management Zone is a tightly restricted network used exclusively for managing infrastructure components — firewall management interfaces, server management ports, SIEM infrastructure, and network monitoring tools. The Guest Zone provides internet access for visitors and personal devices that must not be permitted onto the corporate network. The Cloud Zone encompasses all cloud-hosted workloads, connected to on-premises infrastructure through dedicated, encrypted, and monitored connections.

Traffic between zones is controlled by firewall rules that implement a default-deny posture — all inter-zone traffic is blocked unless explicitly permitted by a specific, documented firewall rule. This is the inverse of the default-allow posture that was common in earlier network architectures, and it represents a fundamental improvement in security because it means that access paths between zones are deliberate and documented rather than accidental and invisible. Every firewall rule that permits inter-zone traffic must have a documented business justification, must be approved by the ISM, must specify the source and destination addresses or ranges as precisely as possible rather than using broad wildcards, must specify the specific ports and protocols permitted, and must be reviewed as part of the bi-annual firewall rule review process. Rules for which a documented current business justification cannot be provided at the time of review are removed immediately.

Network segmentation controls are implemented using a combination of physical firewall appliances, network access control lists on managed switches and routers, and software-defined networking controls in virtualised environments and cloud workloads. The specific technology mix varies by location and environment, but the logical segmentation architecture is consistent across all locations. The IT Operations team maintains network diagrams for each office location and for the cloud environment that accurately reflect the current segmentation architecture, are updated whenever a material change is made to the network, and are reviewed for accuracy by the ISM at each quarterly Steering Committee meeting. These network diagrams are classified as Restricted — they must not be shared outside the IT Operations and IT Security teams without ISM approval.

The Zero Trust architectural principle is being progressively incorporated into the company's network architecture. Zero Trust rejects the traditional implicit trust that is extended to all traffic on the internal corporate network — the assumption that anything inside the perimeter is safe — and instead requires that every access request, regardless of its origin, must be authenticated, authorised, and continuously validated before it is permitted. In practice, Zero Trust adoption at Arjun Technologies means that access to all sensitive applications is mediated through an identity-aware access proxy that enforces MFA and device compliance checking before granting access, rather than relying solely on the user being on the corporate VPN. The Zero Trust programme is phased over a three-year roadmap, with the highest-risk applications being moved to Zero Trust access control first.

| Network Zone | Contents | Trust Level | Key Controls | Visitor / Guest Access |
|---|---|---|---|---|
| Corporate Zone | Employee workstations, IP phones, printers, and corporate wireless devices | Medium — authenticated users and managed devices only | 802.1X port authentication required; NAC enforces device compliance; EDR on all endpoints | No access; NAC denies unknown devices |
| Server Zone | Internal application servers, file servers, database servers, and directory services | High — restricted access; only authorised systems and users permitted | Default deny inbound; only specific source IPs and ports permitted; privileged access via PAM only | No access |
| Demilitarised Zone (DMZ) | Web application firewalls, API gateways, reverse proxies, and internet-facing load balancers | Low — internet-facing; all traffic inspected and filtered | WAF with OWASP rule set; DDoS protection; no direct connection to internal zones; all traffic terminated and re-initiated | No access |
| Management Zone | Firewall management interfaces, SIEM infrastructure, and network management tools | Critical — restricted to named IT Security and IT Operations personnel only | Dedicated out-of-band management network; MFA required; all access logged and reviewed weekly | No access |
| Guest Zone | Visitor Wi-Fi, personal devices | Untrusted — internet only | No connectivity to any corporate zone; captive portal with terms of use acceptance | Permitted |
| Cloud Zone | AWS production workloads, Azure DevOps environments, SaaS integrations | Variable — segmented by workload sensitivity | Security groups and NACLs; no direct internet exposure for data-tier workloads; all cloud access via SSO with MFA | Monitored; least privilege |

### 4.2 Firewall Management and Change Control

Firewalls are the primary technical enforcement mechanism for the network segmentation architecture described in Section 4.1, and their configuration must be managed with the same rigour and change management discipline applied to any other critical infrastructure component. A misconfigured firewall — one with overly permissive rules, redundant rules that create unintended access paths, or rules whose rationale is unknown and that therefore cannot be safely reviewed or removed — is as dangerous as no firewall at all. The company's firewall management standards are designed to ensure that the firewall rule sets accurately implement the intended network segmentation architecture, that every rule has a clear and current business justification, and that the rule sets are maintained in a clean and auditable state over

time.

All changes to firewall rules — including the addition of new rules, modification of existing rules, and deletion of rules — must be initiated through a formal change request submitted to IT Operations via the IT Service Desk. The request must specify the business justification for the change, the source and destination addresses, the protocols and ports involved, the duration of the rule if it is not intended to be permanent, and the name of the line manager who has approved the request. IT Operations implements the change only after the request has been reviewed by the ISM and approved by the IT Security team. Emergency changes — where a business critical service is unavailable and a firewall change is required immediately outside normal business hours — may be implemented verbally by the on-call IT Operations engineer with the on-call ISM's verbal approval, but must be followed by a written request and formal review within 24 hours of the emergency change being made. Emergency changes that are not followed up with a formal review within 24 hours are escalated to the CTO.

Firewall rule sets must be reviewed in their entirety at least twice per year — typically in April and October — by the IT Security team in collaboration with the IT Operations team. The review must evaluate every rule in the current active rule set against the documented business justification on file, identify rules for which no current business justification can be confirmed, identify overly broad rules that could be tightened without operational impact, identify duplicate rules that should be consolidated, and identify rules that conflict with the intended segmentation architecture. Rules for which a current business justification cannot be confirmed within five working days of being flagged are removed, with a seven-day reinstatement window during which the rule owner can provide justification. The findings of each firewall review and the list of rules removed or modified as a result must be documented and submitted to the IT Security Steering Committee at the next quarterly meeting.

The company uses a next-generation firewall platform that provides application-layer inspection, user identity-based policy enforcement, and integrated intrusion prevention capabilities beyond the traditional port and protocol filtering of earlier firewall generations. Application-layer inspection allows the firewall to identify and control specific applications and protocols regardless of the port they use — preventing, for example, encrypted tunnelling applications from circumventing port-based controls by operating over permitted ports. User identity integration allows firewall policies to be applied based on the authenticated identity of the user making the connection, enabling more granular and accurate access control than IP-address-based rules alone. Intrusion prevention capabilities allow the firewall to detect and block known attack patterns in real time based on continuously updated threat intelligence feeds.

### 4.3 Wireless Network Security

Wireless networks present specific security challenges because radio frequency signals propagate beyond physical boundaries — unlike wired network connections, which are physically constrained to the cable into which they are plugged, a wireless access point's signal can be received by anyone within its broadcast range, including individuals outside the building in public areas or in adjacent premises. The company's wireless network security standards are designed to address these challenges by ensuring that wireless networks are appropriately authenticated, encrypted, and monitored, and that rogue wireless access points are detected and eliminated promptly.

The corporate wireless network uses WPA3-Enterprise authentication, which requires each connecting device to authenticate against the company's RADIUS authentication server using the user's Active Directory credentials. This means that connecting to the corporate Wi-Fi requires the same credentials as any other company system, and access can be revoked by disabling the user's Active Directory account. WPA3-Enterprise additionally provides per-session encryption keys, eliminating the vulnerability present in WPA2 and earlier protocols where a user who knows the pre-shared key can decrypt other users' traffic on the same network. All wireless traffic on the corporate network is additionally encrypted through the VPN, providing a second layer of encryption even on the corporate wireless network.

A dedicated guest wireless network with a separate SSID is available at each office location for visitor use. The guest network is logically isolated in the Guest Zone described in Section 4.1 and provides internet access only — it has no connectivity to the Corporate Zone, Server Zone, or any other internal company network. The guest network requires acceptance of terms of use through a captive portal before internet access is granted. Guest network usage is monitored by the IT Security team for anomalous patterns. The password for the guest network is rotated monthly and shared only with visitors currently present in the building through the reception desk.

Rogue wireless access point detection is implemented through the company's wireless infrastructure management system, which continuously scans the radio frequency environment in each office for wireless access points that are not registered as company-managed infrastructure. Any unregistered access point detected within the company's physical premises or in the immediate RF environment is immediately flagged as a potential rogue AP. IT Security investigates all rogue AP detections within one hour of the alert and, where the detection cannot be attributed to a legitimately registered device through investigation, escalates to a physical search of the affected area. The introduction of any personal wireless access point, wireless repeater, or similar device into company premises without prior IT approval is prohibited — any employee found to have introduced an unapproved wireless access point into company premises will be subject to disciplinary action.

### 4.4 Network Monitoring and Intrusion Detection

Perimeter controls — firewalls, access control lists, and authentication requirements — are necessary but not sufficient for network security. Sophisticated attackers who gain initial access to a network frequently spend significant time moving laterally through the environment before carrying out their primary objective, exploiting legitimate but excessive access rights, unpatched vulnerabilities in internal systems, and monitoring blind spots to expand their foothold without triggering obvious alarms. Network monitoring and intrusion detection capabilities are therefore essential complements to perimeter controls, providing the visibility needed to detect attacker activity that has bypassed or evaded the perimeter and to contain it before it escalates to a major incident.

The company's Security Information and Event Management platform is the central hub of the network monitoring capability. The SIEM aggregates security event data from across the technology estate — firewall logs, authentication logs from Active Directory and cloud identity providers, endpoint detection and response alerts, DNS query logs, proxy logs, cloud platform audit logs, and application security logs — and correlates this data in real time to identify patterns that may indicate malicious activity. The SIEM uses a combination of rule-based detection, which triggers alerts when specific known-bad patterns are observed, and behavioural analytics, which establishes baselines of normal activity for each user and system and alerts when significant deviations from baseline are detected.

The SIEM is operated in a Managed Detection and Response model, where a specialist third-party security operations centre provides 24/7 monitoring and initial triage of SIEM alerts on behalf of Arjun Technologies's IT Security team. The MDR provider is responsible for reviewing all security alerts generated by the SIEM, classifying each alert by severity and confidence, dismissing false positives with documentation, and escalating genuine or probable incidents to the IT Security team with an initial assessment and recommended response actions. The IT Security team receives all Priority 1 and Priority 2 escalations immediately regardless of time of day, and is responsible for executing the incident response procedure described in Segment 2 of this policy. The MDR provider's service is governed by a detailed service level agreement that specifies mean time to triage, mean time to escalation, and reporting requirements.

Network traffic analysis is conducted on the company's internal network segments using a combination of flow data collection from network infrastructure and full packet capture at key chokepoints. Flow data provides a high-level view of all network conversations — source, destination, protocol, port, volume, and timing — enabling the detection of anomalous communication patterns such as unusual data volumes, connections to unexpected external destinations, lateral movement patterns between internal systems, and communications with known malicious IP addresses or domains identified through threat intelligence feeds. Full packet capture at selected chokepoints provides deeper inspection capability for investigations of specific suspected incidents. Packet capture data is retained for 14 days to support incident

investigations and is classified as Restricted given the sensitivity of the information it may contain.

### 4.5 DNS Security and Web Proxy Controls

The Domain Name System — the internet's addressing infrastructure that translates human-readable domain names into the IP addresses computers use to communicate — is both a critical dependency of all internet connectivity and a commonly exploited attack vector. Attackers use malicious domain names to host phishing websites, to command and control malware installed on victim systems, and to exfiltrate stolen data in DNS query payloads in a technique known as DNS tunnelling. The company's DNS security controls are designed to prevent employee devices from resolving malicious domain names, to prevent malware on compromised devices from communicating with attacker-controlled infrastructure via DNS, and to detect DNS-based data exfiltration attempts.

All DNS queries from company devices — both on-premises and when connected via VPN — are routed through the company's DNS security platform rather than directly to public resolvers. The DNS security platform incorporates threat intelligence feeds from multiple sources that are updated in real time, blocking the resolution of domain names associated with malware, phishing campaigns, botnets, and other malicious infrastructure. The platform applies both block lists of known-malicious domains and behavioural analysis of domain characteristics — newly registered domains, algorithmically generated domains associated with domain generation algorithms used by malware, and domains with characteristics that deviate from legitimate domain patterns. All DNS queries are logged and retained for 90 days for security investigation purposes.

All HTTP and HTTPS web traffic from company devices is routed through the company's web proxy server, which performs URL filtering, SSL inspection, and content analysis before permitting or blocking web requests. URL filtering blocks access to categories of website that are prohibited under the Acceptable Use Policy — including malware distribution sites, phishing sites, sites hosting illegal content, and sites providing proxies or anonymisation services that could be used to bypass security controls. SSL inspection — the decryption and re-encryption of HTTPS traffic by the proxy for the purpose of inspection — enables the proxy to detect and block malicious content that would otherwise be hidden within encrypted connections. Employees are informed of SSL inspection through this policy and the Acceptable Use Policy. SSL inspection is not applied to certain categories of website — including banking and financial services, healthcare providers, and legal services — where the content of the HTTPS connection may be especially sensitive and where the purpose of inspection is unlikely to produce security benefit proportionate to the privacy consideration.

### 4.6 Email Security Controls

Email is simultaneously one of the most critical business communication tools and one of the most heavily exploited attack vectors. The overwhelming majority of successful cyberattacks on organisations begin with a phishing email — a message designed to deceive the recipient into clicking a malicious link, opening a malicious attachment, or divulging sensitive information. Email security controls at Arjun Technologies operate at multiple layers to reduce the probability that malicious emails reach employee inboxes and to limit the damage that can be caused by those that do.

Inbound email is subject to a multi-layer filtering architecture. At the network level, the company uses an email security gateway that filters all inbound email before it reaches the mail server. The gateway applies reputation filtering — blocking email from IP addresses and domains with poor sending reputation based on threat intelligence — spam filtering, virus and malware scanning of attachments, sandboxing of suspicious attachments in an isolated analysis environment to detect behaviour-based indicators of malicious content, URL rewriting to replace embedded links with safe equivalents that route through the URL filtering system before redirecting to the original destination, and impersonation protection to detect emails that spoof the identities of company executives, IT staff, or trusted external senders.

Outbound email is subject to controls designed to prevent the inadvertent or deliberate exfiltration of sensitive data via email. Data Loss Prevention rules applied at the email gateway scan outbound emails and attachments for patterns consistent with sensitive data categories — credit card numbers, national ID numbers, personal data in bulk, source code signatures, and other indicators specified in the DLP rule set. Emails triggering DLP rules are either blocked automatically or quarantined for review by the sender's manager and the ISM, depending on the severity of the match. DLP rules are updated regularly to reflect changes in the sensitive data categories most relevant to the company's current business and to address patterns identified in security incident investigations.

The company has implemented the DMARC, DKIM, and SPF email authentication protocols on all company domains to prevent external senders from spoofing the company's domain in fraudulent emails sent to clients, partners, and external recipients. SPF specifies which IP addresses are authorised to send email on behalf of the company's domains. DKIM provides a cryptographic signature on outbound emails that allows recipients to verify that the email was genuinely sent from an authorised company system and has not been modified in transit. DMARC specifies how receiving mail servers should handle emails that fail SPF or DKIM checks, and provides the company with reporting data on any sources that are attempting to send emails purporting to be from the company's domains. These three protocols together make it significantly harder for attackers to conduct phishing and business email compromise attacks that impersonate the company's email identity.

## 5. Endpoint Security

### 5.1 Endpoint Security Architecture

Endpoints — the laptops, workstations, mobile phones, tablets, and other devices through which employees interact with company systems and data — are both the primary interface through which work is done and the primary entry point through which modern cyber threats gain access to organisations. Approximately 70 percent of security incidents begin with a compromised endpoint, whether through malware delivered via phishing, drive-by exploitation of a vulnerable browser or application, or physical access to an unlocked device. The company's endpoint security architecture applies multiple independent layers of protection to reduce the probability of a successful endpoint compromise and to limit the damage caused by any compromise that does occur.

Every company-managed endpoint is enrolled in the company's Mobile Device Management and Endpoint Management platform, which provides centralised visibility, control, configuration management, and security enforcement across all devices in the fleet. The MDM platform enforces baseline security configuration policies on all enrolled devices — including mandatory disk encryption, screen lock requirements, application whitelisting, and OS patch level compliance — and reports the compliance status of each device in real time to the IT Security team. Devices that are not enrolled in the MDM platform cannot connect to company Wi-Fi, cannot connect to company email on mobile devices, and are flagged for remediation when detected on company network segments. The MDM platform is the authoritative inventory of all company-managed endpoints.

Endpoint Detection and Response software is deployed on all company-managed laptops, workstations, and servers. EDR provides continuous monitoring of endpoint activity — process execution, file system changes, network connections, registry modifications, and memory operations — and uses a combination of signature-based detection of known malware and behavioural analysis of suspicious activity patterns to identify potential threats. Unlike traditional antivirus software, which primarily detects known malware by its signature, EDR is designed to detect novel threats and living-off-the-land attack techniques that use legitimate system tools in malicious ways. When the EDR detects a threat, it can automatically isolate the affected endpoint from the network to prevent lateral movement while the IT Security team investigates, preserving forensic evidence and containing the potential impact of the incident.

Application control policies restrict which software can execute on company endpoints. The company maintains an approved software list — a catalogue of all applications authorised for use on company devices — and the endpoint management platform enforces this list by blocking the execution of software not on the approved list. This control is one of the most effective defences against malware, because most malware consists of executable files that must run on the endpoint to cause harm. Application control does not block all malware —

malware that operates entirely within the memory of legitimate approved applications ('fileless malware') requires EDR behavioural detection rather than application control — but it eliminates the large category of threats that rely on executing unauthorised executable files.

### 5.2 Patch Management and Vulnerability Remediation

Unpatched software vulnerabilities are the second most common root cause of successful cyberattacks, after compromised credentials. When a software vendor releases a security patch for a vulnerability, that patch simultaneously publicises the existence of the vulnerability to the entire world, including to threat actors who scan for organisations running the vulnerable version and exploit it before it is patched. The window between a patch's public release and its deployment across an organisation's systems is a period of elevated risk — the organisation is aware of the vulnerability, but its systems are still exposed. Minimising this window through rapid, systematic patch deployment is therefore one of the highest-return security investments available.

The company's patch management programme operates on a risk-based schedule defined by the CVSS severity score of each vulnerability. Critical vulnerabilities — those with a CVSS score of 9.0 or above — must be patched within 72 hours of the patch's public release. This 72-hour requirement may require the use of the emergency change process for production systems. High-severity vulnerabilities — CVSS scores of 7.0 to 8.9 — must be patched within seven calendar days. Medium-severity vulnerabilities — CVSS 4.0 to 6.9 — are included in the monthly scheduled maintenance cycle and must be patched within 30 calendar days. Low-severity vulnerabilities are addressed in the quarterly maintenance cycle within 90 days.

| Severity | CVSS Score Range | Patch Deadline | Change Process | Escalation if Overdue |
|---|---|---|---|---|
| Critical | 9.0 – 10.0 | 72 hours from patch release | Emergency change process if required; ISM approval | CTO and ISM informed at 48 hours; BU head no |
| High | 7.0 – 8.9 | 7 calendar days | Standard change process; IT Ops approval | ISM informed at 5 days; escalation to CTO at 10 |
| Medium | 4.0 – 6.9 | 30 calendar days | Monthly scheduled maintenance cycle | ISM informed at 25 days; escalation to IT Ops m |
| Low | 0.1 – 3.9 | 90 calendar days | Quarterly scheduled maintenance cycle | ISM informed at 80 days; no formal escalation u |
| Informational | 0.0 | No mandatory patch timeline | At next scheduled maintenance window | Reviewed only — document and reassess at next |

Patch compliance rates are monitored continuously by the MDM and endpoint management platforms and reported as a key security metric in the weekly ISM dashboard. The target patch compliance rate for Critical and High vulnerabilities is 100 percent by the respective deadline. The target for Medium vulnerabilities is 95 percent within 30 days. Endpoints that have not received required patches by the deadline — typically because the device has been offline or the patch has encountered a compatibility error — are flagged for immediate manual remediation by IT Operations. Employees must not delay or indefinitely defer system update prompts. Where a patch causes an application compatibility issue, the affected application owner must raise a formal exception request with the ISM within 24 hours of identifying the

conflict, and the exception request must include a compensating control and a remediation timeline.

The patching programme covers all software layers on company endpoints and infrastructure: operating systems including Windows, macOS, and Linux distributions; productivity applications including the Microsoft 365 suite, browsers, PDF readers, and collaboration tools; security tools including the EDR agent, the VPN client, and the MDM agent; infrastructure components including web servers, application servers, database engines, network operating systems, and firmware on managed network devices; and cloud-hosted applications to the extent that the company has responsibility for patch management in the applicable shared responsibility model. Third-party applications that are no longer supported by their vendors and for which security patches are no longer released — 'end of life' software — represent an unacceptable and unmanageable risk and must be replaced or decommissioned on a timeline approved by the ISM.

### 5.3 Full-Disk Encryption Requirements

Full-disk encryption is a mandatory control on all company-managed laptops, workstations, and portable storage devices. Encryption renders the data stored on a device unreadable to any party that does not possess the correct decryption key, which is derived from the user's authentication credentials and, on supported hardware, from a hardware security chip such as a Trusted Platform Module. This means that if a device is lost, stolen, or physically accessed by an unauthorised party, the data it contains is protected even if the attacker physically removes the storage drive from the device and connects it to another system — without the correct key, the data appears as meaningless random bytes.

BitLocker with TPM 2.0 integration is the mandated encryption solution for all Windows laptops and workstations. BitLocker recovery keys are automatically escrowed to the company's Azure Active Directory tenant and additionally backed up to the IT Security vault maintained by IT Operations. Employees must not disable BitLocker, must not modify the BitLocker configuration, and must not attempt to access a BitLocker-encrypted drive without the proper authentication mechanism. FileVault 2 is the mandated encryption solution for all Apple macOS laptops. FileVault recovery keys are escrowed to the company's MDM platform and backed up to the IT Security vault. Linux systems hosting sensitive data must use LUKS full-disk encryption, and encryption status is verified during the server build process and included in the monthly vulnerability scan.

All portable storage media used to store company data classified at the Confidential or Restricted level must be encrypted. Unencrypted USB drives and external hard disks are prohibited for use with company data above the Internal Use Only level. The approved solutions for portable storage encryption are VeraCrypt for files and folders on portable media, BitLocker

To Go for USB drives on Windows systems, and the company's approved encrypted USB drive standard for pre-encrypted drives issued by IT Operations. Employees who need to transfer Confidential or Restricted data between systems should use the company's approved secure file transfer solution rather than portable media wherever possible — portable media presents a physical loss risk even when encrypted.

### 5.4 Mobile Device Policy

Company-issued mobile phones are provided to employees in roles where mobile communication is a defined business requirement. Company mobile devices are enrolled in the MDM platform from the point of provisioning, and the MDM profile enforces mandatory screen lock with PIN or biometric, mandatory full-device encryption, VPN configuration, approved application catalogue, and remote wipe capability. Employees must not circumvent MDM management on company mobile devices — jailbreaking or rooting a company mobile device is prohibited and will result in immediate remote wipe and disciplinary action.

Personal mobile devices — phones, tablets, and other personal devices — may access company email, calendar, and the HRMS mobile application under the Bring Your Own Device programme, subject to the device meeting the minimum security requirements enforced by the MDM conditional access policy. These requirements include: operating system version within two major releases of the current version; device encryption enabled; screen lock with PIN or biometric active; the company's MDM profile installed; and no active jailbreak or root. The MDM profile on personal devices manages only the company-managed applications and data — it cannot access personal photos, messages, applications, or other personal content, and can only remotely wipe the company-managed data rather than the entire device. Employees who withdraw from the BYOD programme can remove the MDM profile at any time, which simultaneously removes all company data from their personal device.

Employees who lose or have stolen a company mobile device or a personal device enrolled in the BYOD programme must report the loss to IT Security immediately — at any time of day or night — so that a remote wipe of company data can be initiated before the device is accessed by an unauthorised party. The remote wipe capability is effective even if the device has been powered off, because the wipe command is held in queue and executes the next time the device establishes a network connection. For company devices, the remote wipe wipes the entire device. For personal BYOD devices, the remote wipe removes only the company-managed data and applications, leaving the employee's personal content intact.

## 6. Security Incident Response

### 6.1 Incident Response Programme Overview

A security incident is any event, or combination of events, that threatens or has successfully compromised the confidentiality, integrity, or availability of Arjun Technologies's information assets. Security incidents range in severity from the trivial — a single spam email that is immediately deleted — to the catastrophic — a ransomware infection that encrypts production data and renders client-facing systems unavailable. The company's incident response programme is designed to ensure that all potential incidents are detected and reported promptly, that each incident is classified by severity so that the appropriate response resources are engaged, that effective containment, investigation, and recovery actions are taken in a structured and coordinated way, and that each incident produces learning that is fed back into the security programme to prevent recurrence.

The incident response programme is built on a six-phase process: Preparation, Detection, Triage, Containment, Investigation and Eradication, and Recovery and Post-Incident Review. The Preparation phase is ongoing and includes maintaining and testing the incident response plan, ensuring that all responders know their roles, maintaining up-to-date asset inventories and network diagrams, establishing relationships with external resources including forensic investigation firms and legal counsel, and conducting tabletop exercises and simulated incident drills. The Detection phase encompasses all the monitoring activities — SIEM alerts, MDR provider escalations, employee reports, vulnerability scanner findings, and threat intelligence — through which incidents are first identified. The Triage phase involves the initial classification of each detected event by severity and confidence, the dismissal of false positives, and the initiation of the appropriate response path.

The Containment phase focuses on limiting the spread and impact of a confirmed incident before the full investigation is complete. Containment actions are deliberately rapid and pragmatic — they may involve isolating affected systems from the network, blocking suspected attacker IP addresses or domains at the firewall, forcing password resets for potentially compromised accounts, or temporarily taking down affected services to prevent further damage. Containment actions do not wait for the investigation to be complete because the cost of allowing an incident to spread while the investigation proceeds is typically far higher than the cost of any temporary service disruption caused by containment. The Investigation and Eradication phase involves the detailed forensic analysis of the incident — determining the root cause, the attacker's methods and goals, the full scope of affected systems and data, and the complete timeline — and the removal of the attacker's access, malicious files, and persistence mechanisms from the environment.

Every employee has a role in the incident response programme, regardless of their technical background. The most important role any employee can play is prompt reporting. The biggest

predictor of the severity of a security incident's outcome is not the sophistication of the attack — it is the time elapsed between the attacker's initial access and the initiation of the company's response. Incidents that are reported and contained within hours of detection consistently produce materially better outcomes than incidents that are discovered days or weeks after the attacker has had free run of the environment. An employee who receives a suspicious email, notices unusual behaviour on their workstation, or suspects that their credentials may have been compromised must report it to IT Security at security@arjuntech.in immediately — not after completing their current task, not after asking a colleague whether it seems important, immediately.

### 6.2 Incident Classification and Severity Levels

Security incidents are classified into four priority levels based on the actual or potential impact of the incident, the sensitivity of the systems and data affected, and the likely attacker capability and intent. The priority level determines the response timeline, the escalation path, and the resources deployed. Classification is an initial judgement made with the information available at the time of triage — incidents may be reclassified upward as the investigation reveals additional information about their scope or severity.

| Priority | Label | Classification Criteria | Initial Response Time | Escalation Within | Incident Commander |
|---|---|---|---|---|---|
| P1 | Critical | Active breach with confirmed or highly probable data exfiltration, ransomware deployment, or compromise of domain administrator credentials | Immediate — 24/7 | 30 minutes | CTO or delegate |
| P2 | High | Confirmed malware on a company system without confirmed exfiltration, or compromise of a privileged account with limited scope | Within 2 hours — 24/7 | 1 hour | Head of IT Operations |
| P3 | Medium | Suspected phishing success without confirmed credential compromise, or malware detected and contained by endpoint protection | Within 4 hours — business hours | 4 hours | Senior IT Security Engineer |
| P4 | Low | Failed login attempts within normal variation, policy violations without malicious intent, or suspicious activity determined to be benign after initial review | Within 1 business day | Not escalated unless pattern emerges | IT Security Analyst |

### 6.3 Incident Reporting Obligations

Every employee and contractor who discovers, suspects, or is made aware of a security incident has an immediate personal obligation to report it to the IT Security team at security@arjuntech.in. This reporting obligation applies regardless of how minor the incident appears, regardless of whether the employee believes they may have contributed to it through their own actions, and regardless of the time of day or day of the week. The reporting obligation is personal and cannot be discharged by asking a colleague to report on one's behalf or by assuming that someone else will have already reported the same incident. Delayed or failed incident reporting is itself a serious policy violation, because the delay directly increases the potential harm caused by the incident.

The initial incident report must contain as much of the following information as the reporter has available at the time: a description of what was observed or what event triggered the concern; the date and time the event was first observed; the system or systems involved, identified by hostname, IP address, or service name where known; the names of any users whose accounts or data may be involved; any actions already taken by the reporter in response to the incident;

and the reporter's contact details. A complete and detailed initial report is valuable, but an incomplete report submitted immediately is far more valuable than a complete report submitted after a delay while the reporter gathers additional information. The IT Security team will gather additional details as part of the triage and investigation process.

In addition to the immediate internal reporting obligation, certain types of security incident trigger external reporting obligations to regulatory authorities and affected individuals under applicable law. Under the DPDP Act 2023, a personal data breach that is likely to cause harm to affected data principals must be reported to the Data Protection Board within the timeframe prescribed by the Board's regulations, and affected individuals must be notified. Under the GDPR, where applicable to EU resident data, a personal data breach with a risk to the rights and freedoms of individuals must be reported to the competent supervisory authority within 72 hours of the company becoming aware of it. Under the terms of specific client contracts, particularly in regulated sectors, breach notification obligations to the client may be as short as 24 hours. The Legal and Compliance team is responsible for assessing and executing external notification obligations for all P1 and P2 incidents, in coordination with the ISM and the relevant business unit.

### 6.4 Evidence Preservation and Forensic Handling

The preservation of digital evidence from a security incident is critical for two reasons. First, from a security perspective, forensic evidence allows the investigation to accurately reconstruct the attacker's methods, timeline, and scope of access — which is essential for confirming that the eradication is complete and that all affected systems and accounts have been identified. An incomplete eradication, based on an incomplete forensic picture, can leave the attacker with residual access that they use to re-enter the environment after the initial response has concluded. Second, from a legal and regulatory perspective, forensic evidence may be required to support regulatory investigations, client breach notifications, insurance claims, and potential legal proceedings. Evidence that is not properly preserved — because an affected system was immediately wiped and rebuilt without forensic imaging — may be irrecoverable and may prevent the company from meeting its legal obligations or defending itself in any subsequent proceedings.

When a security incident is confirmed at P1 or P2 severity, the IT Security team immediately activates the evidence preservation protocol. Affected systems must not be powered off, rebooted, or wiped before the IT Security team has confirmed that adequate forensic evidence has been preserved. IT Operations must not perform remediation actions — including patching, configuration changes, or account resets — on affected systems before the IT Security team has authorised the remediation, unless the action is specifically required as an emergency containment measure and has been explicitly approved by the ISM. All containment and remediation actions taken prior to the completion of forensic evidence preservation must be

documented in real time in the incident log, because these actions themselves alter the forensic state of the affected systems.

Forensic evidence collected during a security incident investigation is classified as Restricted. It must be stored in the IT Security team's evidence repository, which has access controls limited to the ISM and designated incident responders. Evidence must be documented in a chain of custody log that records every access to the evidence, the purpose of the access, and the name of the individual who accessed it. Where forensic analysis is conducted by a third-party firm, the evidence transfer must be documented in the chain of custody log and a data sharing agreement covering the specific evidence transferred must be in place before the transfer occurs. The ISM is responsible for maintaining the integrity of the chain of custody and for ensuring that evidence is handled in a manner that would be admissible in legal proceedings if required.

### 6.5 Post-Incident Review and Lessons Learned

Every security incident classified at P1 or P2 severity, and any P3 or P4 incident that reveals a significant gap in the company's security controls, must be followed by a formal post-incident review. The review must be completed and its findings documented within ten working days of the incident being formally closed. The purpose of the post-incident review is not to assign blame — it is to understand precisely what happened, why the incident occurred, why existing controls failed to prevent or detect it earlier, what the company did well in its response, what could have been done better, and what specific changes to the security programme would most effectively reduce the likelihood or impact of a similar incident in the future.

The post-incident review is chaired by the ISM and must include representation from IT Operations, the relevant business unit, Legal, and — where the incident involved HR matters such as an insider threat — HR. The review follows a structured format that examines the incident timeline from the earliest evidence of attacker activity to the completion of recovery, identifies the root cause of the incident using the Five Whys analysis technique to trace the immediate cause back to its underlying systemic contributors, assesses the effectiveness of the detection and response, and produces a prioritised list of remediation recommendations. The recommendations must be assigned to named owners with specific implementation deadlines, and their completion must be tracked in the IT Security risk register.

Findings from post-incident reviews are an important input to the annual information security risk assessment and to the continuous improvement of the security programme. Patterns across multiple post-incident reviews — for example, a recurring theme of delayed internal reporting, or a recurring vulnerability in a specific technology category — inform training programme updates, policy revisions, control enhancement investments, and security architecture changes. The ISM presents a summary of post-incident review findings and the status of outstanding remediation actions to the IT Security Steering Committee at each quarterly meeting. A sanitised version of significant post-incident findings — with all identifying information removed — is shared with the security awareness training programme to ensure that employees can learn from real incidents without compromising the confidentiality of investigation details.

### 6.6 Crisis Communications During a Major Incident

Major security incidents — particularly those involving potential personal data breaches, client data compromises, or significant service unavailability — require careful management of both internal and external communications. The immediate instinct of many organisations facing a major incident is to maintain silence while the investigation is ongoing, for fear of damaging public confidence or triggering additional regulatory scrutiny. This instinct, while understandable, is typically counterproductive. Silence during a major incident creates information vacuums that are filled by speculation. It damages trust with clients and regulators who expect transparency. And it can compound the legal consequences of the incident if silence is later characterised as

concealment.

The communications responsibilities during a major security incident are allocated as follows. Internal employee communications are the responsibility of the CEO, typically through a brief all-company communication that acknowledges the incident, describes what is known and what is being done, and sets expectations for further updates. This communication should go out within four hours of a P1 incident being confirmed — before external rumour or media coverage forces a reactive communication. Client communications are the responsibility of the relevant account managers, working from a briefing prepared by Legal and the ISM. Clients should be notified as soon as the impact on their specific environment or data is confirmed, and should receive regular updates at agreed intervals until the incident is fully resolved. Media and public communications are the sole responsibility of the CEO and the Communications team — no other employee should speak to the media about a security incident under any circumstances.

The company maintains a crisis communications protocol and a pre-approved set of holding statements for the most likely major incident scenarios — ransomware, data breach, and extended service unavailability. These are reviewed and updated annually by Legal, Communications, and the ISM. The existence of pre-prepared communications materials is not an indication that the company expects these incidents to occur — it is a recognition that the ability to communicate quickly and accurately during a crisis is significantly impaired when communications are being written from scratch under time pressure. Having a framework and tested language available in advance allows the company to communicate thoughtfully and accurately rather than hastily and inaccurately when the pressure of an active incident would otherwise compromise the quality of its communications.

### 6.7 Business Continuity Integration

Security incidents do not occur in isolation from the company's broader operational continuity obligations. A ransomware attack, a major data breach under active investigation, or a prolonged service unavailability incident does not pause the company's contractual obligations to its clients, its statutory obligations to its employees, or its regulatory obligations to the authorities that oversee its industry sectors. The incident response programme must therefore be tightly integrated with the company's Business Continuity Plan, ensuring that critical business functions can continue to operate — potentially in a degraded mode — even while a major security incident is being managed, and that the recovery sequence following an incident prioritises the restoration of the most business-critical functions first.

Each critical business system has a defined Recovery Time Objective — the maximum period of unavailability the business can tolerate before the impact becomes unacceptable — and a Recovery Point Objective — the maximum age of the data that can be restored without causing unacceptable business impact. The RTO and RPO for each critical system are documented in

the Business Continuity Plan and inform the design of the company's backup and disaster recovery infrastructure. In the event of a major security incident, the incident response commander must immediately assess whether critical business systems are affected and escalate to the BCP coordinator if any system with an RTO of less than four hours is impacted, so that BCP procedures can be activated in parallel with the security incident response.

The integration of incident response and business continuity is tested through an annual tabletop exercise in which senior management, IT Security, IT Operations, Legal, and BU representatives walk through a simulated major incident scenario — typically a ransomware attack affecting multiple systems — and work through both the incident response and business continuity decisions simultaneously. The exercise identifies gaps in coordination, communication, and decision-making authority that are difficult to see in either programme in isolation. Findings from the tabletop exercise are documented and addressed in the security and BCP programme improvement cycles. The tabletop exercise is a requirement of both ISO 27001 and the IT Security Steering Committee's annual programme review.

## 7. Third-Party and Vendor Security

### 7.1 Vendor Security Risk Management Framework

Third-party vendors, managed service providers, cloud platform providers, and technology partners represent one of the most significant and fastest-growing categories of information security risk for organisations of all sizes. The history of major security incidents over the past decade is full of cases where a well-defended organisation suffered a breach not because its own security controls failed, but because an attacker compromised a less well-defended vendor that had privileged access to the organisation's systems or data — and used that privileged access as a stepping stone. The 2020 SolarWinds supply chain attack, which affected thousands of organisations globally including government agencies, is the most widely known example of this pattern. Arjun Technologies's vendor security risk management framework is designed to prevent this attack surface from being exploited by ensuring that vendors who have access to company systems or data meet security standards commensurate with the sensitivity of the access they are granted.

Vendors are classified into four risk tiers based on the nature and sensitivity of their access to the company's systems and data. Tier 1 vendors — those with access to Restricted data, production system administrative access, or critical infrastructure management — are subject to the most rigorous assessment and ongoing monitoring requirements. Tier 2 vendors have access to Confidential data or significant operational systems but not to the company's most sensitive assets. Tier 3 vendors have access to Internal Use Only information and low-sensitivity operational tools. Tier 4 vendors provide goods or services with no access to company systems or data — standard commercial procurement due diligence applies to this tier without specific

information security assessment requirements.

Before any new vendor engagement begins — and before any existing vendor is granted a new and higher category of access — a vendor security assessment must be conducted. The depth of the assessment is proportionate to the vendor's tier classification. A Tier 1 assessment involves a detailed security questionnaire covering all relevant ISO 27001 control domains, a review of the vendor's own security certifications and audit reports (SOC 2 Type II, ISO 27001 certificate, or equivalent), a review of any recent penetration test executive summaries, and in some cases a right-to-audit visit or interview with the vendor's security leadership. A Tier 2 assessment involves a security questionnaire and certification review. A Tier 3 assessment involves an abbreviated questionnaire focused on the most relevant controls for the specific access being granted.

| Tier | Access Profile | Assessment Requirements | Ongoing Monitoring | Contract Requirements |
|---|---|---|---|---|
| Tier 1 — Critical | Access to Restricted data; privileged system access; access to production environments | Full security questionnaire; review of ISO 27001 certificate or SOC 2 Type II report; review of penetration test summary; annual reassessment | Annual reassessment; quarterly review of any changes to the vendor's security posture; immediate notification of any incident affecting the vendor | Signed DPA; mandatory 24-hour incident notification clause; right to audit; data return or destruction obligation on termination; sub-processor approval requirement |
| Tier 2 — High | Access to Confidential data; standard application access; no privileged system access | Security questionnaire; review of ISO 27001 certificate or SOC 2 report; review of any recent penetration test summary | Annual reassessment; monitoring of any publicly reported incidents affecting the vendor | Signed DPA; 24-hour incident notification clause; data return or destruction obligation on termination; sub-processor approval requirement |
| Tier 3 — Medium | Access to Internal Use Only information; limited system access; no access to Confidential or Restricted data | Abbreviated questionnaire focused on relevant controls; review of any available security certification | Biennial reassessment; monitoring of any publicly reported incidents affecting the vendor | Signed DPA; 24-hour incident notification clause in standard terms |
| Tier 4 — Low | No access to company systems or data; physical goods supply only | Standard procurement due diligence only; no specific security assessment required | Periodic review of supplier relationship | Standard terms and conditions of purchase only. |

### 7.2 Data Processing Agreements and Security Contractual Requirements

Every vendor or subcontractor that processes personal data on behalf of Arjun Technologies — whether that personal data belongs to the company's employees or to the personal data subjects of clients for whom the company acts as a data processor — must have a signed Data Processing Agreement in place before any processing commences. This is a mandatory requirement under both the DPDP Act 2023 and, where EU resident personal data is involved, the GDPR. A DPA that meets the requirements of both instruments must be in place before any data transfer to such a vendor occurs. The Legal and Compliance team is responsible for reviewing and approving all DPAs, and no DPA may be executed without Legal sign-off.

Beyond the DPA requirements that apply specifically to personal data processing, all Tier 1 and Tier 2 vendor contracts must include a set of core security obligations that are non-negotiable: the vendor must implement and maintain appropriate technical and organisational security measures commensurate with the risk presented by the specific access and data involved; the vendor must notify Arjun Technologies within 24 hours of becoming aware of any security incident that involves or may involve the company's data or systems; the vendor must agree to the company's right to audit the vendor's security controls, either directly or through a third-party auditor; the vendor must not engage subcontractors who will have access to the company's data without the company's prior written approval; the vendor must return or certifiably destroy all company data within 30 days of the termination of the engagement; and the vendor must maintain security certifications appropriate to the sensitivity of the access granted throughout the

term of the engagement.

The company's procurement process includes a mandatory security review gate: no new Tier 1 or Tier 2 vendor engagement can be contracted without a completed vendor security assessment and ISM sign-off on the security provisions of the proposed contract. This gate is enforced by requiring the ISM's signature on the vendor contract approval form before the contract can be executed. The process creates occasional friction in fast-moving commercial negotiations — clients and vendors sometimes push back on the time required for security review. The company's position is that this friction is preferable to the operational and legal risk of engaging a vendor that turns out to have inadequate security controls. The ISM will prioritise vendor security reviews to minimise delay where the commercial urgency is genuine.

**Arjun Technologies Pvt. Ltd.**
Bengaluru, Karnataka — 560 001
CIN: U72200KA2008PTC044521 | www.arjuntech.in

# INFORMATION TECHNOLOGY SECURITY POLICY AND PROCEDURES MANUAL

Segment 2 of 3 — Cloud Security · Awareness · BCP/DR · Compliance · Secure SDLC

| | | | |
|---|---|---|---|
| **Version** | 3.5 | **Effective Date** | 01 January 2024 |
| **Review Date** | 31 December 2024 | **Classification** | Internal Use Only |
| **Policy Sponsor** | Mr. Rajesh Arjun | **Document Owner** | Mr. Ashwin Kumar |
| **Approved By** | Mr. Vikram Nair | **Legal Review By** | Mr. Sandeep Iyer |
| **Standard Alignment** | ISO/IEC 27001:2022 | **HR Acknowledgement** | Ms. Priya Menon |
| **Document Ref.** | IT-SEC-POL-001-v3.5 | **Segment** | 2 of 3  (Pages 61–120) |

*This is Segment 2 of the Arjun Technologies Pvt. Ltd. IT Security Policy and Procedures Manual. It covers cloud security governance, the security awareness and training programme, business continuity and disaster recovery, compliance and audit management, and the secure software development lifecycle. It must be read in conjunction with Segment 1, which establishes the governance framework, classification scheme, and access control policy. Queries should be directed to Mr. Ashwin Kumar at itsecurity@arjuntech.in.*

## 8. Cloud Security

### 8.1 Cloud Security Governance and Shared Responsibility

The adoption of cloud computing services has fundamentally changed the information security landscape for Arjun Technologies and for the technology industry more broadly. Cloud platforms — principally Amazon Web Services, Microsoft Azure, and Google Cloud Platform — offer compelling advantages in scalability, resilience, developer productivity, and access to advanced services including managed databases, machine learning infrastructure, and serverless compute. They also introduce a category of security risk that is structurally different from the risks associated with on-premises infrastructure: in a cloud environment, the responsibility for security is divided between the cloud provider and the customer in a way that is not always intuitive and that is a frequent source of significant security misconfiguration. The company's cloud security programme is designed to ensure that the company's share of the cloud security responsibility is always clearly understood, consistently discharged, and regularly verified.

The shared responsibility model varies by service type. For Infrastructure as a Service — where the cloud provider supplies virtual machines, storage, and networking but the customer installs and manages the operating system and everything above it — the customer is responsible for the security of the operating system, all installed software, the data stored on the infrastructure, identity and access management, network security group configurations, and the application layer. For Platform as a Service — managed databases, container orchestration platforms, and similar — the provider manages the underlying infrastructure and runtime, and the customer is responsible for the data, the application code, identity and access management, and configuration of the platform service. For Software as a Service — fully managed applications such as productivity suites and HR systems — the provider manages the entire technology stack, and the customer's security responsibilities are limited to identity management, data governance, and configuration of application-level security settings.

A critical and frequently misunderstood point about the shared responsibility model is that the cloud provider's responsibility for the security of the infrastructure they operate does not reduce the company's legal obligations in relation to the data stored on that infrastructure. If a misconfiguration of a company-managed cloud storage bucket results in the public exposure of client personal data, the fact that the storage infrastructure was managed by a cloud provider does not transfer the company's DPDP Act obligations or its client contractual obligations to that provider. The company remains fully accountable for the data it stores, regardless of where it is stored, and the cloud security controls described in this section are the mechanisms through which that accountability is discharged.

All cloud services used to store, process, or transmit company data classified at the Internal Use Only level or above must be listed in the Approved Cloud Services Register maintained by the IT Security team. The register records each approved service, the classification levels for which it

is approved, the specific security configurations required for use at each classification level, the last date on which the service's security posture was assessed, and the current approval status. Using a cloud service that is not on the Approved Register — shadow IT — is prohibited regardless of the service's general reputation or widespread use in the industry. Shadow IT in a cloud context is particularly dangerous because cloud services can be accessed from any internet-connected device without leaving traces in the company's network monitoring infrastructure, creating data flows that are entirely invisible to the IT Security team.

The IT Security team reviews the Approved Cloud Services Register quarterly and conducts a full reassessment of each listed service annually, reviewing changes to the provider's security certifications, data handling practices, geographic data storage commitments, and incident history. Services that no longer meet the company's security requirements are removed from the Register, and data stored in those services must be migrated to an approved alternative within a timeline agreed between the ISM and the relevant business unit. The procurement of any new cloud service, regardless of cost or commercial urgency, must include an IT Security review and registration before the service goes into use with company data.

### 8.2 Approved Cloud Services and Usage Standards

The following table lists the primary cloud services currently approved for use with company data, the maximum classification level of data for which each service is approved, and the key security configuration requirements that must be maintained for each service. Employees must verify that any service they intend to use appears on this register and that their intended use case does not exceed the approved classification level for that service. For cloud services not listed below, employees must submit an assessment request to IT Security before using the service with any company data above the Public classification level.

| Service | Max Data Classification | Mandatory Security Configurations | Key Exclusions / Notes |
|---|---|---|---|
| Google Workspace (corporate tier) | Confidential | SSO enforced; MFA mandatory for all users; Drive sharing restricted to managed domains only | Personal Gmail accounts and personal Google Drive must not be used |
| Microsoft Azure (commercial tenant) | Restricted (with controls) | Azure Active Directory with Conditional Access; Microsoft Defender for Cloud enabled; Sentinel SIEM integration | Personal Azure subscriptions and unmanaged tenants are prohibited |
| Amazon Web Services (corporate account) | Restricted (with controls) | AWS SSO enforced; CloudTrail enabled in all regions; GuardDuty enabled; Security Hub compliance standards | Personal AWS accounts and root account usage are prohibited |
| GitHub Enterprise (corporate org) | Confidential | SSO enforced; MFA mandatory; branch protection rules on all default branches; secret scanning enabled | Personal GitHub accounts and public repositories are prohibited |
| Slack (corporate account) | Internal Use Only | SSO enforced; MFA mandatory; data retention policy configured; DLP integration for sensitive channels | Confidential and Restricted data must not be shared in Slack channels |
| Zoom (corporate licence) | Internal Use Only | Meeting passwords mandatory; waiting room enabled; cloud recording disabled by default | Meeting links must not be posted publicly; personal Zoom accounts |
| Jira and Confluence (Atlassian Cloud) | Confidential | SSO enforced; MFA mandatory; SCIM provisioning for automated user lifecycle management | Restricted data must not be stored in Jira or Confluence |
| Salesforce (CRM) | Confidential | SSO enforced; MFA mandatory; field-level encryption for sensitive CRM fields; API access restricted | CRM data must not be exported to personal devices or unmanaged |

### 8.3 Infrastructure as Code and Cloud Configuration Management

All cloud infrastructure used to host company workloads must be provisioned and managed exclusively through approved Infrastructure as Code templates. Manual, console-based

provisioning of cloud resources — creating virtual machines, storage buckets, databases, or network configurations through a cloud provider's web console or command-line interface without a corresponding IaC definition — is prohibited for any resource that processes or stores data above the Internal Use Only level, and is only permitted for exploratory work in designated sandbox environments. The prohibition on manual provisioning exists because manually created resources are frequently undocumented, inconsistently configured, and excluded from automated security scanning — they represent security blind spots whose existence is invisible to the monitoring infrastructure.

IaC templates used to provision cloud infrastructure must pass through the company's automated security scanning pipeline before being applied to any environment. The security scanning step executes a set of policy-as-code checks against the template, verifying that the configuration it would create is compliant with the security baseline defined for the applicable cloud provider and classification level. The checks include: public access disabled on all storage resources; encryption at rest enabled on all data stores; security groups and network access control lists following the minimum-necessary-access principle; logging and monitoring services enabled; TLS version requirements met for all internet-facing services; and no hardcoded secrets or credentials in the template. Templates that fail security scanning must be remediated before deployment — they cannot be deployed with scanning failures in place, regardless of schedule pressure.

The concept of configuration drift — the gradual deviation of live cloud resources from the secure configuration defined in the IaC template, caused by manual configuration changes made directly to live resources — is a significant and persistent cloud security risk. Configuration drift most commonly occurs when an engineer makes a quick manual change to a live configuration to resolve an immediate operational issue, without updating the IaC template to reflect the change. Over time, the gap between the documented configuration and the live configuration grows, security scanning becomes less meaningful because it scans the template rather than the live state, and the organisation loses confidence in its understanding of what is actually deployed. The company addresses configuration drift through continuous cloud security posture management, which continuously compares the live configuration of all cloud resources against the approved security baseline and alerts when deviations are detected. Detected deviations must be remediated within 24 hours for Critical-severity findings, 72 hours for High-severity findings, and within the next scheduled deployment cycle for Medium and Low findings.

Secrets management — the secure handling of API keys, database connection strings, service account credentials, and other sensitive configuration values that applications need to function — is one of the most commonly mismanaged aspects of cloud security. The most dangerous pattern is hardcoded secrets: sensitive values embedded directly in source code, configuration files, or environment variables that are then committed to version control repositories and made

accessible to anyone with repository access, or in some cases to the entire internet if the repository is accidentally made public. The company's secrets management policy requires that all secrets used by applications and infrastructure must be stored in a secrets management service — AWS Secrets Manager or Azure Key Vault for the respective cloud environments, HashiCorp Vault for cross-environment needs — and must never be hardcoded in source code, committed to version control, or stored in plain-text configuration files. Secret scanning is integrated into the CI/CD pipeline to detect and block any commit that contains a pattern consistent with a secret or credential.

### 8.4 Cloud Identity and Access Management

Identity and access management in cloud environments requires the same Principles of Least Privilege, Need-to-Know, and Segregation of Duties that govern access to on-premises systems, but the cloud IAM model introduces additional complexity that must be carefully managed. Cloud providers offer rich and granular IAM capabilities — fine-grained policies, service-level roles, resource-level permissions, and the ability to delegate access across accounts and organisations — and this granularity is both a security asset and a risk. A poorly designed IAM configuration can grant an application or a human user far more access than intended, creating attack paths that are invisible to anyone who has not carefully mapped the effective permissions of each principal.

The concept of the cloud security principal — any entity that can make API calls to a cloud platform, including human users, application service accounts, compute instances, serverless functions, and container workloads — must be understood clearly. Every principal must have an explicit, documented identity in the cloud IAM system, and every principal's permissions must be the minimum necessary for its function. Service principals — the identities used by applications, scripts, and automated processes rather than by human users — are a particularly important focus of least-privilege management, because they frequently accumulate excessive permissions over time as additional capabilities are added to the applications they represent, and their permissions are less frequently reviewed than human user accounts. All service principal permissions must be reviewed quarterly as part of the cloud IAM access review.

Root and super-admin accounts in cloud environments — the accounts with full, unrestricted administrative access to the entire cloud environment — present exceptional risk and must be managed with exceptional controls. Root accounts in AWS, and Global Administrator accounts in Azure Active Directory, are the keys to the entire kingdom: an attacker who compromises one of these accounts can access, modify, or destroy every resource in the environment without restriction. Root accounts must never be used for routine operations. They must be protected by FIDO2 hardware keys as the MFA factor — SMS OTP is explicitly not acceptable for these accounts. The root account credentials must be stored in the IT Security vault with access restricted to the ISM and the CTO. All use of root or super-admin accounts must be logged,

reviewed by the ISM within one business day of the use, and documented in the privileged access log.

Cross-account and cross-service access — situations where a resource in one AWS account or Azure subscription needs to access resources in another account or subscription — must be implemented using properly scoped IAM roles rather than by creating service accounts in each account and sharing their credentials. IAM role assumption provides time-limited, automatically expiring access without requiring the storage and management of static credentials, and creates a complete audit trail of which service assumed which role at which time. Any cross-account access configuration that uses static service account credentials rather than role assumption must be documented as a technical exception and have an approved remediation plan in place.

### 8.5 Cloud Security Monitoring and Threat Detection

The monitoring capabilities provided by major cloud platforms — AWS CloudTrail, Azure Monitor, Google Cloud Audit Logs — generate a comprehensive record of every API call made to the cloud environment, including who made the call, from what IP address, at what time, and with what parameters. This data is the foundation of cloud security monitoring and provides the raw material from which both real-time threat detection and retrospective investigation of security incidents can be conducted. The company's cloud security monitoring architecture routes all cloud platform audit logs to the SIEM, where they are correlated with endpoint and network telemetry to create a unified view of the company's security posture across all environments.

Cloud-native security monitoring services are enabled in all company cloud environments as a baseline control. AWS GuardDuty is enabled in all AWS regions across all company accounts, providing machine learning-based threat detection for suspicious API call patterns, unusual network traffic patterns in VPCs, and indicators of credential compromise. Microsoft Defender for Cloud is enabled in all Azure subscriptions, providing continuous security posture assessment, threat detection, and integrated vulnerability management for Azure workloads. Google Security Command Center is enabled for all GCP projects. These cloud-native services complement rather than replace the SIEM integration — they provide cloud-specific threat intelligence and detection algorithms that are more finely tuned to cloud-native attack patterns than a generic SIEM rule set can be.

Cloud infrastructure security posture management is conducted through the combination of cloud-native security posture tools and a third-party CSPM platform that provides a unified view across all cloud environments. The CSPM platform continuously evaluates the configuration of every cloud resource against the company's security baseline and against industry benchmark frameworks including the CIS Benchmarks for each cloud provider, and produces a daily security posture score for each cloud account. The security posture score, and any new Critical

or High findings generated by the CSPM platform, are included in the ISM's weekly security dashboard. The target is a security posture score of 85 or above for all cloud accounts — accounts that fall below this threshold trigger an immediate remediation review by IT Operations and the relevant engineering team.

Anomaly detection in cloud environments focuses particularly on the following categories of suspicious activity: unusual patterns of API calls from unexpected geographic locations; bulk data download or export operations that exceed normal operational volumes; creation of new IAM users, roles, or policy attachments — especially those granting administrative permissions; disabling of security services such as CloudTrail, GuardDuty, or audit logging; creation of publicly accessible storage resources; unusually high compute consumption that may indicate cryptomining abuse; and failed authentication attempts that suggest credential brute forcing. Alerts for all of these categories are configured in the SIEM and are routed to the MDR provider for 24/7 triage. P1 and P2 severity cloud security alerts are escalated to the IT Security team immediately, consistent with the incident response procedure in Section 6 of Segment 1.

## 9. Security Awareness and Training Programme

### 9.1 Programme Philosophy and Objectives

The single most commonly cited root cause in post-incident analyses of significant security breaches is not a technical vulnerability in a firewall, a missing software patch, or an unencrypted database — it is human behaviour. An employee who clicks a phishing link, uses a weak password across multiple accounts, shares credentials with a colleague because it is more convenient than requesting proper access provisioning, or uploads a client document to a personal cloud storage account because the approved file sharing mechanism feels slow on a given day is, in each case, making a decision that directly undermines security controls that may have cost significant time and money to design and implement. The security awareness and training programme is the company's primary mechanism for reducing the frequency and severity of these human errors — not by treating employees as the weak link in the security chain to be constrained and controlled, but by ensuring that every individual understands the threat environment, knows why specific controls exist, and has the practical knowledge and skills to apply those controls effectively in their daily work.

The programme is designed around three practical objectives. The first is awareness — ensuring that every employee is familiar with the threats most relevant to their role, understands the potential consequences of security failures for the company and for clients, and recognises the most common attack techniques used against organisations like Arjun Technologies. Awareness without knowledge is insufficient — an employee who knows that phishing is a thing but cannot recognise a sophisticated spear-phishing email in practice is not materially more secure than an employee who has never heard the word phishing. The second objective is knowledge — giving employees the specific technical and procedural knowledge they need to make secure decisions in their daily work: how to recognise a phishing email, how to use the password manager correctly, what to do if a suspicious email is received, how to classify a document, how to report a security concern. The third objective is skill — moving from knowledge to practiced behaviour through practical exercises, simulations, and reinforcement that embed secure habits into daily routines rather than leaving security as an abstract concept that is understood in theory but forgotten under the time pressure of real work.

The programme applies a differentiated approach to training delivery that recognises the different risk profiles and technical backgrounds of different employee populations. All employees receive the mandatory baseline training that establishes awareness and knowledge of the security topics most relevant to every individual in the organisation. Engineering and development staff receive additional technical training covering the security topics most relevant to their work — secure coding practices, dependency management, secrets handling, and cloud security. Senior managers and executives receive training focused on the risks and responsibilities specific to their roles — business email compromise, executive fraud, data

governance, and the reputational consequences of security failures. IT and security staff receive advanced technical training and participate in exercises that develop their incident detection and response skills beyond the level achievable through standard training modules.

### 9.2 Mandatory Training Curriculum

The following training modules are mandatory for all employees, regardless of role, level, or tenure. All modules must be completed through the company's Learning Management System, which records completion, scores, and the date on which each module was last completed. Completion certificates are automatically generated and stored in the employee's LMS record. Line managers are responsible for ensuring that all direct reports complete mandatory training within the required timelines, and training completion rates are reported as a key metric to the IT Security Steering Committee. Employees who do not complete mandatory training within the required timeline are escalated to their line manager and HRBP, and non-completion may be treated as a disciplinary matter for persistent non-compliers.

| Module Code | Module Title | Target Audience | Duration | Completion Deadline | Assessment | Renewal Fre |
|---|---|---|---|---|---|---|
| SEC-101 | Information Security Fundamentals | All employees | 2 hours | Within 30 days of joining | Quiz — 80% to pass | Annual |
| SEC-102 | Phishing and Social Engineering Awareness | All employees | 90 minutes | Within 30 days of joining | Practical scenario quiz — 75% to pass | Annual |
| SEC-103 | Password Security and Credential Management | All employees | 60 minutes | Within 30 days of joining | Quiz — 80% to pass | Annual |
| SEC-104 | Data Classification and Handling | All employees | 90 minutes | Within 30 days of joining | Classification scenario quiz — 80% to pas | Annual |
| SEC-105 | Acceptable Use Policy | All employees | 60 minutes | Within 30 days of joining | Acknowledgement and quiz | Annual |
| SEC-106 | Remote Work and BYOD Security | All employees eligible for remote/BYOD | 60 minutes | Before first remote working day | Quiz — 75% to pass | Annual |
| SEC-107 | POSH and Workplace Conduct | All employees | 90 minutes | Within 30 days of joining | Acknowledgement | Annual (HR-led) |
| SEC-201 | Secure Coding Fundamentals (OWASP Top 10) | Engineering staff | 4 hours | Within 60 days of joining | Practical coding assessment | Annual — 70% to |
| SEC-202 | Cloud Security for Developers | Engineering and DevOps staff | 3 hours | Within 60 days of joining | Quiz — 75% to pass | Annual |
| SEC-203 | Secrets Management and Secure Configuration | Engineering and DevOps staff | 2 hours | Within 60 days of joining | Practical exercise | Annual |
| SEC-301 | Executive Security Awareness | Band 5 and above | 2 hours | Within 30 days of joining or promotion | Quiz and scenario discussion (ISM-facilita | Annual |
| SEC-302 | Incident Response for Non-Technical Managers | All managers (Band 4+) | 90 minutes | Within 60 days of becoming a manager | Tabletop exercise participation | Annual |
| SEC-401 | Advanced Threat Detection and Response | IT Security team | 8 hours | Within 30 days of joining | Practical assessment | Annual with quarte |

### 9.3 Phishing Simulation Programme

Classroom and e-learning training about phishing is valuable for building conceptual awareness — understanding that phishing is a real threat, knowing the general characteristics of phishing emails, and knowing what to do when a suspicious email is received. It is not, however, sufficient to produce the reflexive vigilance that effective phishing defence requires. Reading about phishing and recognising a real phishing email in the flow of a busy working day, under time pressure, while managing competing priorities, are different skills. The phishing simulation programme addresses this gap by sending employees realistic, non-harmful simulated phishing emails that allow them to practice their recognition skills in a realistic environment, with

immediate feedback and targeted learning when they make the wrong decision.

The phishing simulation programme conducts simulated phishing campaigns at a frequency of one campaign per month, targeting different subsets of the employee population on a rotating basis so that each employee receives approximately one simulation every six to eight weeks. Simulated phishing emails are crafted to reflect the actual attack techniques most commonly observed in real campaigns targeting Indian IT services companies in the current period — including business email compromise simulations that impersonate executives requesting urgent wire transfers, vendor payment redirect scams, IT support credential phishing, and HR benefit-related phishing that exploits employees' interest in their personal financial affairs. Campaign designs are rotated regularly to prevent employees from becoming pattern-matched to a specific style of simulation that does not reflect the diversity of real phishing campaigns.

When an employee clicks a link in a simulated phishing email, they are immediately redirected to a brief, non-threatening educational page that explains what they clicked on, why it was a phishing simulation, what the specific characteristics of the email should have triggered suspicion, and what they should do differently next time. This immediate feedback is a more effective learning mechanism than a delayed notification or a periodic report, because it connects the education directly to the specific decision the employee just made while that decision is still fresh. The educational page also provides clear instructions on how to report suspicious emails using the 'Report Phishing' button in the company's email client, reinforcing the correct response behaviour.

Simulation results are tracked at the individual, team, and business unit level. Employees who click on a simulated phishing link are automatically enrolled in the remedial phishing awareness module (SEC-102R), which must be completed within five working days. Employees who click on three or more simulated phishing emails within a twelve-month period are referred to their line manager and HR for a more formal discussion about security compliance expectations, and may be required to complete additional training. Business unit phishing click rates are reported as a KPI to the IT Security Steering Committee and are shared with the relevant SVPs in an anonymised, aggregated format that allows benchmarking between units without exposing individual employee performance data.

### 9.4 Security Champions Programme

The Security Champions programme identifies and develops a network of employees across all business units and technical teams who have a personal interest in information security and who are willing to serve as the local security resource, advocate, and first point of contact for their colleagues. Security Champions are not IT Security professionals — they are engineers, analysts, project managers, and other functional employees who sit within their business unit teams and understand the specific security challenges and technology environment that their

colleagues work with every day. The programme recognises that centrally-deployed IT Security staff cannot have the contextual knowledge of every team's technology choices and working patterns that is necessary to provide tailored, practical security guidance at the team level.

Security Champions are selected through a combination of self-nomination and manager recommendation, and are formally endorsed by the ISM. The selection criteria emphasise a genuine interest in security, strong technical curiosity, good communication skills, and the personal standing within their team to be able to raise security concerns and recommendations without being dismissed or marginalised. The role is voluntary and does not carry any formal authority — Security Champions cannot approve exceptions to security policy, grant or revoke access, or take disciplinary action for policy violations. What they can do is provide informal guidance, raise awareness of security requirements, flag potential security issues to the IT Security team before they become incidents, and facilitate the delivery of security-relevant communications from the IT Security team to their team.

Active Security Champions receive monthly briefings from the ISM covering the current threat landscape, recent incidents of relevance to the company or the industry, updates to security policy or tooling, and preview of upcoming changes to security requirements that will affect their team. They also receive access to an extended set of security training resources, invitations to attend internal security exercises and tabletop simulations, and a direct communication channel with the IT Security team for escalating concerns or seeking guidance. The company aims to maintain a ratio of at least one Security Champion per 50 employees across the organisation, with specific Champions designated for each office location and each major business unit. The ISM reviews the Security Champions network quarterly and fills vacancies promptly when Champions leave the company or change roles.

### 9.5 Security Culture Measurement and Programme Effectiveness

The security awareness and training programme must be measured and evaluated regularly to determine whether it is producing the behavioural changes it is designed to achieve. Training completion rates, quiz scores, and phishing simulation click rates are the primary programme metrics, but they measure activity and immediate response rather than sustained cultural change. The ISM additionally conducts an annual security culture survey — a confidential, anonymous questionnaire distributed to all employees — that assesses employees' understanding of key security concepts, their confidence in applying security controls in their daily work, their perception of whether the company's security policies are reasonable and clearly communicated, and their willingness to report security concerns without fear of repercussion.

Security culture survey results are analysed by the ISM and presented to the IT Security Steering Committee with year-on-year trend analysis. Specific questions that reveal persistent

gaps in awareness, knowledge, or confidence are used to target updates to the training curriculum and to inform the design of phishing simulations and security communications. Survey results are also used to assess whether the programme is delivering equivalent security outcomes across different employee populations — if engineering staff consistently score higher on technical security knowledge but lower on physical security awareness, or if certain offices consistently report lower confidence in how to report a security concern, these patterns inform targeted programme adjustments.

In addition to the annual survey, the ISM tracks a set of behavioural indicators that provide a more direct measure of security culture than survey responses: the number of security incidents reported by employees through voluntary self-reporting (compared to incidents detected by technical monitoring), the proportion of reported incidents that turn out to be genuine versus false alarms (a high genuine rate suggests good judgement in what to report; a high false alarm rate suggests good awareness but calibration that needs work), the time between incident occurrence and employee reporting, and the rate at which employees use the 'Report Phishing' button in the email client when they receive suspicious emails. These behavioural indicators provide a real-world test of whether the training programme is producing the practical security behaviours it is designed to create.

## 10. Business Continuity and Disaster Recovery

### 10.1 Business Continuity Planning Framework

Business continuity planning at Arjun Technologies is the systematic process of ensuring that the organisation can continue to deliver its critical business functions — including client service delivery, internal operations, and regulatory compliance — in the event of a disruptive event that impairs its normal operating capability. The disruptive events that the BCP addresses include information security incidents such as ransomware and data breaches (which are covered in the intersection of the incident response programme and the BCP), as well as non-security events such as natural disasters, infrastructure failures, supply chain disruptions, pandemic-related workforce unavailability, and prolonged power or telecommunications outages. The BCP and the IT Security incident response programme are deliberately integrated, recognising that a significant security incident is itself a business continuity event that requires the same careful management of operational continuity as any other major disruption.

The Business Continuity Plan is owned by the SVP — Operations, with technical recovery planning components owned by the CTO. The ISM is responsible for the security-related dimensions of both the BCP and the Disaster Recovery Plan — ensuring that recovery processes do not inadvertently create security vulnerabilities, that forensic evidence is preserved during recovery operations, and that restored systems meet security requirements before they are returned to production use. The full BCP is a separate, standalone document classified as Restricted. This section of the IT Security Policy summarises the security-relevant provisions of the BCP and the DR Plan and provides the interface between the security incident response process and the broader business continuity framework.

A Business Impact Analysis is conducted annually in conjunction with the information security risk assessment, typically in October. The BIA identifies all business functions that are necessary for the company to meet its client contractual obligations, its statutory obligations, and its operational viability, and for each function it defines the Maximum Tolerable Period of Disruption — the period beyond which the disruption causes unacceptable harm to the business — and the Minimum Business Continuity Objective — the minimum service level at which the function must be maintained during a disruptive event to prevent the harm from becoming unacceptable. The BIA output directly informs the Recovery Time Objectives and Recovery Point Objectives assigned to each critical business system, which in turn drive the design and capacity requirements of the disaster recovery infrastructure.

The BCP identifies three tiers of response for disruptions of increasing severity. A Tier 1 disruption — affecting a single team, a single system, or a single office for a short duration — is managed through normal operational contingency processes without formal BCP activation. The affected team or system owner resolves the disruption using standard operational runbooks and escalation paths. A Tier 2 disruption — affecting multiple teams, multiple critical systems, or

causing an extended unavailability of a single major system — triggers a BCP activation decision by the SVP-Operations in consultation with the relevant BU SVP and the CTO. BCP activation initiates the formal crisis management structure, with designated command roles, regular crisis team calls, and managed stakeholder communications. A Tier 3 disruption — a major incident affecting the company's overall operational capability, such as a ransomware attack affecting multiple business systems, a major office facility becoming unavailable, or a widespread telecommunications failure — triggers full BCP activation, the crisis management team convenes, and all business units transition to their designated continuity operating modes.

### 10.2 Recovery Time Objectives and Recovery Point Objectives

The Recovery Time Objective for a system is the maximum period of unavailability that the business can tolerate before the impact becomes unacceptable — the deadline by which the system must be recovered and returned to service. The Recovery Point Objective is the maximum age of the data that can be restored without causing unacceptable business impact — the furthest back in time that the business can afford to roll data if a recovery from backup is required. Both metrics are defined through the BIA and represent business decisions about acceptable risk rather than technical assessments of what is achievable. The technical recovery architecture must be designed to meet the RTO and RPO for every critical system — if the architecture cannot achieve the defined objectives, the gap must be remediated or the business must accept the commercial risk of setting a less demanding objective.

| Business System | Criticality | RTO | RPO | Recovery Architecture | Last DR Test | Test Result |
|---|---|---|---|---|---|---|
| Client-facing delivery platforms | Tier 1 — Critical | 2 hours | 15 minutes | Active-active multi-region deployment; automated failover | October 2023 | Passed — actual RTO 47 minutes |
| Internal engineering infrastructure (Git, CI/CD) | Tier 1 — Critical | 4 hours | 1 hour | Cloud-hosted with cross-region replication; infrastructure as code | October 2023 | Passed — 2 hours 35 minutes |
| Corporate email and communications | Tier 1 — Critical | 2 hours | 30 minutes | SaaS platform with provider-managed high availability | September 2023 | Passed — provider-managed |
| HRMS | Tier 2 — High | 8 hours | 4 hours | SaaS platform; data export backup scheduled daily | October 2023 | Passed — 6 hours 15 minutes |
| Financial and ERP systems | Tier 1 — Critical | 4 hours | 1 hour | On-premises primary with cloud hot standby; synchronous replication | November 2023 | Passed — 3 hours 40 minutes |
| Internal IT infrastructure (AD, DNS, DHCP) | Tier 1 — Critical | 1 hour | 30 minutes | Redundant domain controllers in each office; cloud-based backup AD | October 2023 | Passed — 38 minutes |
| CRM platform | Tier 2 — High | 8 hours | 2 hours | SaaS platform with standard provider redundancy; daily export | October 2023 | Passed |
| Project management and collaboration tools | Tier 3 — Medium | 24 hours | 8 hours | SaaS platform; daily backup export | September 2023 | Passed — restored from export |
| Physical office facility (single location) | Tier 2 — High | 48 hours | N/A — work from home capability | Remote working capability for all roles; no physical infrastructure dependency | August 2023 | Facility passed annual fire safety inspection |

### 10.3 Backup Strategy and Data Protection

The company's backup strategy is designed on the 3-2-1-1 principle: three copies of critical data must exist at all times (the production copy plus two backups); the backups must be on two different storage media types; one backup copy must be stored off-site or in a different cloud region from the primary data; and one backup copy must be immutable — protected against modification or deletion by ransomware or by an attacker with administrative access to the primary backup infrastructure. The immutability requirement is the most recent addition to the

strategy and reflects the growing sophistication of ransomware attacks, which now frequently target and destroy backup copies before encrypting production data to prevent recovery without paying the ransom.

Backup schedules are defined by the criticality tier of the system being backed up. Tier 1 Critical systems have continuous data protection where technically feasible, supplemented by hourly snapshots and daily full backups. Tier 2 High systems have hourly snapshots during business hours and daily full backups. Tier 3 Medium systems have daily incremental backups and weekly full backups. All backup sets include the backup of configuration and system state in addition to data, ensuring that recovery can restore both the data and the system configuration to a known-good state rather than requiring manual reconfiguration of the system environment during what may be a high-pressure recovery operation.

Backup integrity is verified through automated recovery testing that goes beyond simply confirming that backup jobs complete successfully. A backup that completes without errors but whose data cannot actually be restored is not a backup — it is a false sense of security. Automated recovery tests restore backup data to isolated test environments and run a suite of validation checks to confirm that the restored data is consistent, complete, and usable. For Tier 1 Critical systems, automated recovery testing is conducted monthly. For Tier 2 High systems, it is conducted quarterly. For Tier 3 Medium systems, it is conducted semi-annually. The results of all automated recovery tests are reported in the security dashboard and any test failures are escalated as high-priority issues for immediate investigation and remediation.

Backup access controls are as important as the technical aspects of the backup infrastructure. Backup data — by definition — contains copies of the company's most sensitive information, often in a form that bypasses the access controls applied to the production systems from which it was taken. Access to backup systems and backup data must therefore be restricted to a small number of named IT Operations personnel with a documented need, must require MFA, must be logged comprehensively, and must be reviewed as part of the quarterly privileged access review. Backup encryption is mandatory: all backup data must be encrypted at rest using AES-256, with encryption keys managed through the company's key management infrastructure and not stored alongside the backup data itself.

### 10.4 Disaster Recovery Testing and Validation

A disaster recovery plan that has never been tested is not a plan — it is a hypothesis. The gap between a documented recovery procedure and the actual ability to execute that procedure under the conditions of a real disaster is consistently underestimated by organisations that do not test regularly. Testing reveals dependencies that were not captured in the documentation, recovery steps that are ambiguous or outdated, configuration drift between production and DR environments that makes recovery scripts fail, and gaps in the skills and knowledge of the

individuals who would need to execute the recovery under time pressure. Regular, realistic DR testing is therefore one of the most important investments the company makes in the resilience of its operations.

The company's DR testing programme operates at three levels of exercise intensity, each providing different types of insight. The Tabletop Exercise is a structured discussion-based scenario in which the crisis management team and key technical staff walk through a simulated disaster scenario, discussing what they would do at each decision point and what the expected outcomes would be, without actually executing any recovery actions. Tabletop exercises are low-cost to run, require minimal disruption to operations, and are valuable for testing decision-making processes, escalation paths, and communication protocols. They are conducted twice per year. The Partial Simulation exercise executes specific recovery procedures in an isolated test environment, validating the technical accuracy of the documented procedures and the ability of the IT Operations team to execute them. Partial simulations are conducted quarterly for Tier 1 systems. The Full Recovery Test exercises the complete recovery of one or more systems from backup, including the restoration of data, the reconfiguration of the system environment, the validation of connectivity to dependent systems, and the confirmation that the recovered system meets security requirements before being notionally returned to service. Full recovery tests are conducted annually for all Tier 1 and Tier 2 systems.

DR test results are documented in a test report that captures: the scenario tested, the specific recovery procedures executed, the actual recovery time achieved versus the defined RTO, the actual data currency achieved versus the defined RPO, any issues encountered during the test, and the remediation actions required to address those issues. Test reports are reviewed by the ISM and the CTO, and are presented to the IT Security Steering Committee at the subsequent quarterly meeting. Outstanding remediation actions from previous tests are tracked in the IT Security risk register and their resolution is monitored. The company publishes the results of DR tests — including both the successes and the failures — to the IT Security Steering Committee and the Board with full transparency. A culture of honesty about testing results, including the willingness to document and address failures without minimisation, is essential to the credibility and effectiveness of the DR programme.

## 11. Compliance, Audit, and Policy Management

### 11.1 Compliance Monitoring Framework

Compliance with this policy and with the broader information security requirements of applicable law, contractual obligations, and the company's ISO/IEC 27001:2022 ISMS is monitored through a layered programme of automated technical monitoring, scheduled internal audits, external assessments, and management reporting. The monitoring framework is designed to provide the IT Security Steering Committee and the CTO with timely, accurate, and actionable visibility of the company's compliance posture — not to produce compliance theatre in which activities are optimised to satisfy auditors rather than to produce actual security outcomes.

Continuous automated compliance monitoring operates through the company's CSPM platform, the vulnerability management infrastructure, the MDM platform, the SIEM, and a set of custom compliance scripts that verify specific configuration and process requirements on a scheduled basis. Together these systems generate daily compliance data across hundreds of individual controls, which is aggregated into the compliance dashboard maintained by the IT Security team. The dashboard summarises the current compliance status against each major control category, tracks trend data to show whether compliance is improving or deteriorating over time, and highlights the specific controls where the gap between current state and required state is largest. This dashboard is the primary input to the weekly security briefing that the ISM provides to the CTO.

Quarterly internal security audits are conducted by a dedicated internal audit function that is independent of the IT Operations and IT Security teams, reporting directly to the CFO. The audit function uses the ISO/IEC 27001:2022 Annex A control set as its primary audit framework, supplemented by the PCI DSS requirements for applicable workloads and the specific contract provisions of the company's major clients. Each quarterly audit focuses on a different subset of controls, ensuring that the full control set is covered over the course of a year. Audit findings are classified by severity — Critical, High, Medium, and Low — and are reported to the IT Security Steering Committee within ten working days of the audit's completion. Critical and High findings require a documented remediation plan within 30 days of the finding being issued.

External assessments provide an independent and objective evaluation of the company's security posture from parties who have no stake in its outcome. The annual ISO/IEC 27001:2022 surveillance audit, conducted by an NABCB-accredited certification body, reviews the ongoing effectiveness and compliance of the ISMS and produces a formal audit report with any Non-Conformities and Observations. Non-Conformities — findings of non-compliance with the ISO 27001 standard — must be addressed within 90 days and evidenced to the certification body. The annual penetration test, conducted by an independent specialist firm under a formal statement of work, attempts to compromise the company's external perimeter, internal network, and key applications through all realistic attack techniques. The penetration test report provides

a candid, evidence-based assessment of the actual exploitability of the company's environment that technical monitoring alone cannot replicate.

| Assessment Activity | Frequency | Conducted By | Scope | Output | Reporting To |
|---|---|---|---|---|---|
| Automated compliance monitoring | Continuous | CSPM / MDM / SIEM platforms | All in-scope cloud and device systems | Daily compliance dashboard | ISM weekly to CTO |
| Vulnerability scanning — external | Monthly | IT Security using approved scanner | All internet-facing IP addresses and DNS names | Vulnerability report with CVSS scores | ISM to CTO for remediation tracking |
| Vulnerability scanning — internal | Quarterly | IT Security | All internal network segments | Vulnerability report with remediation priorities | ISM to Steering Committee |
| Penetration test — external | Annual | Independent specialist firm | External perimeter and all internet-facing applications | Full penetration test report | CTO, Steering Committee; Board Summary |
| Penetration test — internal | Annual | Independent specialist firm | Internal network; privileged escalation paths | Full penetration test report | CTO, Steering Committee |
| ISO 27001 surveillance audit | Annual | NABCB-accredited certification body | Full ISMS scope — all five sites | Audit report; Non-Conformities | CTO, Board |
| Internal security audit | Quarterly | Internal Audit function (independent) | Rotating subset of ISO 27001 Annex A controls | Audit report with findings and recommendations | CISO, Steering Committee |
| Access rights review | Quarterly (standard); Monthly (privileged) | IT Security + Line Managers | All user and service accounts | Access recertification report; revocation actions | ISM to line managers |
| Firewall rule review | Bi-annually | IT Security + IT Operations | All active firewall rule sets | Cleaned rule set; removed rules log | Steering Committee |
| DR test | Annually (full); Quarterly (partial) | IT Operations + ISM | Tier 1 and Tier 2 systems | DR test report with RTO/RPO actuals | CTO, Steering Committee |
| Vendor security review | Annually (Tier 2); Semi-annually (Tier 1) | ISM | All Tier 1 and Tier 2 vendors | Updated vendor risk register | ISM to relevant contract manager |
| Security culture survey | Annual | ISM (anonymous, confidential) | All employees | Culture survey report with trend analysis | Steering Committee; SVPs |

### 11.2 Security Metrics and KPIs

The IT Security Steering Committee reviews a defined set of security KPIs at each quarterly meeting. These KPIs are the primary instrument through which the Steering Committee assesses whether the security programme is performing as intended and whether changes in investment or priority are warranted. The KPIs cover both the effectiveness of security controls — are the controls working as designed? — and the performance of the security programme — are security processes being executed as required? The KPIs are designed to be meaningful measures of actual security outcomes rather than measures of activity. Running a monthly vulnerability scan is activity. The percentage of Critical vulnerabilities remediated within the 72-hour SLA is an outcome measure.

| KPI Category | KPI | Target | Current (Q4 2023) | Trend | Owner |
|---|---|---|---|---|---|
| Vulnerability Management | Critical vulnerability patch compliance within 72-hour SLA | 100% | 96% | Improving | IT Operations |
| Vulnerability Management | High vulnerability patch compliance within 7-day SLA | 98% | 94% | Stable | IT Operations |
| Vulnerability Management | Mean time to remediate Critical findings (days) | < 1.5 days | 1.8 days | Improving | IT Operations |
| Access Control | Leaver account deactivation within 1 business day | 100% | 98% | Stable | IT Operations + HR |
| Access Control | Quarterly access review completion rate | 100% | 91% | Improving | IT Security + Line Managers |
| Training | Mandatory security training completion rate | 100% | 93% | Improving | ISM + HR |
| Phishing Simulation | Monthly phishing simulation click rate | < 5% | 7.2% | Improving (was 12% in Q1) | ISM |
| Incident Response | Mean time to detect (hours, P1 and P2 incidents) | < 4 hours | 2.1 hours | Stable | ISM + MDR provider |
| Incident Response | Mean time to contain (hours, P1 and P2 incidents) | < 8 hours | 5.4 hours | Improving | ISM |
| Cloud Security | Cloud CSPM security posture score (average across accounts) | ≥ 85 | 81 | Improving | IT Security |

| KPI Category | KPI | Target | Current (Q4 2023) | Trend | Owner |
|---|---|---|---|---|---|
| Patch Management | Endpoint OS patch compliance (current minus max 1 release) | ≥ 95% | 97% | Stable | IT Operations |
| Audit | Internal audit findings (Critical/High) closed within 30 days | 100% | 87% | Improving | ISM + relevant BU |

### 11.3 Policy Management and Document Control

This policy and all subsidiary security standards and procedures are subject to a formal document control process that ensures they are authoritative, current, accessible, and version-controlled. Every security policy document is assigned a unique document reference number, a version number, an owner, an approver, an effective date, and a next review date. Changes to any security policy document — however minor — must be approved by the document owner and, for material changes, by the CTO before the updated version takes effect. Minor editorial corrections that do not change the substance of any requirement may be approved by the ISM alone. The document management system maintains a complete version history for all security policy documents, allowing any previous version to be retrieved for audit purposes or to resolve disputes about what the policy required at a specific point in time.

Security policy documents are distributed to all employees through the HRMS portal and the IT Security intranet page. Employees receive a notification through HRMS whenever a new version of a policy document that applies to them takes effect. All employees are required to acknowledge receipt and understanding of any security policy document that has materially changed since their previous acknowledgement. Acknowledgements are recorded in the HRMS learning management system and are retrievable for audit and HR purposes. Employees who do not submit required policy acknowledgements within ten working days of being notified are escalated to their line manager and HRBP.

The annual policy review cycle is coordinated by the ISM in the fourth quarter of each calendar year, timed to incorporate the findings of the annual penetration test, the internal audit findings from the most recent quarter, the results of the annual information security risk assessment, and any material changes in the legal and regulatory environment. Each policy document owner reviews their document against current practice, current risk profile, and any external changes in requirements, and proposes updates. Updates are reviewed by the ISM, Legal, and — where they affect employee obligations — HR, before being presented to the CTO for approval. The updated policy suite takes effect on 1 January of the new year, providing a clean annual cycle.

## 12. Secure Software Development Lifecycle

### 12.1 SSDLC Framework and Principles

The security of the software that Arjun Technologies develops and delivers for its clients is the most direct expression of the company's security competence and the most direct source of security risk in its client-facing operations. A vulnerability in software delivered to a client is not merely an IT Security problem for the company — it is a problem that the client will experience directly, in their production environment, affecting their customers and their operations. For clients in regulated sectors, a vulnerability in company-delivered software can expose them to regulatory sanctions. For clients in financial services, it can expose them to financial fraud. For clients in healthcare, it can expose patient data. The Secure Software Development Lifecycle is the company's systematic approach to ensuring that security is designed into every piece of software from its earliest conception, not bolted on as an afterthought after the development is complete.

The SSDLC integrates security activities into every phase of the standard software development lifecycle — requirements, design, development, testing, deployment, and maintenance — in a way that is proportionate to the risk profile of the software being built. High-risk software — systems that process regulated personal data, authenticate users, handle financial transactions, or interface with critical client infrastructure — is subject to the full complement of SSDLC requirements, including formal threat modelling, design review by the IT Security team, code review with specific focus on security, dynamic application security testing, penetration testing prior to production deployment, and a formal security sign-off from the ISM before the system goes live. Lower-risk software — internal tools with no exposure to sensitive data or external attackers — is subject to a lighter-touch set of requirements that focuses on the most impactful controls without the overhead of the full enterprise SSDLC process.

The OWASP Top 10 Web Application Security Risks is the primary reference framework for understanding and preventing the most common categories of software vulnerability in web applications and APIs. All developers working on web applications or REST APIs must have completed the SEC-201 Secure Coding Fundamentals training module and must demonstrate familiarity with each of the OWASP Top 10 categories: injection attacks, broken authentication, sensitive data exposure, XML external entity injection, broken access control, security misconfiguration, cross-site scripting, insecure deserialization, using components with known vulnerabilities, and insufficient logging and monitoring. The ISM updates the company's internal secure coding guidelines annually to reflect the current OWASP Top 10 and any additional vulnerability categories relevant to the company's specific technology stack.

Threat modelling is the process of systematically identifying the security threats that are relevant to a specific system or application, assessing the potential impact of each threat, and designing mitigations into the system architecture before development begins. For high-risk systems,

threat modelling is a mandatory SSDLC activity conducted jointly by the system architect, the lead developer, and the IT Security Business Partner during the design phase. The threat model is documented using the STRIDE methodology — Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — and the documentation is retained as part of the system's security architecture record. Threats identified in the threat model that cannot be fully mitigated by design must be documented as accepted residual risks, reviewed by the ISM, and included in the project's risk register.

### 12.2 Security in the Development Environment

The development environment — the set of tools, systems, and processes through which code is written, reviewed, tested, and deployed — is itself a security-sensitive environment that must be managed with appropriate controls. Compromise of the development environment is a particularly dangerous category of attack because it offers an attacker the opportunity to introduce malicious code into software that will subsequently be deployed to production systems or delivered to clients. The security of the development environment is not a question of trust in the individual developers who work within it — it is a question of ensuring that the technical controls are robust enough that a compromise of any individual developer's credentials or workstation does not automatically translate into a compromise of the entire software supply chain.

All source code repositories are hosted in the company's GitHub Enterprise organisation, which is managed with SSO, MFA, and branch protection rules enforced on all default and release branches. Branch protection rules require a minimum of two approving code reviews from named developers who are members of the relevant team before a pull request can be merged, preventing any individual developer from unilaterally pushing changes to the main or release branches. The code review process must include at least one reviewer who has completed the SEC-201 Secure Coding Fundamentals training and who specifically reviews the change for security implications — not only for functional correctness and code quality. Pull request reviews that do not include a security-focused review from a qualified reviewer cannot be approved as meeting the SSDLC security review requirement.

Automated security scanning is integrated into the CI/CD pipeline as a mandatory gate — builds that fail security scanning checks cannot be deployed to any environment, including development and test environments, until the security findings are addressed. The automated scanning pipeline includes three primary categories of checks: Static Application Security Testing, which analyses the source code itself for patterns associated with known vulnerability categories; Software Composition Analysis, which scans the dependency tree of the application to identify known vulnerabilities in third-party libraries and open-source components; and Secret Scanning, which detects API keys, passwords, connection strings, and other sensitive values that should not be present in code. Each category of check produces a finding report with

findings classified by severity. Critical and High-severity findings are blocking — they must be remediated before the build can proceed. Medium and Low findings are non-blocking but must be reviewed and documented within 72 hours of the build.

| SSDLC Phase | Mandatory Security Activities | Responsible Party | Artefact Produced | High-Risk Amplification |
|---|---|---|---|---|
| Requirements | Security and privacy requirements gathering; abuse case development; regulatory mapping | Business analyst + Security Champion | Security requirements section in user story; abuse case library | Missing abuse cases for payment or authentication features |
| Design | Threat modelling (STRIDE); security architecture review for new components | Architect + Security Champion | Threat model document; architecture review sign-off | Skipping threat modelling for "small" changes that touch auth or data |
| Development | Secure coding standards compliance; pre-commit secrets scanning | Developer | Code that meets standards; no secrets in repository | Developers bypassing pre-commit hooks with --no-verify |
| Code Review | Security-focused code review by qualified reviewer; SAST triage | Peer developer + Security Champion | Approved PR with documented SAST finding resolutions | Rubber-stamp reviews without genuine security scrutiny |
| Testing | DAST against running application; dependency vulnerability report review | QA engineer + Security Champion | DAST report; penetration test scope agreement | Testing only the happy path; no negative or boundary testing |
| Pre-Production | Penetration test or security assessment for Critical/High findings; SAST/SCA sign-off | External tester + Security Champion | Penetration test report; remediation evidence | Deploying with unresolved Critical findings under time pressure |
| Production & Maintenance | Continuous monitoring for new vulnerabilities in deployed dependencies | Security tooling + Development team | Vulnerability alerts; patched dependency releases | Delayed patching of known vulnerabilities in production systems |

### 12.3 Open Source and Third-Party Component Management

Modern software development is built on a foundation of open-source libraries, frameworks, and components. A typical enterprise web application may have hundreds or thousands of direct and transitive dependencies — other projects' code that is incorporated into the application and executed alongside the company's own code. This dependency model is enormously productive, allowing developers to build on existing, tested solutions rather than implementing every capability from scratch. It is also, however, a significant security risk: a vulnerability in a widely used open-source library can affect thousands of applications simultaneously, and the pace of vulnerability discovery in open-source components has increased steadily over recent years. The SolarWinds and Log4Shell incidents demonstrated the scale of impact that a single compromised or vulnerable component can have across the software industry.

The company's Software Composition Analysis programme continuously monitors the dependency trees of all company-developed applications for known vulnerabilities in incorporated open-source and third-party components. SCA is integrated into the CI/CD pipeline as described in Section 12.2, and additionally runs on a nightly schedule against all deployed applications to detect newly disclosed vulnerabilities in components that may have been incorporated before the vulnerability was known. When a new vulnerability is disclosed in a component used by a company application, the SCA tooling generates a finding classified by the CVSS severity of the vulnerability. Critical and High severity findings in production applications trigger the vulnerability remediation SLA process described in Section 5.2 of Segment 1 — these are treated as infrastructure vulnerabilities for remediation prioritisation purposes, because their exploitability and potential impact are equivalent.

The use of open-source components is governed by both security requirements and licence compliance requirements. From a licence compliance perspective, developers must verify that the licence of any open-source component they incorporate into a company or client product

permits the intended use — some open-source licences, including the GPL family, impose conditions on how software that incorporates them can be distributed that may be incompatible with the company's commercial obligations to clients. The SCA tooling includes a licence scanning capability that flags components with licences that are on the company's prohibited or restricted list. The Legal team maintains the licence policy and the list of prohibited and restricted licences. Components with prohibited licences must not be incorporated into any commercial deliverable. Components with restricted licences require Legal sign-off before incorporation.

### 12.4 Secure Deployment and Infrastructure as Code Security

The deployment of software from development through testing environments to production is a point in the delivery lifecycle at which security controls are frequently weakest and security incidents are disproportionately common. Deployment pipelines — the automated systems that build, test, and release software — are high-value targets for attackers because a compromise of the pipeline allows malicious code to be introduced into production without any individual developer having intentionally written it. Protecting the security of the deployment pipeline is therefore as important as protecting the security of the source code itself, and the security requirements that apply to the deployment infrastructure are among the most stringent in the SSDLC.

All deployment pipeline configurations — the CI/CD pipeline definitions, the infrastructure as code templates, the Kubernetes manifests, and the container configurations — are stored in version-controlled repositories and subject to the same code review and security scanning requirements as application source code. No deployment configuration change may take effect in production without having been committed to version control, reviewed by a qualified reviewer, and passed through the automated security scanning gate. The concept of immutable infrastructure — deploying pre-built, pre-tested, pre-scanned artefacts to production rather than applying configuration changes to live systems — is the company's preferred deployment pattern, because it makes every production state fully reproducible, auditable, and consistent with the verified artefacts that passed security scanning.

Container security deserves specific attention because containers have become the dominant deployment model for the company's cloud workloads. Container images — the packaged artefacts from which containers are run — must be built from approved base images that are maintained and patched by the IT Security team, must pass a container image vulnerability scan before being pushed to the company's container registry, and must be scanned again at runtime for newly disclosed vulnerabilities in the components they contain. Container workloads must run with the minimum necessary permissions — specifically, containers must not run as root unless there is a documented and ISM-approved business requirement, must not have access to the host network namespace unless required, and must be prevented from escalating their

own privileges through security context controls applied at the Kubernetes pod specification level.

## 13. Data Loss Prevention

### 13.1 DLP Programme Overview and Architecture

The Data Loss Prevention programme at Arjun Technologies is designed to prevent the unauthorised or accidental transmission of sensitive information — particularly client personal data, proprietary source code, financial records, and commercially sensitive business information — outside the company's controlled information environment. DLP operates as a detective and preventive control layer that monitors data in motion across company communication channels, data at rest in company storage systems, and data in use on company endpoints, and applies policy-based rules to identify potential policy violations and either block them automatically or route them for review.

The DLP architecture operates across three vectors that together cover the primary pathways through which sensitive data can leave the organisation's control. DLP for data in motion monitors and controls outbound data flows through the email gateway, the web proxy, and API endpoints. When an outbound email or file upload contains patterns matching the DLP rule set — credit card numbers in sequence, combinations of fields consistent with personal data records, source code signatures, or any other pattern defined in the current rule set — the DLP engine applies the appropriate policy action: block the transmission and notify the sender, quarantine the message for review by the sender's manager and the ISM, or allow the transmission but log it for subsequent audit review. DLP for data at rest scans the contents of company-managed file storage systems, SharePoint sites, and cloud storage repositories on a scheduled basis to identify files that are stored in locations inconsistent with their classification level — for example, a file containing client personal data stored in a general shared folder rather than in an access-controlled client-specific repository.

DLP policies are developed collaboratively between the ISM, Legal, and the relevant business unit leads. The policy development process begins with a data discovery exercise that maps the types of sensitive data most commonly created and handled by each business unit, identifies the legitimate business processes that require the transmission of that data externally, and designs DLP rules that accurately distinguish between legitimate business transmissions and policy violations. Poorly calibrated DLP policies — those with high false positive rates that block or flag large volumes of legitimate business communication — erode employee confidence in the programme and create pressure to bypass or disable the controls. The company invests significant effort in calibrating DLP policies through a tuning period when new rules are first deployed, initially in monitor-only mode before switching to blocking or quarantine mode only when the false positive rate has been reduced to an acceptable level.

DLP incident management follows a defined process. When the DLP system generates an alert or a quarantine event, the IT Security team reviews the alert within four hours during business hours. Where the alert reflects a genuine policy violation, the ISM investigates the

circumstances — was the transmission accidental, was it the result of misclassification of the data, or was it deliberate? — and takes appropriate action, which may range from an educational conversation with the employee to a referral to HR for disciplinary action depending on the nature and severity of the violation and the employee's intent. Where the alert is a false positive, the ISM documents it and uses the data to refine the DLP rule. All DLP incidents, including false positives, are logged and the aggregate data is reviewed monthly to identify patterns that suggest gaps in the data classification training programme or in the DLP rule set.

### 13.2 DLP Rules and Sensitive Data Patterns

DLP rules are defined for the sensitive data categories most commonly handled by Arjun Technologies and its client engagements. Each rule is described by the data pattern it detects, the threshold at which detection is triggered, the transmission contexts to which the rule applies, and the policy action taken when the rule fires. Rules are reviewed quarterly by the ISM and updated to reflect changes in the types of sensitive data the company handles, changes in the threat landscape, and lessons learned from DLP incident investigations.

| Rule Name | Data Pattern Detected | Trigger Threshold | Applies To | Policy Action | Review Owner |
|---|---|---|---|---|---|
| PAN Data Detection | Primary Account Number pattern (credit/debit card numbers) | 1 or more PANs in a single transmission | Email, web upload, USB, personal cloud sync | Block; alert ISM and sender | ISM + Finance |
| Aadhaar Number Detection | 12-digit Aadhaar number pattern with valid checksum | 1 or more Aadhaar numbers in a single transmission | Email, web upload, USB | Block; alert ISM; quarantine for review | ISM + Legal |
| PAN Card Number Detection | Indian Permanent Account Number format (AAAAA9999A) | 1 or more PANs in a single transmission | Email, web upload | Block; alert ISM | ISM + Legal |
| Bulk Personal Data | Multiple instances of names + email addresses + phone numbers | 50 or more records in a single transmission | Email, web upload, cloud storage | Quarantine for review; alert ISM | ISM + relevant HRBP |
| Source Code Exfiltration | Known source code signatures (function declarations, class structures) | Any match in a single transmission | Email, USB, personal cloud sync, web upload | Block; alert ISM and CTO | ISM + CTO's primary tech s |
| Financial Data — Revenue/Profit | Keywords and patterns indicating financial statement data (Revenue, EBITDA, profit/loss figures) | Any match in a single transmission | Email, web upload, cloud storage | Quarantine for review; alert CFO and ISM | ISM + CFO |
| Client Confidential Marker | Documents labelled 'Confidential', 'Restricted', or 'Client Name' | Any match in a single transmission | Email, web upload, USB | Block and alert ISM; allow if to approved client domain with ISM approval | ISM + account manager |
| Password and Secret Patterns | High-entropy strings consistent with API keys, database passwords, or private keys | Any match in a single transmission | Email, web upload, cloud storage, USB | Block immediately; alert ISM and IT Security | ISM + IT Security |
| Employee Personal Data | Employee name + salary or employment history | Any combination of 2 or more data elements | Email, web upload, cloud storage | Quarantine for review; alert HRBP and ISM | ISM + HRBP |

### 13.3 Endpoint Data Controls

Endpoint-level DLP controls address data loss pathways that are not captured by network-level monitoring — primarily the copying of sensitive data to removable storage media, the printing of sensitive documents to non-secure printers, and the use of unauthorised applications to access or transmit sensitive data locally on the endpoint. These controls are enforced through the endpoint management platform and the EDR agent deployed on all company-managed devices.

Removable media controls restrict the ability to copy data to USB drives, external hard disks, and other removable storage. By default, all removable media connections on company endpoints are blocked. An employee who has a legitimate business need to transfer data to removable media must request a temporary exemption through the IT Service Desk, specifying the purpose, the data to be transferred, and the destination. The IT Security team reviews the

request and, if approved, grants a time-limited and logged exemption that permits the specific transfer. All data transferred to approved removable media must be encrypted using the company's approved encryption solution. The use of personal USB drives that do not support hardware encryption on company devices is prohibited.

Screen capture and local copy controls monitor for unusual patterns of screenshot activity or clipboard operations that may indicate an attempt to capture sensitive on-screen data for transmission through an unmonitored channel. These controls operate in conjunction with the DLP system's monitoring of the cloud upload and email channels — an employee who attempts to circumvent email-level DLP by taking screenshots of sensitive data and transmitting the screenshots rather than the original files will trigger both the screen capture monitoring and the image-based DLP scanning applied to image uploads. The ISM is notified of any pattern of screenshot activity that is anomalous relative to the employee's normal usage baseline.

### 13.4 DLP Governance and Employee Communication

The effectiveness of the DLP programme depends not only on the technical accuracy of its rules but on employees understanding what the programme does, why it exists, and how to work with it rather than around it. An employee who encounters a DLP block when attempting a legitimate business transmission and does not know why the block occurred or how to get it reviewed will experience the DLP system as an opaque and arbitrary obstacle, and may find ways to accomplish the same transmission through unmonitored channels. Transparency about DLP — explaining to employees what is monitored, what triggers an alert or a block, and what the review process involves — produces better outcomes than treating DLP as a covert surveillance system.

Employees are informed of the DLP programme through the SEC-104 Data Classification and Handling training module and through the Acceptable Use Policy. When a DLP system blocks or quarantines an outbound transmission, the sender receives an immediate notification through their email client or the web proxy page that explains that the transmission has been held, provides the general category of rule that was triggered, and gives instructions for requesting a review if the transmission is believed to be legitimate. The review request is submitted to the IT Security team through the Service Desk. Reviews are completed within two business hours for Priority 1 requests — where the transmission delay has a material impact on a client-facing commitment — and within one business day for standard requests.

DLP programme performance is measured and reported monthly. Key metrics include the total volume of DLP events, the breakdown by rule category and policy action, the false positive rate for each rule, the average time to review quarantined transmissions, and the number of confirmed DLP policy violations identified. The ISM presents DLP performance data to the IT Security Steering Committee quarterly, alongside any material policy violations identified and the

actions taken. Where DLP data identifies a pattern of accidental policy violations in a specific team or business unit — suggesting a gap in awareness or process rather than deliberate misconduct — HR and the relevant manager are informed so that targeted awareness or training interventions can be designed.

## 14. Physical and Environmental Security

### 14.1 Physical Security Perimeter

The physical security perimeter of Arjun Technologies's offices is the first line of defence in the information security framework. An attacker who gains physical access to company premises has the opportunity to interact directly with unattended workstations, install hardware-based surveillance or attack devices, access printed documents, remove storage media, and observe or record sensitive on-screen information. Physical security controls are therefore not a facilities management concern separate from information security — they are an integral component of the ISMS, designed and maintained with the same systematic risk management approach as technical controls.

All company premises operate within a defined physical security perimeter that is enforced through a combination of architectural barriers, access control systems, visual monitoring, and security personnel. The perimeter is reviewed annually by the ISM and the Administration team as part of the information security risk assessment, and any changes to the physical layout of office premises — including office renovations, expansions, or the introduction of shared co-working spaces — must be reviewed by the ISM before they take effect to ensure that the physical security perimeter remains intact and that any new access pathways created by the physical change are appropriately controlled.

The company employs or contracts security personnel at its Bengaluru headquarters and at the Hyderabad office, the two largest locations. Security personnel are responsible for managing reception, verifying visitor identity and registering visitors, monitoring CCTV feeds, conducting regular perimeter patrols during and after business hours, and responding to physical security alerts. Security personnel are trained in the company's physical security procedures, visitor management requirements, and emergency response procedures before being deployed. The company's physical security personnel contracts require background verification of all security staff, and the Administration team conducts periodic audits of the physical security personnel provider's compliance with this requirement.

After-hours physical security is maintained through a combination of automated systems and regular security patrols. CCTV cameras with motion detection are active in all office areas, server rooms, and perimeter access points on a 24/7 basis. Motion-triggered alerts are sent to the on-duty security personnel and to the ISM's emergency contact for any after-hours access or motion event in a high-security zone. The physical access control system logs all after-hours access events and generates a report that is reviewed by the Administration team each business morning. Any access event that cannot be attributed to a legitimate business activity — an authorised after-hours project, a maintenance window, or other pre-approved activity — is escalated to the ISM and the relevant manager for investigation.

### 14.2 Secure Areas and Equipment Protection

Within the physical perimeter, certain areas require enhanced controls because of the sensitivity of the information or equipment they contain. Server rooms and network infrastructure rooms are the highest-security physical spaces in the company's offices. They contain the servers, network equipment, and communication infrastructure on which the entire company's operations depend, and a physical compromise of these spaces — through equipment theft, the installation of rogue network devices, or deliberate physical damage — would be as devastating as a major cyber attack. Server rooms are therefore protected by access controls additional to the main office access control system, typically including a separate keycard or combination of keycard and biometric authentication. Entry is restricted to named members of the IT Operations team and the ISM. All access events are logged in real time.

Equipment protection standards apply to all company-owned technology assets at all locations. Fixed equipment — desktop computers, servers, network devices, and other equipment that is not designed to be portable — must be secured to fixed surfaces using appropriate anti-theft cable locks or fixed mounts where the form factor permits. Portable equipment — laptops, mobile phones, tablets, and external drives — must not be left unattended in publicly accessible areas, vehicles, or any space where they are visible and physically accessible to unauthorised persons. All portable equipment must be returned to a secured location — a locked office, a locked drawer, or a locked cabinet — when not in active use.

Environmental controls in server rooms and network infrastructure spaces are managed by the Facilities team with technical oversight from IT Operations. The environmental requirements for these spaces include temperature and humidity control within the ranges specified by the hardware manufacturers, uninterruptible power supply systems to protect against short power interruptions, automatic transfer switches or generator backup for extended power outages at the Bengaluru headquarters, fire suppression systems appropriate for electronics environments, and water leak detection systems. Environmental monitoring sensors generate alerts when readings deviate outside defined thresholds, and these alerts are monitored by the IT Operations on-call engineer. IT Operations conducts quarterly environmental systems checks and maintains maintenance logs.

### 14.3 Clean Desk and Clear Screen Policy

The clean desk and clear screen policy is one of the simplest and most cost-effective physical security controls available, and one of the most consistently underestimated. A workstation left logged in and unattended, or a desk covered with printed documents containing client data, is a security vulnerability that no technical control can compensate for. The policy requires that every employee ensures their workstation and physical workspace meet defined security standards whenever they leave their desk — whether for a brief meeting, a comfort break, or at the end of the working day — and that they return their workspace to a secure state before departing.

The clean desk requirements state that all physical documents — regardless of classification level — must be removed from desktops, work surfaces, and meeting room tables at the end of every working day and whenever the workspace will be unattended for more than 30 minutes. Documents classified at the Confidential or Restricted level must be stored in locked drawers or cabinets when not in active use and must never be left visible on an unattended desk at any time during the working day. Removable storage media, access tokens, and physical authentication devices must be secured in locked storage when not in active use. Whiteboards containing Confidential or Restricted information must be erased before meeting rooms are vacated, and the erasing obligation falls on the last person to leave the room.

Clear screen requirements mandate that all workstations must be locked — using the operating system's keyboard shortcut or screensaver lock — immediately upon the user leaving the workstation, regardless of how brief the absence is intended to be. The workstation must not be left in an unlocked state while the user is absent. Screensaver-based auto-lock is configured on all company workstations to activate after a maximum of five minutes of inactivity as a backstop control, but this auto-lock is a failsafe rather than a substitute for the manual lock obligation. In shared or open-plan working environments, users must additionally be aware of shoulder surfing — the observation of on-screen information by passers-by — and should position their screens to minimise the angle at which screen content is visible to anyone other than the authorised user.

### 14.4 Visitor Management and Escorting Procedures

All visitors to company premises — including clients, candidates, vendors, auditors, regulatory inspectors, maintenance contractors, and the personal guests of employees — are subject to the visitor management procedure. The procedure exists to ensure that the identities of all visitors are recorded, that visitors do not have unsupervised access to company systems or sensitive information, and that the company maintains an accurate record of who was on its premises at any given time, which may be required in the event of a physical security incident or a regulatory inspection.

Visitor registration must be completed at the reception desk of the relevant office before the visitor enters beyond the reception area. Registration requires the visitor to provide their full name, the organisation they represent, the name of the company employee they are visiting, the purpose of their visit, and a contact phone number. The visitor's identity must be verified against a government-issued photo ID — Aadhaar card, passport, PAN card, or driving licence — and a copy of the ID page is retained in the visitor log for 30 days. The visitor is issued a visitor badge that must be worn visibly at all times on the company's premises. The visitor badge has a different visual design from employee badges and clearly identifies the holder as a visitor rather than an employee.

Visitors must be accompanied by an authorised employee at all times in office areas beyond the reception and public meeting rooms designated for visitor use. The accompanying employee is personally responsible for the visitor's conduct during the visit, for ensuring that the visitor does not access any area of the premises for which they are not specifically authorised, and for ensuring that the visitor does not interact with company equipment, printed documents, or systems without explicit authorisation. At the conclusion of the visit, the accompanying employee must ensure that the visitor returns their badge to reception and signs out of the visitor log. Visitors who are found to be unescorted in non-public office areas are to be politely redirected by any employee who encounters them, who should also notify security personnel and the reception desk.

## 15. Cryptography and Key Management

### 15.1 Cryptographic Policy

Cryptography is the mathematical foundation of information security — it is the mechanism through which data is protected against unauthorised disclosure during transmission and storage, through which the authenticity of digital communications and documents is verified, and through which the integrity of data is confirmed. The company's cryptographic policy defines the approved algorithms, key lengths, and implementation standards for all cryptographic uses within the organisation. Using cryptographic algorithms or key lengths that are not on the approved list — either because they are obsolete and have known weaknesses, or because they are experimental and have not been validated by the cryptographic community — is prohibited regardless of the perceived convenience or performance advantage.

The approved cryptographic algorithms and key lengths for use in company systems are as follows. For symmetric encryption — the protection of data at rest — AES with 256-bit keys (AES-256) is the mandatory standard for all Confidential and Restricted data. AES-256 is currently computationally unbreakable with any known technology and is expected to remain so in the foreseeable future, including in the post-quantum threat environment. For asymmetric encryption and digital signatures — used in TLS, code signing, email signing, and authentication protocols — RSA with a minimum key length of 4096 bits is approved; Elliptic Curve Cryptography with the NIST P-256 curve or higher is the preferred alternative offering equivalent security with significantly shorter key lengths. For hashing — used in password storage, integrity verification, and digital signatures — SHA-256 and SHA-3 are approved. SHA-1 and MD5 are explicitly deprecated and must not be used for any new implementation; existing uses must be migrated on a timeline approved by the ISM.

Protocols that incorporate cryptography are held to the same standards. TLS version 1.2 is the minimum approved version for all encrypted communications. TLS 1.3 is the preferred standard and is required for all new implementations. TLS 1.0 and TLS 1.1 are deprecated and must not be used. SSL in any version is prohibited. Where legacy systems or client requirements create a dependency on older TLS versions, a formal exception must be approved by the ISM with a documented remediation timeline. The company's web application firewalls and load balancers are configured to reject connections using TLS versions below 1.2 and to prefer TLS 1.3 where the client supports it.

The selection and implementation of cryptographic controls must always be based on established, peer-reviewed cryptographic primitives and libraries rather than on custom or proprietary cryptographic implementations. The adage 'don't roll your own crypto' is one of the most consistent pieces of advice in the information security community, for good reason — custom cryptographic implementations almost always contain subtle vulnerabilities that only become apparent to specialists under adversarial analysis, and the consequences of a broken

cryptographic implementation are typically far worse than the consequences of a broken access control or input validation: all data ever protected by the broken cryptography must be considered compromised. All cryptographic implementations used in company products and systems must use approved libraries — OpenSSL, libsodium, Bouncy Castle, or the native cryptographic libraries provided by the cloud platforms — with configurations reviewed by a developer with SEC-201 certification or higher.

### 15.2 Key Management Lifecycle

The security of any cryptographic system depends entirely on the security of the cryptographic keys it uses. A system that uses AES-256 encryption — computationally unbreakable with current technology — but stores the encryption key in plain text in the same location as the encrypted data provides effectively zero security, because the attacker can obtain the key and decrypt the data without needing to attack the encryption algorithm itself. Key management — the systematic process of generating, storing, distributing, using, rotating, retiring, and destroying cryptographic keys — is therefore the most operationally critical component of the cryptographic security programme.

Cryptographic key generation must use a cryptographically secure random number generator that produces sufficient entropy to ensure that the generated key cannot be predicted or reproduced by an attacker. On company-managed systems, the OS-provided cryptographically secure PRNG is used for key generation. In cloud environments, the cloud provider's key management service (AWS KMS, Azure Key Vault, or Google Cloud KMS) generates and manages keys using the provider's validated hardware security modules. Keys generated outside an HSM-backed environment for Restricted data use must be approved by the ISM. Keys generated by employees using ad-hoc methods — such as deriving keys from passwords without a proper key derivation function — are not acceptable for any use above Internal Use Only data.

| Key Type | Key Length | Algorithm | Rotation Frequency | Storage Requirement | Backup Requirement | Destruction Meth |
|---|---|---|---|---|---|---|
| AES data encryption keys (Confidential) | 256 bits | AES-256 | Annual; on suspected compromise | Cloud KMS or approved secrets manager | Encrypted backup in separate location | Cryptographic erasure; destroy all copies and |
| AES data encryption keys (Restricted) | 256 bits | AES-256-GCM | Every 90 days; on suspected compromise | HSM-backed KMS only; key never exported in plaintext | HSM-backed backup; split-knowledge recovery procedure | Cryptographic erasure; destroy all HSM key ma |
| TLS server certificates | RSA 4096-bit or ECDSA P-256 | RSA or ECDSA | Annual; on key compromise or CA revocation | Certificate management platform; private key never exported | Encrypted backup of private key and certificate | Certificate revocation; destroy private key; C |
| Code signing certificates | RSA 4096-bit or ECDSA P-256 | RSA or ECDSA | Annual | HSM for production signing keys; separate from TLS keys | HSM key backup; secondary HSM in DR site | Revocation with CA; HSM se |
| SSH keys (developer access) | Ed25519 or RSA 4096 | Ed25519 or RSA | Annual; on role change or suspected compromise | Approved secrets manager for private keys; never stored on shared systems | Private keys not backed up; public keys recorded in authorised_keys files | Remove public key from all authorised_keys fil |
| Service account API keys | 256 bits (service-specific) | Service-specific | Every 90 days; on suspected compromise | Secrets manager; never in source code, configuration files, or environment variables | Encrypted backup of secrets manager vault | Revoke in issuing service; remove from secrets |
| VPN certificates | RSA 4096-bit | RSA | Annual; on CA compromise | Certificate management platform | IT Operations secure backup | CRL update; certificate archival |
| Backup encryption keys | 256 bits | AES-256 | Annual | Air-gapped key store managed by CISO; separate from backup system | Two physically separate encrypted copies in | Cryptographic erasure; destroy all copies in |

### 15.3 Certificate Lifecycle Management

Digital certificates — particularly the TLS server certificates that encrypt communications between users and company web services and APIs — are a specific category of cryptographic asset that requires systematic lifecycle management to prevent the security incidents caused by certificate expiry, revocation, or key compromise. Certificate expiry is a surprisingly common root cause of service outages and security incidents: an expired certificate causes modern web browsers and API clients to reject the connection as untrusted, which can render client-facing services completely unavailable with immediate notice. An expired certificate on an internal service can disrupt authentication systems, monitoring infrastructure, or internal APIs in ways that are difficult to diagnose and that affect multiple dependent services simultaneously.

The company maintains a certificate inventory in the IT Security team's certificate management platform, which records every certificate in use across company systems, the associated domain or service, the issuing Certificate Authority, the issue date, the expiry date, the key type and length, and the responsible system owner. Automated monitoring generates alerts at 60 days, 30 days, 14 days, and 7 days before each certificate's expiry date, providing ample time for renewal under normal circumstances. Renewal must be completed and the new certificate deployed at least 14 days before the expiry date, ensuring that the 7-day alert serves as a backstop rather than a routine working deadline. The IT Security team conducts a quarterly review of the certificate inventory to identify any certificates that have been added to company systems without being registered in the inventory, which is a common gap in certificate management programmes.

Certificate revocation — the process of invalidating a certificate before its expiry date because the associated private key has been compromised, because the certificate was issued to an incorrect identity, or because the certificate is no longer needed — must be executed immediately upon determining that revocation is warranted. Delayed revocation of a compromised certificate leaves the corresponding private key as a valid means of impersonating the company's services or decrypting intercepted communications for the duration of the delay. Revocation is accomplished by submitting a revocation request to the issuing CA, which updates its Certificate Revocation List and its OCSP responder. The revocation must be documented in the certificate inventory with the reason for revocation, the date of revocation, and the name of the person who authorised it. Where revocation affects client-facing services, the Communications team and account managers must be notified immediately to manage any client communications required.

## 16. Security in Human Resources

### 16.1 Pre-Employment Security Screening

Information security risks are not limited to external attackers — insider threats, whether malicious or unintentional, represent a significant and qualitatively different category of risk. An employee who has legitimate system access and a legitimate physical presence in company offices can cause damage that would be technically impossible for an external attacker to replicate, because they operate from a position of trusted access. The company's HR-related security controls are designed to reduce insider threat risk through careful screening of candidates before employment begins, through access controls and monitoring during employment, and through a structured offboarding process that terminates all access cleanly at the end of employment.

Pre-employment background verification is a mandatory condition of employment for all roles, and is described in detail in the Employee Handbook. From an information security perspective, the most relevant components of background verification are identity verification — confirming that the candidate is who they claim to be — and employment history verification — confirming that the candidate's stated work history is accurate. Misrepresentation of employment history, qualifications, or identity is a strong predictor of willingness to engage in other forms of dishonesty during employment, and the company treats such misrepresentation as grounds for withdrawal of the offer or immediate termination if discovered after joining.

For roles that involve access to Restricted data, privileged system access, or significant financial authority, enhanced background verification is conducted in addition to the standard checks. Enhanced verification includes a credit history check — relevant to roles with financial authority because financial distress is a known risk factor for insider fraud — a more detailed criminal record check, and reference conversations that specifically explore any previous concerns about the candidate's honesty, integrity, or compliance with security requirements. Enhanced verification is also applied to roles in the IT Security and IT Operations teams, who have privileged access to the company's security infrastructure, and to senior finance roles who have access to company financial systems.

The company's recruitment process includes specific security awareness assessments for roles in IT Security, IT Operations, and engineering. Candidates for these roles are assessed on their understanding of key security concepts relevant to the role, their approach to security trade-offs, and their response to hypothetical security dilemma scenarios. These assessments are not designed to identify candidates who have memorised security terminology — they are designed to assess practical security judgement and a genuine commitment to security as a professional standard rather than a compliance exercise. Candidates who perform well on these assessments but poorly on technical coding or system administration assessments are not hired — security awareness is a necessary but not sufficient qualification.

### 16.2 Security Obligations During Employment

All employees have ongoing information security obligations that are a condition of employment from their first day to their last. These obligations are established through the employment contract, communicated through mandatory security training, reinforced through the company's security culture programme, and enforced through the disciplinary procedure described in Section 1.6. The security obligations are not additional to the employee's professional responsibilities — they are integral to how those responsibilities are discharged. An engineer who delivers technically excellent code that has serious security vulnerabilities has not fully discharged their professional responsibilities, regardless of how well the code functions.

The most important ongoing employee security obligation is prompt reporting. Every employee is required to report any actual or suspected security incident — including receiving a suspicious email, noticing unusual system behaviour, discovering that they may have inadvertently shared sensitive information with an unauthorised party, or losing a company device — to the IT Security team at security@arjuntech.in immediately upon discovery. The value of prompt reporting in limiting the damage caused by security incidents cannot be overstated. Every hour of delay in reporting gives an attacker in an active breach additional time to expand their access, identify valuable data, and establish persistence mechanisms that make eventual eradication more difficult and more uncertain.

Changes in an employee's personal circumstances that may be relevant to their security risk profile must be disclosed to HR promptly. The security-relevant circumstances that require disclosure are: any criminal conviction, caution, or the commencement of criminal proceedings against the employee; any personal financial distress event including bankruptcy, individual voluntary arrangement, or County Court Judgment; any change in immigration status that affects the employee's right to work; and any new relationship with a competitor, client, or supplier that could create a conflict of interest in relation to the employee's information access. These disclosures are handled confidentially by HR and the response is designed to be supportive rather than punitive — the objective is to understand the changed risk profile and make appropriate adjustments, not to penalise the employee for personal circumstances beyond their control.

### 16.3 Security Offboarding

The offboarding of departing employees is a critical information security process that must be executed completely and promptly. Accounts that remain active after an employee's last working day represent an ongoing vulnerability — the former employee may retain knowledge of passwords from their employment period, and where MFA is linked to a personal device that they have taken with them, they may retain the ability to authenticate. The company's target is complete deactivation of all accounts on the last working day, and the IT Operations team is

notified by HR no later than 24 hours before the employee's last working day to prepare for this.

The offboarding security checklist covers: deactivation of all Active Directory and cloud identity accounts simultaneously at end of business on the last working day; revocation of all VPN certificates and remote access credentials; removal from all security groups and application roles; revocation of all API keys and service account credentials provisioned for the employee's use; removal from the physical access control system; recovery of all company devices including laptops, mobile phones, access tokens, and physical security keys; confirmation from IT Operations that any company data on personal devices enrolled in the BYOD programme has been remotely wiped; and a review of the employee's recent access logs for any unusual activity in the final days of employment that may indicate data exfiltration.

For employees in sensitive roles — particularly IT Security, IT Operations, senior finance, and senior engineering — the offboarding security review includes an analysis of data access and transmission patterns in the 30 days preceding the last working day, specifically looking for indicators of data staging or exfiltration. This is not a punitive process applied only to employees who are suspected of wrongdoing — it is a routine security practice applied consistently to all departures from sensitive roles, informed by the well-documented pattern that the period immediately before an employee's departure is statistically the period of highest insider data exfiltration risk. Findings from the offboarding review that suggest potential data exfiltration are escalated to Legal and HR for investigation before the FnF settlement is finalised.

## 17. Supply Chain Security

### 17.1 Software Supply Chain Risk

The software supply chain — the network of third-party tools, libraries, platforms, and services through which the company's software is built and delivered — has become one of the most significant and rapidly evolving categories of information security risk in the technology industry. High-profile supply chain attacks including the SolarWinds compromise of 2020, the Kaseya VSA attack of 2021, and the Log4Shell vulnerability of 2021 demonstrated that a single compromised component in a widely-used piece of software can simultaneously affect thousands of organisations across multiple sectors, providing attackers with unprecedented scale of access and making attribution and containment exceptionally difficult. The company's software supply chain security programme is designed to reduce the risk of both types of supply chain attack: the compromise of software the company builds and delivers (which could affect clients), and the compromise of software the company uses in its own operations (which affects the company directly).

For software the company delivers to clients, the primary supply chain risk is the incorporation of malicious or vulnerable third-party components into the delivered product. The SCA programme described in Section 12.3 addresses the vulnerability dimension of this risk by continuously scanning for known vulnerabilities in incorporated dependencies. The malicious component risk — where a legitimate open-source package is taken over by a malicious actor who introduces malicious code into a new release, or where a typosquatting package designed to mimic a legitimate package is accidentally incorporated — is addressed through dependency pinning and integrity verification. All dependencies in company-developed software must be pinned to specific, immutable version hashes rather than floating version ranges, ensuring that the exact artifact incorporated into a build is always the one that was reviewed and approved. Where a legitimate open-source maintainer's account is compromised and malicious code is introduced into a new release, dependency pinning ensures that the compromised release is not automatically incorporated into company builds.

For software the company uses in its own operations — including the CI/CD pipeline tools, the build infrastructure, the monitoring and security tooling, and the business application suite — the supply chain risk is managed through the vendor security assessment process described in Section 7 of Segment 1, supplemented by integrity verification of software packages. All software packages installed on company infrastructure must be obtained from trusted, official sources — the official package repositories for each language ecosystem, the official download pages of commercial software vendors, or the company's internal artifact repository which mirrors approved package sources after integrity verification. Packages obtained from unofficial mirrors, file sharing sites, or through peer-to-peer distribution channels must not be installed on company systems regardless of their apparent legitimacy.

Integrity verification for software packages means confirming that the package downloaded matches the authentic release from the legitimate publisher, before installation. This is accomplished through verification of the publisher's digital signature on the package where the publisher provides signed releases, or through hash verification against the officially published hash value where signing is not available. Software packages for which neither signature verification nor hash verification is possible — because the publisher does not provide either — must not be used on company systems without an exception approved by the ISM, because the company cannot confirm that what it has downloaded has not been modified in transit or replaced with a malicious substitute at the download source.

### 17.2 Hardware Supply Chain Controls

Hardware supply chain attacks — the compromise of physical devices through malicious components, firmware modifications, or interception during shipping — represent a lower-probability but potentially very high-impact risk category. An attacker who successfully introduces a malicious hardware component into a server, a network device, or an employee laptop before it reaches the company has the potential to establish a persistent, hardware-level foothold that survives operating system reinstallation, firmware updates, and virtually all software-level security controls. While sophisticated hardware supply chain attacks require significant resources and are primarily associated with nation-state threat actors, the company's hardware procurement controls are designed to reduce the risk to an appropriately low level given the company's threat profile.

All hardware procurement for company infrastructure must go through approved vendors who are enrolled in the company's vendor management programme. The company purchases server and network infrastructure hardware exclusively from authorised resellers and direct vendor channels, never from secondary markets, auction sites, or unverified third-party sellers. For high-value infrastructure components — particularly servers destined for production environments and network devices deployed at perimeter security positions — the company verifies the authenticity of received hardware through the manufacturer's product authentication programme where available, and checks received serial numbers against the manufacturer's warranty registration database to confirm that the device was legitimately produced and has not been reported as diverted or counterfeit.

Firmware security is an important dimension of hardware supply chain security that is frequently overlooked in standard patch management programmes. Firmware — the low-level software embedded in hardware devices that operates below the operating system — can be a vector for persistent attacks that survive OS reinstallation and are invisible to OS-level security monitoring. The company's hardware security programme includes firmware version management for all managed network devices, servers, and storage systems. Firmware updates are applied on the same risk-based SLA schedule as operating system security patches. Where a firmware update

cannot be immediately applied due to compatibility concerns, the specific vulnerability being addressed must be documented and a compensating control or remediation timeline approved by the ISM.

### 17.3 Secure Software Delivery to Clients

When the company delivers software directly to clients — through code deployment to client-managed environments, through delivery of packaged software releases, or through APIs and integrations connecting company-managed services to client systems — the security of that delivery process is both a contractual and an ethical obligation. A client who receives software from the company has the right to confidence that what they received is exactly what the company built and tested, without modification or addition by any intermediate party. The company's secure software delivery procedures are designed to provide that confidence through cryptographic integrity assurance, verified delivery channels, and documented delivery records.

All software releases delivered to clients must be cryptographically signed by the company's code signing certificate before delivery. The signature allows the client to verify, at any subsequent point, that the delivered software is identical to the version that was signed by the company and has not been modified since. Code signing private keys are held in HSM-backed key management infrastructure, and the signing process requires authentication by a named member of the release management team and generates an audit log entry for every signing event. Releases that have not been signed, or where the signature cannot be verified against the company's published signing certificate, must not be deployed to client production environments.

Delivery channels for software releases to clients must be encrypted and access-controlled. Software releases classified at the Confidential level — which includes proprietary application code and configurations — must be delivered through the company's secure file transfer platform or through client-specific secure channels specified in the project delivery agreement. Delivery through unencrypted channels, personal file sharing services, or public file hosting platforms is prohibited. All deliveries must be accompanied by a delivery record that captures the hash of the delivered artefact, the delivery channel used, the date and time of delivery, the identity of the person who authorised and executed the delivery, and the client representative who received and acknowledged receipt.

## 18. Mobile and Remote Workforce Security

### 18.1 Mobile Security Architecture

The mobile and remote workforce represents both the company's most productive operating model and its most geographically distributed security challenge. Employees accessing company systems from a home office, a client site, a hotel, or a conference venue are operating outside the company's physical and network perimeter, relying on infrastructure — home broadband routers, hotel Wi-Fi, mobile carrier networks — that is managed by third parties with security standards that are entirely outside the company's control. The mobile security architecture must compensate for the absence of perimeter controls by placing security directly on the device and in the identity layer, ensuring that the security controls travel with the employee regardless of where they are working.

The company's mobile security framework rests on three pillars. Device management ensures that every device used to access company data meets a defined minimum security standard — encrypted, running current OS, endpoint protection active, and MDM-managed — before access is permitted. Identity assurance ensures that every access request to a company system requires strong authentication regardless of the device's network location, eliminating the implicit trust that was historically extended to devices on the corporate network. Network security ensures that all traffic between the employee's device and company systems is encrypted and routed through the company's monitoring infrastructure via the mandatory VPN, providing visibility and threat detection capability even for distributed workforce traffic.

Device health checking is enforced through the MDM conditional access policy, which evaluates a set of device compliance criteria at every authentication attempt and blocks or challenges access where compliance criteria are not met. The compliance criteria evaluated include: OS version within the approved range; last security patch applied within 30 days; full-disk encryption active; endpoint protection active with current signatures; no known malware detected; screen lock active with minimum complexity; no active jailbreak or root; and MDM profile installed and not tampered with. Devices that fail one or more compliance criteria receive an access denial with a specific error message indicating which criterion is not met and providing instructions for remediation. Compliance criteria violations are logged and reported monthly to the ISM.

The increasing adoption of collaboration and productivity tools delivered as cloud services — email, video conferencing, project management, and document collaboration — means that a significant portion of the company's employees' working day involves access to company data through browser-based interfaces rather than through traditional thick-client applications. Browser security is therefore a significant dimension of the mobile security architecture. All company-managed devices must use an approved browser with security extensions including the company's approved ad and script blocker, the phishing site detection extension, and the password manager extension. Browser extensions not on the company's approved list must not

be installed on company devices, because browser extensions typically have access to all content displayed in the browser, including any sensitive data.

### 18.2 International Travel Security

Business travel to international destinations introduces information security risks beyond those of domestic remote working. In addition to the standard risks of working from an unfamiliar network environment, international travellers face risks specific to certain destinations: nation-state surveillance of electronic communications and data, mandatory device inspection by border authorities, physical theft of devices in high-crime areas, and the legal restrictions on encryption and VPN use that exist in certain countries. The company's international travel security programme provides employees with the knowledge, tools, and protocols they need to protect company information during international business travel.

Employees travelling to destinations on the IT Security team's High-Risk Travel Advisory — which currently includes China, Russia, Iran, North Korea, and several other countries with active state-level cyber surveillance programmes — must complete the international travel security briefing with the IT Security team before travel and must use a travel loaner device provided by IT Operations rather than their standard company laptop. Travel loaner devices are clean devices with no company data on them — employees access company systems through the browser and VPN during travel, without storing data locally, and the device is wiped and reimaged upon return. This prevents a device inspection at a border from resulting in access to historical company data or to stored credentials.

Even for travel to lower-risk international destinations, employees must follow specific protocols that go beyond the standard remote working requirements. These protocols include: enabling full-disk encryption before departure and confirming that the encryption is active; not connecting to hotel Wi-Fi or conference venue Wi-Fi without immediately activating the VPN; ensuring the VPN is active before opening any company application or service; enabling the device's privacy screen filter to prevent shoulder surfing on public transport and in airports; being physically present when company devices are sent through airport security scanning rather than placing them in trays that move out of the traveller's sight line; not leaving company devices in hotel rooms unattended without activating the screen lock and physically securing them where possible; and not discussing sensitive company or client information in public spaces, restaurants, or hotel lobbies where conversations can be overheard.

### 18.3 Security for Conference and Public Speaking Engagements

Employees who represent the company at industry conferences, client events, and public speaking engagements face specific information security considerations related to the public presentation of technical and business information. A conference presentation or demonstration that inadvertently reveals proprietary system architecture, security control details, client data, or

non-public business information can cause information security harm equivalent to a data breach, because the information is disclosed to a large, uncontrolled audience from which it cannot be recalled. The company's conference security guidelines exist to prevent these inadvertent disclosures through a review process that evaluates presentations for sensitive content before they are delivered publicly.

All external presentations, conference papers, and public demonstrations that contain information about company technology, systems, or business practices must be reviewed by the ISM and the relevant business unit head before delivery. The review focuses on identifying: any technical details about company security controls, network architecture, or system vulnerabilities that could assist an attacker; any client data or identifiable references to client projects without explicit client approval; any non-public financial, commercial, or strategic information; and any proprietary technology or methodology that the company has not decided to make public. The review process must be completed at least two weeks before the scheduled delivery date. Presentations that are submitted for review less than two weeks before the delivery date will be reviewed on a best-efforts basis, but the company cannot guarantee review completion within the compressed timeline.

Live demonstrations — where a presenter shows working company software or systems during a conference presentation — require specific precautions to prevent the inadvertent disclosure of real data. All live demonstrations must use a dedicated demonstration environment that contains only synthetic or anonymised data. Real client data must never be used in a live demonstration environment, even if the individual client data records appear innocuous in isolation. Demonstration environments must not be connected to production systems during the demonstration. Presenters must test their demonstration in the exact configuration that will be used at the event before the event, to identify and address any unexpected system behaviour that could expose unintended information. The ISM must approve the demonstration environment configuration before the first public use.

## Appendix A: Security Incident Classification Reference

This appendix provides a detailed reference for classifying security incidents at Arjun Technologies. Correct classification is essential because it determines the response resources deployed, the escalation path, and the external notification obligations that may apply. Classification is always an initial judgement made with incomplete information — incidents may be reclassified as the investigation reveals additional details. All reclassifications must be documented in the incident record with the reason for the change and the name of the person who authorised it.

The four priority levels — P1 Critical, P2 High, P3 Medium, and P4 Low — are defined in Section 6.2 of Segment 1. This appendix provides additional guidance on the classification of specific incident types that are commonly encountered and where classification judgement is most frequently required. The guidance below is authoritative for the incident types listed, but the ISM always has the authority to override the classification of a specific incident based on the full context of that incident if the standard guidance would produce a materially wrong outcome.

| Incident Type | Default Classification | Key Factors That Increase Severity | Key Factors That Reduce Severity | External Notification T |
|---|---|---|---|---|
| Phishing email received but not acted upon | P4 | Volume suggesting targeted campaign; executive impersonation | Single generic phishing email; no interaction; known sender | No notification required |
| Phishing link clicked but no credential entered | P3 | User clicked on link to known credential harvesting page | Endpoint detection blocked payload; no data exfiltration observed | Notify affected user's manager |
| Credentials entered on phishing page | P2 | Privileged account credentials; MFA not enabled on account | Credentials for low-privilege account; MFA active and not bypassed | Notify affected user; consider |
| Lost or stolen device — encrypted | P3 | Device contained Restricted data; device not encrypted | Standard-issue device; device encrypted; remote wipe confirmed | Notify Data Protection Officer |
| Lost or stolen device — unencrypted | P1 | Any device containing Confidential or Restricted data | No compensating factors | Data breach notification if p |
| Malware detected on endpoint — quarantined | P3 | Credential-stealing malware type; lateral movement detected | Generic adware; no network activity detected; isolated device | No notification required |
| Ransomware — isolated to single endpoint | P2 | Spread to network share detected before containment | Single endpoint; contained before encryption began | Notify affected department |
| Ransomware — spreading on network | P1 | Multiple systems affected; backup infrastructure targeted | Limited scope; offline backups confirmed intact | Data breach assessment within |
| Unauthorised access to production database | P2 or P1 | Customer personal data accessed; large number of records | Access limited to non-sensitive tables; short duration | Notify DPO; DPB |
| Public cloud storage bucket misconfigured | P2 or P1 | Confirmed public access; sensitive data indexed by search engines | Bucket contained only non-sensitive data; misconfiguration detected | Notify DPO; potential |

## Appendix B: Acceptable Use Policy — Full Text

This Acceptable Use Policy governs the use of all information technology resources provided by or managed by Arjun Technologies Pvt. Ltd., including company-owned and company-managed computers, mobile devices, networks, internet connectivity, software applications, cloud services, email systems, and collaboration platforms. By using these resources, every employee and contractor acknowledges their personal obligation to comply with this policy in full. This policy should be read in conjunction with the IT Security Policy and Procedures Manual, of which it forms a part. Where this AUP and any other company policy conflict, the more restrictive provision applies.

**Permitted Uses.** Company IT resources are provided primarily for business purposes. Employees may use company IT resources for their designated work responsibilities, for communication with clients, colleagues, and vendors in the conduct of company business, for accessing information and tools necessary for their role, for participation in company-provided training and development programmes, and for incidental, brief personal use of communication and information tools during the working day, provided such use does not impair work performance, consume significant network resources, create a security risk, violate any law, or conflict with any other provision of this policy. Incidental personal use is a tolerance extended at the company's discretion and does not create any right or entitlement.

**Prohibited Uses — Absolute.** The following uses are prohibited under all circumstances and will be treated as serious disciplinary matters regardless of intent or claimed purpose: accessing, storing, or transmitting illegal content of any kind including child sexual abuse material, content promoting terrorism, or content that infringes copyright in a material way; using company systems for personal commercial activities, secondary employment, or any revenue-generating activity for personal benefit; installing any software, application, browser extension, or tool on a company device without prior IT approval; attempting to access systems, data, or areas for which the individual is not authorised; using company systems to harass, bully, intimidate, or target any individual; accessing another person's account, email, or files without their explicit permission and documented business justification; mining cryptocurrency using company computing resources; and deliberately circumventing or testing any security control, monitoring system, or access restriction.

**Prohibited Uses — Conditional.** The following uses are prohibited without specific prior approval from the appropriate authority: sending Confidential or Restricted information to any external party without a signed NDA and, for personal data, a DPA; accessing company systems from a country on the High-Risk Travel Advisory without completing the international travel security briefing; connecting a personal device to company systems without completing the BYOD enrolment process; transmitting company source code to any external system, repository, or service not on the Approved Systems list; and making public statements in a professional context that represent the company's position on any matter without Communications team approval.

**Monitoring.** Employees should have no expectation of privacy when using company IT resources. The company monitors the use of its IT resources for the purposes of security, compliance, and operational management. Monitoring activities include the review of network traffic logs, email security gateway logs, web proxy logs, endpoint activity logs, cloud service access logs, and SIEM event data. Monitoring is conducted by the IT Security team in accordance with the company's security policies and with the requirements of applicable law. Employees are informed of monitoring through this policy. Monitoring data is accessed and used only for legitimate security and operational purposes, and is handled in accordance with the

Data Privacy Policy.

## Appendix C: Security Configuration Baseline Standards

This appendix defines the minimum security configuration standards that must be applied to all company-managed systems. Configuration baselines ensure that every system deployed in the company's environment starts from a secure, consistent state rather than from a vendor default configuration that is optimised for ease of use rather than security. Vendor default configurations typically enable more features and services than most deployments require, use well-known default credentials, and disable security controls that create initial setup friction. Applying the configuration baseline eliminates these vulnerabilities systematically across all deployed systems.

Configuration baselines are defined for each major category of system: Windows workstations, macOS workstations, Linux servers, Windows servers, network infrastructure devices, cloud infrastructure, and mobile devices. Each baseline is aligned with the Centre for Internet Security Benchmarks for the relevant platform, adjusted where necessary to reflect the company's specific operational requirements. Baselines are reviewed and updated annually by the IT Security team in conjunction with the IT Operations team, and are additionally updated whenever a significant OS version change or a major security finding warrants a mid-year revision.

| System Category | Baseline Standard | Key Configuration Requirements | Hardening Tool | Compliance Verificatio |
|---|---|---|---|---|
| Windows Workstations | CIS Windows 11 Benchmark Level 1 | BitLocker mandatory; Windows Defender Firewall enabled; UAC | Active Directory Group Policy | Monthly automated scan |
| macOS Workstations | CIS macOS 14 Benchmark Level 1 | FileVault mandatory; XProtect and Gatekeeper active; firewall enabled; screen | Jamf Pro configuration profiles | Monthly MDM compliance report |
| Linux Servers (Ubuntu 22.04 LTS) | CIS Ubuntu Linux 22.04 LTS Benchmark Level 2 | AppArmor enforcing; UFW configured; SSH key-only authentication; root login | Ansible playbooks | Quarterly automated scan |
| Network Devices (Cisco IOS XE) | CIS Cisco IOS 16 Benchmark | SSHv2 only (Telnet disabled); SNMPv3 only; NTP configured; unused ports sh | Oxidized configuration management | Quarterly manual audit |
| Cloud (AWS) | CIS AWS Foundations Benchmark v1.5 | Root MFA mandatory; CloudTrail all-regions enabled; S3 public access block | AWS Config Rules; Security Hub | Continuous automated |
| Cloud (Azure) | CIS Microsoft Azure Foundations Benchmark v2.0 | Defender for Cloud Standard; MFA for all users; Privileged Identity Management | Azure Policy; Defender for Cloud | Weekly automated scan |
| Mobile Devices (iOS) | CIS Apple iOS 17 Benchmark Level 1 | Passcode minimum 6 digits; Face ID or Touch ID; Auto-lock 2 minutes; MDM | MDM (Jamf Pro) policy | Monthly MDM compliance report |
| Mobile Devices (Android) | CIS Google Android 14 Benchmark Level 1 | 6-digit PIN; full-device encryption; Google Play Protect enabled; Developer | MDM (Microsoft Intune) policy | Monthly MDM compliance report |

Deviations from the configuration baseline must be approved through the formal exception process described in Section 1.6. A system that cannot immediately meet the full baseline — for example, a legacy application server that requires an older TLS version or a specific open network port — must have a documented exception with a compensating control and a remediation timeline. The ISM reviews all open exceptions at each quarterly Steering Committee meeting. Exceptions that have been outstanding for more than six months without documented progress toward remediation are escalated to the CTO.

New systems provisioned in the company's environment — whether on-premises or in the cloud — must be built from approved, hardened base images rather than from vendor-provided default images. The IT Security team maintains a library of approved base images for each major

platform, built from the vendor's official release and hardened to the company's configuration baseline. These approved base images are the mandatory starting point for all new system provisioning. Using an unapproved base image — including a vendor's marketplace image, a community-contributed image, or a personal image — to provision a system that will handle company data is a policy violation regardless of the apparent security quality of the image. The provenance of the base image must be verifiable, and the configuration baseline compliance of any system provisioned from an external image must be verified by the IT Security team before the system is permitted to process company data.

## Appendix D: Key Contacts and Escalation Directory

The following table provides the contact information for all individuals and teams who play a role in the company's information security programme. This directory is maintained by the IT Security team and is updated whenever personnel changes or contact details change. The current version of this directory is always available on the IT Security intranet page.

| Role | Name | Email | Direct Phone | Escalation For |
|---|---|---|---|---|
| Chief Technology Officer | Mr. Vikram Nair | vikram.nair@arjuntech.in | +91-80-4455-0010 | Security strategy; material policy |
| Information Security Manager | Mr. Ashwin Kumar | ashwin.kumar@arjuntech.in | +91-80-4455-0201 | All security incidents; policy exce |
| IT Security Incident Hotline | — | security@arjuntech.in | 0800-XXX-XXXX (24/7) | Reporting all security incidents – |
| IT Operations Lead | Mr. Rajan Pillai | rajan.pillai@arjuntech.in | +91-80-4455-0202 | Infrastructure issues; access pro |
| IT Service Desk | — | itsupport@arjuntech.in | +91-80-4455-0200 | Access requests; software appro |
| General Counsel | Mr. Sandeep Iyer | sandeep.iyer@arjuntech.in | +91-80-4455-0030 | Legal compliance questions; reg |
| VP Human Resources | Ms. Priya Menon | priya.menon@arjuntech.in | +91-80-4455-0100 | HR-related security matters; insi |
| MDR Provider — 24/7 SOC | — | mdr-escalation@provider.com | Provided in MDR SLA document | P1 and P2 incident triage and in |
| Forensic Investigation Retainer | — | Contact via ISM | Available on request | Major incident forensic support; |
| External Legal Counsel (Data Privacy) | — | Contact via General Counsel | Available on request | Regulatory notifications; data su |

**Arjun Technologies Pvt. Ltd.**
Bengaluru, Karnataka — 560 001
CIN: U72200KA2008PTC044521 | www.arjuntech.in

# INFORMATION TECHNOLOGY SECURITY POLICY AND PROCEDURES MANUAL

Segment 3 of 3 — Risk Management · Penetration Testing · Architecture · Detection · Appendices A–I

| | | | |
|---|---|---|---|
| **Version** | 3.5 | **Effective Date** | 01 January 2024 |
| **Review Date** | 31 December 2024 | **Classification** | Internal Use Only |
| **Policy Sponsor** | Mr. Rajesh Arjun | **Document Owner** | Mr. Ashwin Kumar |
| **Approved By** | Mr. Vikram Nair | **Legal Review By** | Mr. Sandeep Iyer |
| **Alignment** | ISO/IEC 27001:2022 | **HR Acknowledgement** | Ms. Priya Menon |
| **Doc Ref.** | IT-SEC-POL-001-v3.5 | **Segment** | 3 of 3 (Pages 121–180) |

*This final segment of the Arjun Technologies Pvt. Ltd. IT Security Policy and Procedures Manual completes the three-segment document. It covers the information security risk management methodology and risk register, penetration testing programme requirements, security architecture and Zero Trust roadmap, detection engineering and threat hunting, and the complete suite of supporting appendices including the security glossary (Appendix A), forms catalogue (Appendix B), configuration baseline quick reference (Appendix C), incident classification guide (Appendix D), approved tools register (Appendix E), security KPI definitions (Appendix F), penetration test scope template (Appendix G), third-party risk assessment criteria (Appendix H), and the policy acknowledgement form (Appendix I). All queries regarding this policy should be directed to Mr. Ashwin Kumar at itsecurity@arjuntech.in.*

## 19. Information Security Risk Management

### 19.1 Risk Management Methodology

Information security risk management is the systematic and continuous process through which Arjun Technologies identifies, analyses, evaluates, and treats the risks that threaten the confidentiality, integrity, and availability of its information assets. The risk management framework is not a periodic compliance exercise — it is the foundational engine of the ISMS and the primary mechanism through which the company decides which security controls to implement, at what level of rigour, and with what priority of investment. Security controls that are not grounded in a documented risk assessment are arbitrary choices that may not address the most significant actual risks; controls that are systematically derived from a risk assessment are proportionate, defensible, and far more likely to produce meaningful security outcomes. The company follows ISO/IEC 27005:2022 as its risk management methodology, which is designed specifically for information security risk and is fully aligned with the broader ISO 31000 enterprise risk management standard and with the risk management requirements of ISO/IEC 27001:2022.

The annual information security risk assessment is conducted by the ISM each October, timed to produce the updated risk register and risk treatment plan that will govern the security programme's investment priorities for the following calendar year. The assessment is a structured collaborative exercise involving the ISM, the IT Operations lead, the IT Security Business Partners embedded within each major business division, and subject-matter experts from the relevant business units who understand the operational context of the assets and processes being assessed. The exercise takes approximately four weeks from initial scoping to final sign-off by the IT Security Steering Committee at the November quarterly meeting. The assessment produces three primary outputs: the Risk Register, the updated Risk Treatment Plan, and the revised Statement of Applicability confirming which of the ISO 27001:2022 Annex A controls are applicable to the company and their current implementation status.

The risk identification phase begins with a review and update of the information asset inventory, confirming that the register of assets within the ISMS scope is current and complete. Assets are grouped into five categories: information assets (data, documents, databases), software assets (applications, operating systems, development tools), physical assets (hardware, telecommunications equipment, removable media), service assets (cloud services, utilities, third-party services), and people assets (employees, contractors, visitors with system access). For each asset category, the assessment identifies the relevant threats — events or conditions that could cause harm to the asset — and vulnerabilities — weaknesses in the asset or its controls that a threat could exploit. The threat landscape component of the identification phase draws on the year's threat intelligence programme output, the annual penetration test findings, security incident data from the preceding twelve months, CERT-In advisories and bulletins, and

current intelligence about the threat actors most commonly targeting Indian IT services companies.

Likelihood and impact scores are assigned on a 1-to-5 scale, and each score is assigned to the residual risk — the risk level after the application of existing controls — rather than to the inherent risk, which is the risk without any controls. This approach ensures that the risk register reflects the company's actual security posture rather than a theoretical worst case, and means that the investment in existing controls is appropriately recognised in the risk assessment. Likelihood is scored based on the combination of the threat actor's motivation and capability, the attractiveness of the company's specific assets as targets, and the effectiveness of the existing preventive controls. Impact is scored based on the potential financial loss, regulatory penalty, operational disruption, and reputational damage that would result from a successful attack on the asset. The residual risk score — the product of the likelihood and impact scores — determines the treatment priority. Risks scoring 1 to 4 are accepted without mandatory treatment. Risks scoring 5 to 9 require documented monitoring. Risks scoring 10 or above require a formal treatment plan approved by the Steering Committee.

The risk register is maintained by the ISM as a living document that is updated continuously as new information becomes available, not merely annually. Risk owners — the senior managers responsible for the assets and processes associated with each identified risk — are required to report any material change in risk status to the ISM as soon as it becomes known, whether that change arises from a new vulnerability being discovered, a significant change in the threat landscape, the successful implementation of a planned control, or a change in the company's operations that affects the asset's exposure profile. The ISM updates the register to reflect reported changes and escalates any risk whose score has increased above the acceptance threshold since the last formal assessment to the Steering Committee for a risk treatment decision. This dynamic maintenance of the risk register is a requirement of ISO 27001:2022 and is verified during surveillance audits.

### 19.2 Current Risk Register Summary

The following table provides a summary of the top-priority risks in the company's current information security risk register. The full risk register maintained by the ISM contains over sixty individual risk entries covering all ISO 27001 control domains, client-specific risks, and regulatory compliance risks. The entries below represent those with the highest residual risk scores as of the January 2024 review, and are presented to the IT Security Steering Committee at each quarterly meeting with a status update from the respective risk owner. All entries in the full register are reviewed in their entirety at the annual risk assessment.

| ID | Threat | Asset | L | I | Score | Primary Controls | Treatment Status |
|---|---|---|---|---|---|---|---|
| ISR-001 | Phishing and business email compromise leading to credential theft | Corporate identity and Active Directory | 4 | 5 | 20 | Email gateway, MFA enforcement, EDR, security awareness training | Active — ongoing |

| ID | Threat | Asset | L | I | Score | Primary Controls | Treatment Status |
|---|---|---|---|---|---|---|---|
| ISR-002 | Ransomware encryption of production systems | All production systems | 4 | 5 | 20 | EDR with auto-isolation; network segmentation; immutable backups | Active — implementation in progress |
| ISR-003 | Cloud misconfiguration resulting in public data exposure | AWS, Azure, GCP environments | 4 | 5 | 20 | CSPM platform; IaC security gates; quarterly access reviews | Active — CSPM onboarding complete; review cadence established |
| ISR-004 | Insider data exfiltration — departing employee copying source code | Git repositories, internal file shares | 3 | 4 | 12 | DLP; access logging; UEBA alerts; offboarding checklist | Active — UEBA tuning in progress |
| ISR-005 | Exploitation of unpatched vulnerability in customer-facing web application | Customer portal, public APIs | 3 | 4 | 12 | Monthly DAST; SAST in CI/CD; patching SLA per severity | Active — SLA adherence tracked monthly |
| ISR-006 | Software supply chain compromise through malicious or vulnerable third-party dependency | Build pipeline, production releases | 3 | 5 | 15 | SCA scanning; SBOM generation; dependency pinning; code signing | Active — SBOM generation in progress |
| ISR-007 | Social engineering targeting finance staff leading to fraudulent payment | Finance systems, ERP | 3 | 5 | 15 | Dual-approval for payments; phishing-resistant MFA; annual security awareness training; DMARC enforcement | Active — DMARC reject policy implemented |
| ISR-008 | Regulatory non-compliance with DPDP Act 2023 due to inadequate consent management or data retention practices | Personal data of employees, customers, and users | 2 | 5 | 10 | Data inventory; consent management module; retention schedules; annual DPDP compliance review | Active — gap analysis completed; remediation in progress |
| ISR-009 | Physical security breach of on-premises server room leading to theft of hardware or unauthorised access to systems | On-premises servers, network infrastructure | 2 | 4 | 8 | Biometric + card access; CCTV; visitor log; annual physical security audit | Active — CCTV upgrade scheduled for Q3 |
| ISR-010 | DDoS attack causing extended unavailability of customer-facing services | Client-facing APIs, web services | 3 | 3 | 9 | Cloud-native DDoS protection; CDN; rate limiting; incident response playbook | Monitoring — no incidents in 12 months |

### 19.3 Risk Treatment and Monitoring Cadence

Risk treatment plans are developed by the ISM in collaboration with the risk owner and approved by the Steering Committee for all risks scoring 10 or above. Each plan specifies the treatment option selected, the specific control or set of controls to be implemented, the implementation owner, the implementation timeline, the expected residual risk score after treatment, and the metric by which implementation success will be verified. Treatment plans are reviewed at every monthly security dashboard meeting between the ISM and the CTO, and their status is reported to the Steering Committee quarterly. A risk that has not seen meaningful treatment progress for two consecutive months triggers an escalation to the CTO and, where warranted, to the relevant SVP.

The risk monitoring process tracks changes in the residual risk score of all register entries on a continuous basis. The ISM monitors the effectiveness of implemented controls through the security KPI dashboard — which measures outcomes such as patch compliance rates, phishing simulation click rates, and cloud posture scores — and updates the relevant residual likelihood scores when a sustained improvement in a KPI indicates that an implemented control has meaningfully reduced the probability of a successful attack. Conversely, where a KPI deteriorates or a new threat intelligence report indicates that the likelihood of a specific threat has increased, the ISM updates the affected register entries and determines whether the updated score triggers a requirement for additional treatment. This continuous monitoring ensures that the risk register reflects the company's current security posture rather than a point-in-time snapshot from the annual assessment.

## 20. Penetration Testing Programme

### 20.1 Programme Overview and Rationale

A penetration test is an authorised, controlled simulation of a real-world attack against the company's systems, conducted by skilled security professionals with the specific goal of identifying exploitable vulnerabilities before genuine attackers do. It is the most direct available test of whether the security controls documented in this policy are actually working as intended in practice — not in theory, not in a compliance checklist, but in the adversarial, creative, human-driven way that real attackers approach an organisation's defences. The annual penetration test at Arjun Technologies is conducted by an independent third-party specialist firm, not by the internal IT Security team, because independent testing eliminates the inherent bias of testing one's own work and provides the Steering Committee and the Board with an objective assessment of the company's actual security posture.

The penetration testing firm is selected through a rigorous annual procurement process that evaluates technical certifications (CREST, CHECK, OSCP, OSWE, and equivalent), sector-specific experience in testing technology services companies of similar profile and complexity, methodology documentation and approach to the MITRE ATT&CK; framework, references from comparable engagements conducted in the preceding twelve months, and the firm's quality assurance process for findings classification and report quality. The ISM reviews the incumbent firm's performance against all of these criteria annually and makes a recommendation to the CTO on whether to renew the engagement or conduct a competitive tender. The company has conducted external competitive tenders for penetration testing services every three years since the programme began.

The penetration testing programme encompasses four distinct testing activities conducted at different frequencies and with different scopes. The annual external network and web application penetration test simulates an attacker with no prior knowledge of the company's systems attempting to compromise internet-facing infrastructure and client-facing applications from the public internet. The annual internal network penetration test simulates an attacker who has gained a foothold on the internal network — through a compromised employee device or stolen VPN credentials — and attempts to move laterally through the environment, escalate privileges, and access the company's most sensitive systems and data. The biannual application security review provides in-depth coverage of the two to three highest-risk client-facing applications as designated by the ISM, examining application logic, authentication and authorisation flows, API security, input validation, session management, and data handling in significantly more depth than the annual broad-scope test can achieve. The monthly automated vulnerability scan provides continuous coverage of internet-facing systems between the annual penetration tests, identifying newly disclosed vulnerabilities in the software versions and configurations that the company exposes to the internet.

### 20.2 Penetration Test Scope, Rules of Engagement, and Delivery

The scope of each penetration test engagement is defined in a formal Statement of Work, agreed between the ISM and the testing firm and signed by the CTO before any testing commences. The SOW is a legally important document that establishes the authorisation for the testing firm to conduct activities that would otherwise constitute unauthorised access under the IT Act 2000 — without a properly executed SOW, the testing firm's activities are not legally protected. The SOW defines: the specific systems, IP ranges, domain names, and application entry points in scope; the testing window, including the hours during which active testing may be conducted; the prohibited techniques, if any (for example, physical intrusion simulation, direct employee social engineering, and denial of service testing may be excluded from some scopes); the process for pausing or stopping the test if it triggers an unintended operational impact on a production system; the escalation path for critical findings that must be communicated immediately rather than waiting for the final report; and the data handling and confidentiality obligations that apply to the testing firm and its personnel.

| Test Type | Frequency | Scope | Methodology | Deliverables | Remediation SLA |
|---|---|---|---|---|---|
| External Network + Web Application | Annual — Q4 | All internet-facing IPs, DNS hostnames, and web applications | Black-box; no credentials provided; OWASP Testing Guide v4 | Executive summary; technical report with CVSS scores; proof-of-concept for each finding | Critical: 7 days; High: 30 days; Medium: 90 days |
| Internal Network | Annual — Q4 | Internal network from simulated compromised workstation | Assumed-breach; lateral movement and privilege escalation permitted | Executive summary; technical report; attack path diagram | Critical: 7 days; High: 30 days; Medium: 90 days |
| Application Security Review | Annual — Q2 | Top 3 highest-risk client-facing web applications | OWASP Testing Guide v4; authenticated and unauthenticated | Executive summary; technical report with CVSS scores; proof-of-concept for each finding | Critical: 7 days; High: 30 days; Medium: 90 days |
| Automated Vulnerability Scan | Monthly | All internet-facing IPs | Authenticated; all internal segments | Vulnerability report; trend analysis | Critical: 7 days; High: 30 days |
| Red Team Exercise | Every 3 years — next 2025 | Full external and internal; no pre-announced boundaries | Adversary simulation; objective-based | Red Team report; detection gap analysis | Per engagement |

### 20.3 Finding Remediation and Verification Process

A penetration test that produces findings which are filed without structured remediation delivers no security value. The value of penetration testing is entirely dependent on the prompt, complete remediation of identified vulnerabilities and the independent verification that each remediation is effective. The company's finding remediation process requires that within five working days of the report being issued, each finding is assigned to a named remediation owner; within ten working days, a remediation plan documenting the specific fix, the timeline, and any compensating controls required during the remediation period is recorded in the ISM's remediation tracker; and progress against each Critical and High finding is reviewed at every weekly security dashboard meeting between the ISM and the CTO until the finding is closed.

For every Critical and High severity finding from a commissioned penetration test, the testing firm conducts a targeted retest of the specific finding after the remediation has been applied. The retest verifies that the fix has genuinely eliminated the vulnerability — not merely its surface manifestation — and that the fix has not inadvertently introduced a new vulnerability in the corrected code or configuration. Findings that are not confirmed remediated in the retest are re-opened in the tracker and the remediation owner must provide a revised timeline and, if the original fix approach was incorrect, a revised remediation strategy. Findings that have been

open for more than twice their defined SLA without confirmed remediation are escalated to the relevant SVP and flagged in the Steering Committee report.

## 21. Security Architecture and Zero Trust Roadmap

### 21.1 Current Security Architecture

The security architecture of Arjun Technologies has evolved significantly over the past four years from a perimeter-centric model — in which the corporate network boundary was the primary trust boundary and devices on the internal network were implicitly trusted — toward a Zero Trust model that evaluates every access request on its own merits, regardless of the requester's network location. This architectural evolution has been driven by three converging trends: the adoption of cloud services that host critical workloads outside the traditional network perimeter; the normalisation of hybrid working that places employees and their devices outside the perimeter for a substantial portion of their working time; and the growing sophistication of attackers who routinely bypass perimeter controls through credential theft and social engineering, making the network perimeter a progressively less reliable security boundary.

The current security architecture operates across three primary planes that together provide defence in depth. The identity plane, built on Azure Active Directory with Conditional Access policies, has become the primary trust boundary. Every access request to any company resource — whether the request originates from within the corporate office, from a home network, or from a hotel Wi-Fi in another country — is evaluated by the Conditional Access policy engine, which assesses the user's identity and authentication strength, the device's compliance status as reported by the MDM platform, the sensitivity of the requested resource, and the sign-in risk score generated by the identity platform's machine learning algorithms, before granting, blocking, or challenging the access. The network plane provides secondary controls through firewall-enforced segmentation, VPN, DNS security, and the SIEM-integrated network monitoring infrastructure. The endpoint plane provides tertiary controls through EDR, MDM-enforced device compliance, application control, and full-disk encryption on every managed device.

The Zero Trust implementation programme is a phased, multi-year initiative with a defined roadmap covering the five Zero Trust pillars identified in NIST SP 800-207: Identity, Devices, Networks, Applications and Workloads, and Data. The Identity pillar is the most mature — MFA is mandatory for all system access, Conditional Access policies are enforced consistently, and FIDO2 hardware keys are being rolled out to all Band 5 and above employees. The Devices pillar is advancing through the MDM compliance enforcement programme and the integration of device health data into access decisions. The Networks pillar is the least mature and represents the most significant architectural investment in the roadmap — specifically the replacement of the traditional flat internal network model with application-level access proxies that enforce identity-based access to specific applications rather than providing broad network access to all internal resources.

### 21.2 Zero Trust Pillar Maturity and Roadmap

| Pillar | Current Maturity (1–5) | Current State Description | 12-Month Target | 36-Month Target | Key Investments Required |
|---|---|---|---|---|---|
| Identity | 3 — Advanced | MFA mandatory for all systems. Conditional Access enforced. PIM for admin accounts. Annual access reviews. | 4 — Optimal | 5 — Leading | FIDO2 keys rollout; Entra ID Governance; passwordless |
| Devices | 3 — Advanced | MDM mandatory for all managed devices. Compliance gating on VPN and cloud access. Device health attestation. | 4 — Optimal | 5 — Leading | Certificate-based device identity; automated remediation |
| Networks | 2 — Basic | Perimeter firewall and segmentation in place. VPN for remote access. Network monitoring via SIEM. | 3 — Advanced | 4 — Optimal | Zero Trust Network Access (ZTNA) to replace VPN; micro-segmentation |
| Applications | 2 — Basic | WAF on public-facing apps. SAST and DAST in CI/CD pipeline. Application-level logging. | 3 — Advanced | 4 — Optimal | Runtime application self-protection (RASP); API gateway |
| Data | 2 — Basic | Data classification policy in place. DLP deployed on email and web. Encryption at rest for databases. | 3 — Advanced | 4 — Optimal | Automated classification; data access governance; DLP |

## 22. Detection Engineering and Threat Hunting

### 22.1 Detection Engineering Framework

Detection engineering is the discipline of systematically designing, implementing, testing, and maintaining the rules, behavioural analytics models, and threat hunting queries that enable the company's security monitoring infrastructure to identify attacker activity within the environment. Effective detection capability is not a static configuration — it is a continuously maintained programme that must adapt to the evolving threat landscape, the company's changing technology environment, and the specific lessons learned from security incidents, penetration tests, and industry intelligence. A detection rule set that comprehensively covered the relevant threat techniques when it was first deployed but has not been reviewed or updated for two years is not current detection capability. The techniques used by threat actors targeting the company's sector evolve continuously; detection rules that do not evolve in parallel create a progressively widening gap between what the company is monitoring for and what attackers are actually doing.

The detection engineering programme is built around the MITRE ATT&CK; framework, which provides a comprehensive, actively maintained taxonomy of the tactics, techniques, and procedures observed in real-world attacks across the full attack lifecycle from initial access through to impact. By mapping the company's current detection rules to the ATT&CK; framework, the ISM maintains explicit visibility of which techniques are currently detected, which are partially covered, and which have no detection capability at all. This coverage map is reviewed quarterly and drives the detection engineering backlog — the prioritised list of new detection rules, detection improvements, and ATT&CK; coverage gaps that the ISM and the MDR provider are working to address. New detection rules are developed collaboratively by the ISM and the MDR provider's detection engineering team, tested in a staging environment against both synthetic attack traffic and benign activity to validate accuracy, and deployed to production with defined alert severity thresholds and escalation paths.

The detection engineering backlog is prioritised based on four factors. The first is relevance: techniques not covered by current detection that are actively used by the threat actor groups most commonly targeting Indian IT services companies receive the highest priority, because they represent the most probable gap between what the company is monitoring for and what an actual attack would involve. The second is impact: techniques whose successful execution would have the highest potential business impact — credential theft leading to account takeover, data exfiltration from production databases, lateral movement toward backup systems — are prioritised ahead of techniques that would have lower impact even if executed successfully. The third is feasibility: some ATT&CK; techniques can be detected reliably from the telemetry the company currently collects; others would require new data sources or detection models that represent significant additional investment. The feasibility score accounts for this difference. The

fourth is operational cost: a detection rule that generates a high volume of false positives creates analyst fatigue and increases the risk that genuine alerts are missed in the noise; rules with a projected high false positive rate require additional tuning investment before they are ready for production deployment.

### 22.2 Threat Hunting Programme

Threat hunting is the proactive, hypothesis-driven search for attacker activity within the environment that has evaded automated detection. The fundamental premise of threat hunting is that sophisticated attackers — particularly those operating in a targeted, persistent manner — are capable of remaining below the threshold of automated detection rules by using legitimate system tools, normal-looking network traffic, and living-off-the-land techniques that blend into the baseline of ordinary activity. Automated detection rules excel at identifying known patterns and significant deviations from baseline, but they have inherent blind spots that a skilled adversary can exploit. Threat hunting applies human expertise and adversarial thinking to search for the subtle indicators of compromise that automated rules do not flag, acting as a complementary capability to automated detection rather than a substitute for it.

Threat hunting activities are conducted monthly by the ISM and the MDR provider's specialist threat hunting team. Each hunting exercise is driven by a specific, testable hypothesis — a statement about an attacker activity that may be occurring in the environment — derived from one of three sources: threat intelligence about techniques being actively used by the groups most relevant to the company's threat profile; coverage gaps in the ATT&CK; detection map; or anomalous patterns in system behaviour that have been flagged by analysts but that have not triggered automated alert thresholds. The hypothesis is tested by querying the available data sources — SIEM aggregated logs, EDR telemetry, DNS query logs, authentication event logs, and cloud platform audit logs — for patterns consistent with the hypothesised technique. Hunts that find evidence consistent with the hypothesis immediately escalate to the incident response process. Hunts that find no evidence are documented and inform the ongoing calibration of automated detection rules.

The threat hunting programme maintains a hunt journal that records every completed hunt: the date, the specific hypothesis, the ATT&CK; technique referenced, the data sources and query logic used, the findings, and the disposition. The hunt journal serves several important functions. It prevents repeated hunting of the same hypothesis without new information, ensuring that the programme consistently generates new insights rather than recycling completed work. It provides an audit trail that demonstrates the proactive nature of the company's security programme to auditors and regulators. It informs the detection engineering backlog by identifying techniques that are consistently hunted but never automated — a strong signal that the technique should be prioritised for automated detection development. And it contributes to the quarterly Steering Committee view of the company's security posture by providing a

narrative of the adversarial activity landscape beyond what KPI metrics alone can convey.

## Appendix A: Information Security Glossary

The following definitions apply to all terms used throughout the IT Security Policy and Procedures Manual. Where a term has a specific statutory definition under the DPDP Act 2023, the IT Act 2000, or any other applicable Indian law, the statutory definition governs for the purposes of legal compliance obligations. For all other terms, the definitions below are the authoritative reference for the purposes of this policy.

| Term | Definition |
|---|---|
| Advanced Persistent Threat (APT) | A sophisticated, long-duration cyberattack in which a threat actor establishes persistent, covert access in |
| Attack Surface | The complete set of entry points and pathways through which an attacker can interact with a system or o |
| Authentication | The process of verifying that an entity is who or what it claims to be, typically through the presentation of |
| Authorisation | The process of determining whether an authenticated entity has permission to perform a specific action o |
| BYOD (Bring Your Own Device) | A policy permitting employees to use personally owned devices to access company systems and data, su |
| CERT-In | The Indian Computer Emergency Response Team — the national nodal agency under MeitY responsible |
| CIA Triad | The three core properties that define information security: Confidentiality (protection against unauthorised |
| CSPM (Cloud Security Posture Management) | A category of technology tools that continuously assess cloud infrastructure configurations against securi |
| CVSS (Common Vulnerability Scoring System) | An open standard for rating the severity of software security vulnerabilities on a scale of 0 to 10, based o |
| CVE (Common Vulnerabilities and Exposures) | A publicly available catalogue of known information security vulnerabilities, each assigned a unique ident |
| DAST (Dynamic Application Security Testing) | Testing of a running application by simulating attacks against it from outside without access to so |
| Data Fiduciary | Under the DPDP Act 2023, any person or organisation that alone or in conjunction with others determines |
| Defence in Depth | A security strategy that deploys multiple independent layers of security controls, such that the failure or b |
| DLP (Data Loss Prevention) | Technology and processes designed to detect and prevent the unauthorised or accidental transmission o |
| DPDP Act | The Digital Personal Data Protection Act, 2023 — India's primary personal data protection legislation, est |
| EDR (Endpoint Detection and Response) | Security software deployed on endpoints that continuously monitors activity for indicators of attack, provid |
| Hardening | The process of securing a system by reducing its attack surface — disabling unnecessary services, apply |
| IaC (Infrastructure as Code) | The practice of defining and managing infrastructure configurations in version-controlled code files, enabl |
| ISMS (Information Security Management System) | A systematic framework of policies, processes, controls, and monitoring activities through which an organ |
| Least Privilege (Principle of) | The security principle that every user, system, process, and service should have access only to the speci |
| MITRE ATT&CK | A globally accessible, continuously maintained knowledge base of adversary tactics, techniques, and pro |
| MFA (Multi-Factor Authentication) | Authentication requiring two or more verification factors from different categories: something the user kno |
| PAM (Privileged Access Management) | A security framework and associated technology for managing, monitoring, logging, and auditing the use |
| Penetration Test | An authorised, controlled simulation of a real-world attack against an organisation's systems, conducted |
| RBAC (Role-Based Access Control) | An access control model in which permissions are assigned to defined roles rather than directly to individ |
| SAST (Static Application Security Testing) | Analysis of application source code or compiled binaries without executing the application, to identify patt |
| SCA (Software Composition Analysis) | Automated scanning of the open-source and third-party component dependencies incorporated into a sof |
| SIEM (Security Information and Event Management) | A platform that aggregates, normalises, correlates, and analyses security event data from across the tech |
| SOC (Security Operations Centre) | A team of security professionals operating on a continuous basis to monitor, detect, investigate, and resp |
| Threat Actor | Any individual, group, or organisation motivated and capable of causing harm to an organisation's inform |

| Term | Definition |
| --- | --- |
| TLS (Transport Layer Security) | The cryptographic protocol used to secure communications across networks, providing encryption in tran |
| Zero Trust | A security architecture principle that eliminates implicit trust based on network location and requires conti |

## Appendix B: IT Security Forms and Templates Catalogue

All forms listed below are available in their current version on the IT Security intranet page and on the HRMS portal under Policies and Documents. Always download the current version before completing any form. Do not use printed copies from a prior period as forms are updated when policy changes require corresponding changes to the data collected or the approval workflow.

| Form ID | Title | Purpose | Who Completes | Submission Path |
|---|---|---|---|---|
| SEC-F001 | Security Incident Report | Initial report of any actual or suspected security incident | Any employee, contractor, or third-party user who identifies or suspects an incident | Emailed to the Security Operations Centre at soc@ and copied to the IT Security Manager; for P1 incidents, also reported by telephone to the on-call IT Security Officer within 1 hour |
| SEC-F002 | Security Policy Exception Request | Formal request for a documented, time-limited exception to a mandatory IT security control | Requesting employee's line manager, countersigned by the IT Security Manager | Submitted via the HRMS portal under Policies and Documents; reviewed by the ISMC at its next scheduled meeting |
| SEC-F003 | System Access Request | Formal request for initial system access, modification, or removal of access rights | Requesting employee's line manager, with input from the system owner | Submitted via the HRMS portal; routed automatically to the relevant system owner for approval |
| SEC-F004 | Privileged Access Justification Form | Supplementary justification required for all requests for privileged or administrative access | Requesting employee and their line manager | Attached to the corresponding SEC-F003 request in the HRMS portal; reviewed by the IT Operations Manager |
| SEC-F005 | Vendor Security Assessment – Tier 1 | Comprehensive security questionnaire for vendors handling Confidential or Restricted data | Vendor's information security officer or designated representative | Returned to the procurement team, who forwards it to the IT Security Officer for evaluation before contract signature |
| SEC-F006 | Vendor Security Assessment – Tier 2 | Standard security questionnaire for vendors with access to Internal data | Vendor's designated representative | Returned to the procurement team, who forwards it to the IT Security Officer for evaluation before contract signature |
| SEC-F007 | Evidence Preservation Checklist | Step-by-step checklist for preserving digital evidence during a security incident | The first responder, typically a member of the IT Operations team | Completed during the incident and submitted to the IT Security Manager as an attachment to the incident report |
| SEC-F008 | Post-Incident Review Report | Structured report produced within 10 working days of the closure of a P1 or P2 incident | IT Security Manager, with input from the incident handler and relevant system owners | Presented to the ISMC at its next meeting; approved by the CTO and stored in the incident management system |
| SEC-F009 | Cloud Resource Provisioning Checklist | Security checklist verified by IT Operations and reviewed by IT Security before any new cloud resource is made live | IT Operations engineer | Reviewed by IT Security via the HRMS portal before the resource is released to the requesting team |
| SEC-F010 | BYOD Enrolment Agreement | Agreement signed by employees before enrolling a personal device in the corporate MDM programme | Employee | Uploaded to the HRMS portal; IT Operations activates the MDM profile only after the agreement is recorded |
| SEC-F011 | Penetration Test Statement of Work Template | Standard template for commissioning penetration tests from external providers | IT Security Manager, in collaboration with the engaging CTO, prior to testing | Signed by the CTO and provided to the testing firm at least 14 days before the planned test window |
| SEC-F012 | Annual Risk Assessment Worksheet | Structured template for the annual information security risk assessment | ISMC members, facilitated by the IT Security Manager | Completed during the annual risk review meeting; the signed worksheet is stored in the ISMS document repository |
| SEC-F013 | Security Training Completion Record | Automated record generated by the LMS on completion of each mandatory security training module | LMS automatically; employee confirms completion via HRMS portal | Stored in the HRMS portal and accessible to the employee, their manager, and HR |
| SEC-F014 | Responsible Disclosure Report | Standard format for external security researchers submitting vulnerability reports | External researcher | Submitted to security@ and acknowledged within 2 working days; tracked to resolution in the vulnerability register |

## Appendix C: Security Configuration Baseline Quick Reference

The following quick reference summarises the mandatory security configuration baselines for each major platform category deployed in Arjun Technologies's environment. These baselines represent the minimum acceptable security configuration for any device or system handling company data at the Internal Use Only level or above. Full baseline specifications, including all individual configuration settings, are maintained in the IT Security team's configuration management repository. Deviations require a formally approved exception per Section 1.6.

| Platform | Baseline Standard | Top 5 Mandatory Settings | Compliance Tool | Review Frequency |
|---|---|---|---|---|
| Windows 11 Workstations | CIS Windows 11 Level 1 | 1. BitLocker full-disk encryption — mandatory<br>2. Windows Defender real-time protection — on<br>3. Windows Firewall — all profiles enabled<br>4. Auto screen lock — 5 minutes maximum<br>5. SMBv1 — disabled | Microsoft Intune + CIS-CAT Pro | Monthly automated MDM compliance |
| macOS 14 Workstations | CIS macOS 14 Level 1 | 1. FileVault full-disk encryption — mandatory<br>2. Gatekeeper and XProtect — enabled<br>3. Firewall — enabled with stealth mode<br>4. SIP (System Integrity Protection) — enabled<br>5. Auto screen lock — 5 minutes maximum | Jamf Pro + CIS-CAT Pro | Monthly automated MDM compliance |
| Ubuntu Linux 22.04 Servers | CIS Ubuntu 22.04 Level 2 | 1. AppArmor — enforcing mode<br>2. SSH — key-based auth only; root login disabled<br>3. UFW firewall — configured; default deny inbound<br>4. auditd — active with security-relevant rules<br>5. Automatic security patches — unattended-upgrades active for Critical | Ansible hardening playbooks + OpenSCAP | Quarterly + Qualys vuln scan; monthly |
| AWS Cloud Accounts | CIS AWS Foundations v1.5 | 1. CloudTrail — enabled all regions, all accounts<br>2. GuardDuty — enabled all regions<br>3. S3 Block Public Access — enabled account-wide<br>4. Root account MFA — FIDO2 hardware key mandatory<br>5. EBS default encryption — enabled with customer KMS key | AWS Config Rules + Security Hub | Real-time via Security Hub; weekly C |
| Azure Subscriptions | CIS Azure Foundations v2.0 | 1. Microsoft Defender for Cloud — Standard tier enabled<br>2. MFA — enforced for all users via Conditional Access<br>3. Privileged Identity Management — enabled for all privileged roles<br>4. Key Vault — all secrets and keys stored here only<br>5. Diagnostic logging — all resources sending to Log Analytics | Azure Policy + Defender for Cloud | Real-time via Defender; weekly CSP |
| iOS Mobile Devices | CIS iOS 17 Level 1 | 1. Passcode — minimum 6 digits; biometric enabled<br>2. Auto-lock — 2 minutes maximum<br>3. Jailbreak detection — MDM compliance policy active<br>4. App Store — managed app distribution only<br>5. AirDrop — disabled in managed profile | Intune MDM | Monthly compliance report |
| Android Mobile Devices | CIS Android 14 Level 1 | 1. Screen lock — minimum 6-digit PIN<br>2. Full-device encryption — verified active<br>3. Unknown sources — disabled<br>4. Developer options — disabled<br>5. Work profile — all company apps in managed container | Microsoft Intune MDM | Monthly compliance report |
| Network Devices (Cisco IOS-XE) | CIS Cisco IOS-XE 16 | 1. SSH v2 only — Telnet disabled<br>2. SNMPv3 — v1 and v2 disabled<br>3. Unused interfaces — administratively shut down<br>4. NTP — configured to company time servers<br>5. Syslog — forwarding to SIEM | Cisco NSO configuration templates | Quarterly configuration audit |

## Appendix D: Security Incident Quick Classification Guide

This guide provides practical classification guidance for the most commonly encountered security incident types at Arjun Technologies. The priority level determines the response timeline, escalation path, and resources deployed. Classification is always an initial judgement — incidents may be reclassified upward as the investigation reveals additional scope or severity. When in doubt, classify higher and de-escalate when the facts support it.

| Incident Type | Default Priority | Key Escalation Triggers | Immediate Action Required | External Notification? |
|---|---|---|---|---|
| Phishing email received — not acted upon | P4 | Volume suggests targeted campaign; executive impersonation | Mark as phishing; block sender; no user action required | No |
| Phishing link clicked — no credential entered | P3 | Link was confirmed credential harvesting page | Isolate device from network; run full malware scan | No |
| Credentials entered on phishing page | P2 | Privileged account; MFA not enabled; lateral movement detected | Reset credentials immediately; revoke active sessions; force password reset on next login | No |
| Lost device — encrypted, remote wipe confirmed | P3 | Device held privileged credentials; data classification unknown | Report to IT Security; confirm remote wipe completed; revoke device certificates | No |
| Lost device — encryption status unknown | P1 | Any possibility of company data exposure | Report immediately to CISO and DPO; initiate breach assessment; legal review required | Yes — DPO and legal assess |
| Malware detected on endpoint — quarantined by EDR | P3 | Ransomware variant; lateral movement indicators; multiple devices | Confirm quarantine; collect forensic image before remediation; notify IT Security | No |
| Ransomware — single endpoint | P2 | Spread to network shares detected; backup systems accessible | Isolate device immediately; do not power off; preserve memory; notify CISO and IT Security | No |
| Ransomware — network spread confirmed | P1 | Multiple systems; backup infrastructure affected; data exfiltration suspected | Activate Incident Response Plan; isolate affected segments; engage DFIR retainer | Yes — CISO, DPO, legal, board |
| Unauthorised access to production database | P2 | Client personal data rows accessed; privileged account used | Revoke access; preserve logs; assess scope; notify DPO within 24 hours | Yes — DPO |
| Public cloud storage bucket exposed to internet | P2 | Confirmed Confidential or Restricted data; data actively accessed by external IPs | Restrict bucket access immediately; preserve access logs; assess data exposure | Yes — DPO and legal if personal data involved |
| Security policy violation — data sent to personal email | P3 | Bulk transfer of Restricted data; repeat offender | Block transfer; preserve evidence; notify HR and manager | No |
| Successful brute-force or password spray on privileged account | P2 | Admin account targeted; geographically anomalous login | Force password reset; revoke all active sessions; review account activity for 30 days | No |

## Appendix E: Approved Security and Productivity Tools Register

The following register lists the security and productivity tools currently approved for use by Arjun Technologies employees, the maximum data classification level for which each tool is approved, and any special conditions that apply. Tools not on this register must not be used with company data above the Public classification without a formal assessment request submitted to IT Security at itsecurity@arjuntech.in.

| Tool Category | Approved Tools | Max Data Classification | Key Conditions | Not Approved Equivalent |
|---|---|---|---|---|
| Password Manager | 1Password Enterprise; Bitwarden Enterprise | Restricted | SSO integration mandatory; personal vaults must not be used for company credentials | LastPass; browser-saved passwords; Chrome/Firefox password sync |
| Multi-Factor Authentication | Microsoft Authenticator; Google Authenticator; hardware security keys (YubiKey 5 Series) | Restricted | Hardware keys required for all privileged accounts and remote access | SMS-based OTP; email-based OTP |
| Secure File Transfer | SFTP via company-managed server; Microsoft SharePoint Online; Box Enterprise | Confidential | Recipient verification required; MFA enforced; DLP policies must be active | Personal Dropbox; personal Google Drive; WeTransfer; personal OneDrive |
| Video Conferencing | Zoom (corporate licence); Microsoft Teams (corporate tenant) | Confidential | Waiting room enabled; recording disabled by default; meeting passwords required | Skype (personal); free Zoom accounts; Google Meet (personal) |
| AI Coding Assistants | GitHub Copilot (company-licensed); Cursor (company-licensed) | Internal | Code suggestions must be reviewed by a human before merge; no customer data in prompts | ChatGPT (free tier); personal GitHub Copilot; any tool trained on company code |
| AI General Tools | Claude.ai (Teams plan); Microsoft Copilot (M365 enterprise) | Internal | Do not paste Confidential or Restricted data; no personal accounts for company work | ChatGPT (free tier); personal accounts for any AI tool |
| Cloud Storage | Google Drive (Workspace account); OneDrive for Business; SharePoint Online | Confidential | Company account only; no personal cloud storage for work files | Personal Dropbox; personal Google Drive; personal OneDrive |
| Code Repositories | GitHub Enterprise (company organisation); GitLab self-managed | Confidential | Branch protection rules enforced; MFA mandatory; no personal repositories for company code | GitHub personal repositories; Bitbucket personal; GitLab.com personal |
| Endpoint Security | CrowdStrike Falcon (EDR); Microsoft Defender for Endpoint | Restricted | Managed by IT; tamper protection enabled; no user-disabled agents | Avast; AVG; Norton; any consumer antivirus |
| VPN | Cisco AnyConnect (company-managed profile); Tailscale (company tenant) | Restricted | Required for all remote access; split tunnelling disabled | NordVPN; ExpressVPN; any personal VPN |

## Appendix I: Policy Acknowledgement and Annual Certification Form

This acknowledgement must be completed by every employee and contractor within 30 days of joining Arjun Technologies Pvt. Ltd. and within 14 days of any material revision to this policy taking effect. Annual re-acknowledgement is completed through the HRMS portal as part of the SEC-101 annual refresher training in January of each year. Completion is tracked by HR and non-completion is escalated to the employee's line manager and HRBP. Employees who have not acknowledged the current policy version may have system access suspended pending acknowledgement.

I confirm that I have received a copy of the Arjun Technologies Pvt. Ltd. Information Technology Security Policy and Procedures Manual, Version 3.5, effective 01 January 2024. I confirm that I have read and understood all three segments of the manual in full. I agree to comply with all requirements set out in this policy and in any subsidiary security standards and procedures issued by the IT Security team. I understand that compliance with this policy is a condition of my employment or engagement, and that violation of its provisions may result in disciplinary action up to and including termination.

| | |
|---|---|
| **Full Legal Name (Print)** | |
| **Employee / Contractor ID** | |
| **Job Title** | |
| **Department / Business Unit** | |
| **Office Location** | |
| **Date of Joining** | |
| **Date of Acknowledgement** | |
| **Employee Signature** | |
| **Line Manager Name (Print)** | |
| **Line Manager Signature** | |

*Submit completed acknowledgements via HRMS under Policies and Documents, or in person to the HR team. For queries contact itsecurity@arjuntech.in.*

### Document Completion — IT Security Policy and Procedures Manual

| Segment | Content | Pages | Status |
|---|---|---|---|
| Segment 1 | Governance · Classification · Access Control · Network Security · Endpoint Security · Incident Response · Third-Party Securit | 1–60 | Published |
| Segment 2 | Cloud Security · Awareness · BCP/DR · Compliance · Secure SDLC · DLP · Physical Security · Cryptography · HR Security · | 61–120 | Published |
| Segment 3 | Risk Management · Penetration Testing · Architecture · Detection Engineering · Appendices · This Document | 121–180 | This |